JAYVIK LABS

Internship Program | Study Material | Maharashtra, India

www.jayviklabs.online | contact@jayviklabs.online | +91 8855843841

Solapur University BCA | Sem V & VI | 2026

NETWORK SECURITY

Complete Study Notes

Punyashlok Ahilyadevi Holkar Solapur University

Bachelor of Computer Applications (BCA)

Semester V & VI | Academic Year 2025–2026

★ TOPICS COVERED ★

Cryptography • DES / AES / RSA • Network Attacks • Firewalls & IDS/IPS
VPN • SSL • TLS • IPSec • Digital Signatures & PKI • Cyber Laws & IT Act 2000
Ethical Hacking • Penetration Testing • Wireless Security • WPA3

2-Mark • 5-Mark • 10-Mark Q&A • Definitions • Diagrams • Previous Year Pattern • Cheat Sheet

Table of Contents

BCA | Network Security | Solapur University | 2025-26

UNIT 1 — INTRODUCTION TO NETWORK SECURITY

1.1. What is Network Security? .....
1.2. Goals of Network Security (CIA Triad) .....
1.3. Types of Security Attacks .....
1.4. Security Services & Mechanisms .....
1.5. OSI Security Architecture .....
1.6. Network Security Model .....

UNIT 2 — CRYPTOGRAPHY

2.1. Introduction to Cryptography .....
2.2. Symmetric Key Cryptography .....
2.3. DES — Data Encryption Standard .....
2.4. AES — Advanced Encryption Standard .....
2.5. Asymmetric Key Cryptography .....
2.6. RSA Algorithm .....
2.7. Diffie-Hellman Key Exchange .....
2.8. Hash Functions — MD5, SHA .....
2.9. Digital Signatures .....

UNIT 3 — AUTHENTICATION & KEY MANAGEMENT

3.1. Authentication Basics .....
3.2. Password Authentication .....
3.3. Kerberos Authentication .....
3.4. Public Key Infrastructure (PKI) .....
3.5. Digital Certificates & CA .....
3.6. SSL / TLS Protocol .....

UNIT 4 — NETWORK ATTACKS & THREATS

4.1. Types of Attacks .....
4.2. IP Security (IPSec) .....
4.3. Denial of Service (DoS) Attacks .....
4.4. Malware — Viruses, Worms, Trojans .....
4.5. Intrusion Detection Systems (IDS) .....

UNIT 5 — FIREWALLS, VPN & WIRELESS SECURITY

5.1. Firewalls — Types & Working .....
5.2. Packet Filtering Firewall .....

5.3. VPN — Virtual Private Network .....

5.4. Wireless Security — WEP, WPA, WPA2 .....

5.5. Email Security — PGP, S/MIME .....

EXTRAS

Important Questions (2/5/10 Marks) .....

Key Definitions Glossary .....

Previous Year Pattern Q&A .....

Exam Info

University: Solapur University | Course: BCA | Subject: Network Security
All 5 Units covered with theory, diagrams, definitions, and Q&A.
Questions marked with [2M], [5M], [10M] for exam weightage.

UNIT 1: Introduction to Network Security

Network security is the practice of protecting computer networks and the data they carry from unauthorized access, misuse, modification, or denial. In today's digital world, where billions of devices are connected, network security has become one of the most critical areas of information technology.

1.1 What is Network Security?

> **Definition: Network Security**
>
> Network Security refers to the policies, practices, technologies, and procedures designed to protect the integrity, confidentiality, and availability of computer networks and data using both hardware and software technologies.

Network security involves multiple layers of protection at the edge and inside the network. Each network security layer implements policies and controls. Authorized users gain access to network resources, while malicious actors are blocked from carrying out exploits and threats.

Why is Network Security Important?

- Protects sensitive data from unauthorized access and theft
- Prevents financial losses due to cyber attacks
- Ensures business continuity and system availability
- Maintains user trust and organizational reputation
- Compliance with legal regulations (GDPR, IT Act 2000)
- Prevents network downtime and service disruption

> **Note:**
>
> Network security is not just about technology — it also involves people, processes, and policies working together to protect network resources.

1.2 Goals of Network Security — CIA Triad

The three fundamental goals of network security are collectively known as the CIA Triad. Every security measure is designed to protect one or more of these three properties.

CIA Triad Diagram

```
+-------------------+
|                   |
|  CONFIDENTIALITY  |
|  (Only authorized |
```

```
                     |   access to data) |
                     +-------------------+
                            /\
                           /  \
                          /    \
                         /      \
    +------------------+/        \+------------------+
    |                  /          \                  |
    |   INTEGRITY     /  CIA TRIAD \   AVAILABILITY  |
    | (Data accuracy)/              \(System always  |
    | & completeness)                \  accessible)  |
    +------------------+            +------------------+
```

1. Confidentiality

> **Definition: Confidentiality**
> Confidentiality ensures that information is accessible only to those authorized to access it. It prevents unauthorized disclosure of data.

Confidentiality means keeping information secret from unauthorized parties. It ensures that sensitive data is accessible only to those with proper authorization. Techniques used include encryption, access control, and data masking.

- Example: Only the bank employee can see your account details, not everyone
- Techniques: Encryption (AES, RSA), Access Control Lists (ACL), VPN
- Threat to Confidentiality: Eavesdropping, Sniffing, Man-in-the-Middle attack

2. Integrity

> **Definition: Integrity**
> Integrity ensures that data is accurate, complete, and has not been tampered with or altered by unauthorized parties during storage or transmission.

Integrity means that data remains unchanged and accurate from source to destination. Any unauthorized modification of data must be detected. It ensures that information is trustworthy and accurate.

- Example: A bank transfer of Rs. 1000 should reach as Rs. 1000, not Rs. 100
- Techniques: Hash functions (MD5, SHA), Digital Signatures, Checksums
- Threat to Integrity: Data modification, Man-in-the-Middle attack, SQL Injection

3. Availability

> **Definition: Availability**
> Availability ensures that information systems and resources are accessible and usable by authorized users whenever they are needed.

Availability means that systems, applications, and data must be available to authorized users when needed. A denial-of-service attack violates availability by making systems unavailable.

- Example: ATM machine should work 24/7 for customers
- Techniques: Redundancy, Load balancing, Backup systems, DDoS protection
- Threat to Availability: DoS/DDoS attacks, Hardware failures, Natural disasters

Property	Goal	Threat	Protection
Confidentiality	Keep data secret	Eavesdropping, Sniffing	Encryption, VPN
Integrity	Keep data accurate	Data tampering, MITM	Hash, Digital Signature
Availability	Keep services running	DoS/DDoS, Crashes	Redundancy, Backup

Exam Important:

Q: Explain the CIA Triad in Network Security. [5M/10M]

Q: Define Confidentiality, Integrity and Availability with examples. [5M]

Q: What are the goals of Network Security? [2M]

1.3 Types of Security Attacks

Definition: Security Attack

A security attack is any action that compromises the security of information or systems. Attacks are classified into Passive Attacks and Active Attacks.

Classification of Security Attacks

```
                    SECURITY ATTACKS
                   /                 \
                  /                   \
         PASSIVE ATTACKS          ACTIVE ATTACKS
        (just observe,           (modify, destroy,
         no modification)         or disrupt data)
              |                        |
    +-----------+--------+    +--------+----------+
    |                    |    |        |           |
 Traffic             Content  Replay  Masquerade  DoS
 Analysis           Release  Attack              Attack
 (who talks          (read               Modification
  to whom?)          data)               of Messages
```

A. Passive Attacks

Definition: Passive Attack

A passive attack involves monitoring or eavesdropping on communication without altering the data. The attacker only observes and collects information. It is difficult to detect because no data is modified.

In passive attacks, the attacker only listens to or monitors the data being transmitted. The data itself is not changed. These attacks violate confidentiality.

- **Traffic Analysis:** Attacker observes patterns of communication — who is communicating, frequency, length of messages — even if the content is encrypted
- **Release of Message Contents:** Attacker reads the actual content of messages (like emails, file transfers) if they are not encrypted

B. Active Attacks

Definition: Active Attack

An active attack involves modification, interruption, or fabrication of data. The attacker actively interferes with data transmission. These attacks violate integrity and availability.

- **Masquerade (Spoofing):** Attacker pretends to be another entity — fakes identity to gain unauthorized access
- **Replay Attack:** Attacker captures data and retransmits it later to produce unauthorized effects (e.g., replay a login packet)
- **Modification of Messages:** Attacker alters a legitimate message — changes amount in a transaction, modifies an email
- **Denial of Service (DoS):** Attacker prevents legitimate users from accessing resources by overwhelming the system with traffic

Attack Type	Category	Violates	Example
Traffic Analysis	Passive	Confidentiality	Watching who emails whom
Eavesdropping	Passive	Confidentiality	Reading unencrypted messages
Masquerade	Active	Authentication	Fake IP address (spoofing)
Replay	Active	Authentication, Integrity	Replay login packet
Message Modification	Active	Integrity	Change bank transfer amount
Denial of Service	Active	Availability	Flood server with requests

Exam Important:

Q: Differentiate between Active and Passive attacks. [5M]

Q: What is a Replay Attack? [2M]

Q: What is Masquerade attack? [2M]

Q: Explain types of security attacks with examples. [10M]

1.4 Security Services & Mechanisms

Security Services

Definition: Security Service

A security service is a service provided by a protocol layer of communicating systems, which ensures adequate security of the system or data transfers. It is defined in X.800 standard.

Security Service	Description	Example
Authentication	Verifies the identity of communicating parties	Login with username/password
Access Control	Controls who can access what resources	File permissions
Data Confidentiality	Protects data from unauthorized disclosure	Encryption of messages
Data Integrity	Detects modification of data	Hash functions, checksums
Non-repudiation	Prevents sender from denying sending a message	Digital Signatures
Availability	Ensures resources are accessible when needed	Redundant servers

Security Mechanisms

Definition: Security Mechanism

A security mechanism is a process or device designed to detect, prevent, or recover from a security attack. Mechanisms implement one or more security services.

- **Encipherment (Encryption):** Converting data to unreadable form using a key
- **Digital Signature:** Mathematical scheme to verify authenticity of message
- **Access Control:** Rules defining who can access what resources
- **Data Integrity Mechanism:** Hash functions to detect tampering
- **Authentication Exchange:** Protocols to verify identity (passwords, tokens)
- **Traffic Padding:** Inserting extra data to make traffic analysis difficult
- **Routing Control:** Selecting secure routes for data transmission
- **Notarization:** Using trusted third party to register communications

1.5 OSI Security Architecture

Definition: OSI Security Architecture

The OSI Security Architecture is defined in ITU-T Recommendation X.800. It provides a systematic way of defining security requirements and characterizing approaches to satisfying those requirements in terms of security attacks, services, and mechanisms.

The OSI Security Architecture has three important aspects:

- **Security Attacks:** Any action that compromises the security of information
- **Security Mechanisms:** Mechanisms to detect, prevent, or recover from security attacks
- **Security Services:** Services that counter security attacks using one or more security mechanisms

OSI Security Architecture Model

```
+-----------------------------------------------+
|          OSI SECURITY ARCHITECTURE            |
+-----------------------------------------------+
|  SECURITY ATTACKS                             |
|  ├── Passive: Traffic Analysis, Eavesdropping |
|  └── Active: DoS, Masquerade, Replay, Modify  |
+-----------------------------------------------+
|  SECURITY SERVICES (X.800)                    |
|  ├── Authentication                           |
|  ├── Access Control                           |
|  ├── Data Confidentiality                     |
|  ├── Data Integrity                           |
|  └── Non-repudiation                          |
+-----------------------------------------------+
|  SECURITY MECHANISMS                          |
|  ├── Encryption, Digital Signature            |
|  ├── Access Control, Authentication           |
|  └── Traffic Padding, Notarization            |
+-----------------------------------------------+
```

1.6 Network Security Model

Definition: Network Security Model

A Network Security Model describes the components and relationships involved in providing security for data transmission over a network. It shows how two parties communicate securely using a trusted third party.

Network Security Model

```
                  Trusted Third Party
               (Key Distribution, Certificate)
                           |
           +--------------+--------------+
           |                             |
    [Sender/Principal A]          [Receiver/Principal B]
           |                             |
    Information  ------>  Secure  -----> Information
    + Security           Channel          Verification
    Transform                            + Security
    (Encrypt)                            Transform
                                         (Decrypt)

    Opponent/Attacker can attempt to:
    - Intercept (Passive)
    - Modify/Inject (Active)
```

The model shows four basic tasks in designing a security service:

1. Design an algorithm for security transformation — encryption or authentication algorithm
2. Generate secret information (keys) to be used with the algorithm
3. Develop methods for distribution and sharing of secret information
4. Specify a protocol to be used by sender and receiver using the algorithm and secret info

1.7 Important Questions — Unit 1

2 Mark Questions

Q: Define Network Security. [2M Marks]

Ans: Network Security refers to policies, practices, and technologies designed to protect computer networks and data from unauthorized access, misuse, or attacks, ensuring confidentiality, integrity, and availability of information.

Q: What is CIA Triad? [2M Marks]

Ans: CIA Triad stands for Confidentiality (keeping data secret), Integrity (keeping data accurate and unchanged), and Availability (ensuring systems are accessible when needed). These are the three fundamental goals of information security.

Q: What is a Passive Attack? [2M Marks]

Ans: A passive attack involves monitoring or eavesdropping on communication without modifying the data. Examples include traffic analysis and release of message contents. It violates confidentiality and is difficult to detect.

Q: What is Non-repudiation? [2M Marks]

Ans: Non-repudiation is a security service that prevents a sender from denying that they sent a message. It provides proof of the origin and integrity of data. Digital signatures are used to provide non-repudiation.

5 Mark Questions

Q: Explain Active and Passive attacks with examples. [5M Marks]

Ans: PASSIVE ATTACKS: Involve only monitoring/observing data without modification. Types: (1) Traffic Analysis — observing communication patterns even if encrypted. (2) Release of Message Contents — reading actual message content. Passive attacks violate confidentiality and are hard to detect. ACTIVE ATTACKS: Involve modification or disruption of data. Types: (1) Masquerade — pretending to be another entity. (2) Replay — capturing and retransmitting valid data. (3) Modification — altering message content. (4) DoS — preventing legitimate access. Active attacks violate integrity and availability.

Q: Explain the CIA Triad in detail. [5M Marks]

Ans: CIA Triad consists of three security goals: 1. CONFIDENTIALITY: Ensures data is accessible only to authorized users. Protected by encryption (AES, RSA), access control, VPN. Threatened

by eavesdropping and sniffing. 2. INTEGRITY: Ensures data is accurate and unmodified. Protected by hash functions (SHA, MD5), digital signatures, checksums. Threatened by data modification attacks. 3. AVAILABILITY: Ensures systems are accessible when needed. Protected by redundancy, load balancing, DDoS protection. Threatened by DoS attacks and hardware failures.

10 Mark Questions

Q: Explain OSI Security Architecture in detail. [10M Marks]

Ans: The OSI Security Architecture (X.800) provides a framework for network security with three components: 1. SECURITY ATTACKS: Actions that compromise security. Passive attacks (traffic analysis, eavesdropping) only monitor data. Active attacks (masquerade, replay, modification, DoS) modify or disrupt data. 2. SECURITY SERVICES: Services that counter attacks — Authentication (verifies identity), Access Control (controls access), Data Confidentiality (protects from disclosure), Data Integrity (detects modification), Non-repudiation (prevents denial). 3. SECURITY MECHANISMS: Tools implementing services — Encipherment (encryption), Digital Signatures (authentication), Access Control (permissions), Traffic Padding (hides patterns), Authentication Exchange (protocols). These three components work together to provide comprehensive network security.

Unit 1 (Extended): Network Security — Complete Foundation

1.9 Types of Network Security Controls

Security controls are categorized into three main types based on how they protect systems. Every organization needs all three layers working together.

Control Type	Purpose	Examples	When It Acts
Preventive	Stop attacks before they happen	Firewall, Encryption, Access Control, MFA	Before incident
Detective	Identify attacks happening or already happened	IDS, Log monitoring, SIEM, Antivirus scan	During/after incident
Corrective	Recover and fix after an attack	Backup restore, Patch management, Incident response	After incident
Deterrent	Discourage attackers from attempting	Warning banners, Visible cameras, Legal notices	Before incident
Compensating	Alternative control when primary not feasible	Manual review when automation unavailable	Ongoing

1.10 Defence in Depth

Definition: Defence in Depth

A security strategy that uses multiple layers of security controls so that if one layer fails, another is there to stop the attacker. Based on the military concept of layered defences — no single point of failure.

Defence in Depth — Layered Security Model

```
+-----------------------------------------------+
|          PHYSICAL SECURITY                    |
|  +----------------------------------------+   |
|  |        NETWORK PERIMETER                |   |
|  |  (Firewall, IDS, DMZ)                   |   |
|  |  +-------------------------------------+ |   |
|  |  |       INTERNAL NETWORK               | |   |
|  |  |  (VLANs, 802.1X, NAC)               | |   |
|  |  |  +----------------------------------+ | |   |
|  |  |  |     HOST/ENDPOINT                | | |   |
|  |  |  |  (AV, HIDS, patch management)   | | |   |
|  |  |  |  +-----------------------------+ | | |   |
|  |  |  |  |  APPLICATION SECURITY        | | | |   |
|  |  |  |  |  (WAF, code review, OWASP)  | | | |   |
|  |  |  |  |  +--------------------------+ | | | |   |
|  |  |  |  |  |     DATA SECURITY        | | | | |   |
|  |  |  |  |  |  (Encryption, DLP, DRM)  | | | | |   |
```

```
   |   |   |   |   +--------------------------+ | | | |   |
   Attacker must break through EVERY layer
```

1.11 Security Threats Landscape

1.11.1 Internal vs External Threats

Threat Source	Description	Examples	Detection Difficulty
External Attacker	Person outside the organization attacking remotely	Hacker, cybercriminal, nation-state	Moderate — detected at perimeter
Malicious Insider	Employee intentionally misusing access	Disgruntled employee stealing data, selling credentials	HIGH — has legitimate access
Negligent Insider	Employee accidentally causing breach	Clicking phishing link, weak password, misconfiguration	Moderate — accidental behavior
Third-party/Supply Chain	Vendor or partner with access to systems	SolarWinds attack (2020) — software update trojanized	Very HIGH — trusted access

1.11.2 Threat Actors

Threat Actor	Motivation	Skill Level	Resources	Example
Script Kiddie	Fun, notoriety	Low — uses existing tools	Low	Using LOIC for DoS
Hacktivist	Political/social cause	Medium	Low-Medium	Anonymous, LulzSec
Cybercriminal	Financial gain	Medium-High	Medium	Ransomware gangs
Insider Threat	Revenge, money, ideology	Varies	High (has access)	Edward Snowden
Nation-State APT	Espionage, disruption	Very High	Unlimited	Fancy Bear, Lazarus Group
Terrorist	Fear, disruption	Medium	Medium	Cyber-attacks on infrastructure

1.12 Network Fundamentals Review

1.12.1 TCP/IP Model vs OSI Model

OSI Layer	OSI Name	TCP/IP Layer	Protocols	PDU Name
7	Application	Application	HTTP, HTTPS, FTP, DNS, SMTP, SSH	Data

6	Presentation	Application	SSL/TLS, JPEG, ASCII	Data
5	Session	Application	NetBIOS, RPC, PPTP	Data
4	Transport	Transport	TCP, UDP, SCTP	Segment
3	Network	Internet	IP, ICMP, ARP, IPSec	Packet
2	Data Link	Network Access	Ethernet, WiFi (802.11), PPP	Frame
1	Physical	Network Access	Copper, Fiber, Radio waves	Bits

1.12.2 TCP Three-Way Handshake

Definition: TCP Three-Way Handshake

The process by which a TCP connection is established between client and server. Consists of three steps: SYN, SYN-ACK, ACK. This handshake is exploited in SYN Flood attacks.

TCP Three-Way Handshake

```
  CLIENT                          SERVER
    |                                |
    |--- SYN (seq=x) ------------> |  Step 1: Client wants to connect
    |                                |          Server allocates
resources
    |<-- SYN-ACK (seq=y,ack=x+1)- |  Step 2: Server acknowledges
    |                                |
    |--- ACK (ack=y+1) ----------> |  Step 3: Client confirms
    |                                |
    |====== DATA TRANSFER ========>|  Connection established!

SYN Flood Attack: Attacker sends thousands of SYN packets
  Server allocates resources for each — runs out of memory — DoS!
  Fix: SYN Cookies — server doesn't allocate until ACK received
```

1.12.3 IP Addressing & Subnetting (Security Context)

Address Range	Type	Routable?	Security Use
10.0.0.0/8	Private (Class A)	No — NAT required	Large corporate internal networks
172.16.0.0/12	Private (Class B)	No — NAT required	Medium corporate networks
192.168.0.0/16	Private (Class C)	No — NAT required	Home/small office networks
127.0.0.0/8	Loopback	No	Local testing — localhost
0.0.0.0/0	Default route	—	Firewall default deny rule
255.255.255.255	Broadcast	No	ARP, DHCP — can be abused

1.13 Common Ports & Protocols — Security Reference

Port	Protocol	Service	Secure Alternative	Risk If Open
21	TCP	FTP — File Transfer (plaintext)	SFTP (22) / FTPS (990)	Credentials sniffable
22	TCP	SSH — Secure Shell	Already secure — use key auth	Brute force attacks
23	TCP	Telnet — Remote login (plaintext)	SSH (22)	Full session sniffable
25	TCP	SMTP — Email sending	SMTPS (465)	Open relay, spam
53	UDP/TCP	DNS — Domain resolution	DoH, DNSSEC	DNS poisoning, amplification
80	TCP	HTTP — Web (plaintext)	HTTPS (443)	Session hijacking, MITM
110	TCP	POP3 — Email retrieval	POP3S (995)	Credential theft
143	TCP	IMAP — Email access	IMAPS (993)	Credential theft
443	TCP	HTTPS — Secure web	Already secure (TLS)	SSL stripping if misconfigured
3306	TCP	MySQL Database	Keep behind firewall — no public exposure	SQL injection entry
3389	TCP	RDP — Remote Desktop	VPN + RDP, or NLA auth	BlueKeep, brute force
445	TCP	SMB — Windows file sharing	SMBv3 with encryption	EternalBlue/WannaCry

1.14 Security Policies & Frameworks

Definition: Security Policy

A formal document that states an organization's security rules, standards, and guidelines. It defines what is allowed, what is prohibited, and how security incidents are handled.

Policy Type	What It Covers	Example
Acceptable Use Policy (AUP)	Rules for using organization's IT resources	No personal software, no torrents, work email only for work
Password Policy	Rules for creating and managing passwords	Min 12 chars, uppercase, number, special char, change every 90 days
Access Control Policy	Who can access what resources	Role-based access, least privilege, need-to-know basis
Incident Response Policy	Steps to take when security breach occurs	Detect > Contain > Eradicate > Recover > Lessons learned
BYOD Policy	Rules for personal devices on corporate network	MDM enrollment required, no jailbroken devices, remote wipe allowed
Data Classification Policy	How to categorize and protect data	Public / Internal / Confidential / Secret / Top Secret

Change Management Policy	How to make changes to IT systems safely	Change request, testing, approval, rollback plan, change window

1.15 Security Frameworks & Standards

Framework/Standard	Full Name	Focus	Used By
ISO 27001	Information Security Management System	Complete ISMS — policies, risk, controls	Global enterprises, certification
NIST CSF	NIST Cybersecurity Framework	Identify, Protect, Detect, Respond, Recover	US govt, critical infrastructure
PCI DSS	Payment Card Industry Data Security Standard	Protecting cardholder data	All orgs handling credit cards
HIPAA	Health Insurance Portability & Accountability Act	Healthcare data privacy & security	US healthcare organizations
SOC 2	Service Organization Control 2	Cloud security (Availability, Confidentiality, Integrity)	SaaS companies, cloud providers
GDPR	General Data Protection Regulation	Personal data privacy (EU citizens)	Any org with EU customers
OWASP	Open Web Application Security Project	Web application security	Developers, security testers

1.16 Risk Management

Definition: Risk Management

The process of identifying, analyzing, evaluating, and treating risks to reduce them to an acceptable level. Security spending is justified by risk reduction.

Risk Management Process

```
1. RISK IDENTIFICATION
   Identify assets (what needs protection)
   Identify threats (what can go wrong)
   Identify vulnerabilities (weaknesses)
        |
2. RISK ANALYSIS
   Risk = Likelihood × Impact
   Qualitative: High/Medium/Low
   Quantitative: SLE × ARO = ALE
        |
3. RISK EVALUATION
   Compare risk to acceptable threshold
   Prioritize which risks to treat first
        |
```

```
4. RISK TREATMENT (choose one):
   AVOID — eliminate activity causing risk
   REDUCE — implement controls to lower risk
   TRANSFER — insurance, outsource risk
   ACCEPT — acknowledge risk, do nothing (low risk)
        |
5. MONITOR & REVIEW — ongoing process
```

Term	Formula/Meaning	Example
Asset Value (AV)	Value of the asset being protected	Database server = ₹50 lakh
Exposure Factor (EF)	% of asset lost if threat occurs	Ransomware destroys 80% = 0.80
Single Loss Expectancy (SLE)	SLE = AV × EF	₹50L × 0.80 = ₹40 lakh per incident
Annual Rate of Occurrence (ARO)	How many times per year threat occurs	Ransomware: 0.25 times/year (once in 4 years)
Annual Loss Expectancy (ALE)	ALE = SLE × ARO	₹40L × 0.25 = ₹10 lakh/year
Safeguard Value	If control costs less than ALE — worth buying	Backup system costs ₹2L/year — justified vs ₹10L risk

1.17 Incident Response (IR)

Definition: Incident Response

A structured approach to handling and managing the aftermath of a security breach or cyberattack. Goal: minimize damage, reduce recovery time, and prevent future attacks.

NIST Incident Response Lifecycle

```
+-----------+    +----------+    +-----------+    +----------+
|PREPARATION|    |DETECTION |    |CONTAINMENT|    | RECOVERY |
|           | -> |    &     | -> | ERADICATE | -> |          |
|  IR plan  |    |ANALYSIS  |    | RECOVER   |    | Restore  |
|  Training |    |          |    |           |    | services |
|  Tools    |    | SIEM     |    | Isolate   |    |          |
+-----------+    |Alerts    |    | Patch     |    +----------+
                 +----------+    +-----------+         |
                                                        v
                                              POST-INCIDENT REVIEW
                                              Lessons learned, improve
```

IR Phase	Activities	Tools/Techniques
Preparation	Create IR plan, train team, set up tools, define roles	SIEM, IR playbooks, contact lists, forensic tools
Detection & Analysis	Identify incident, determine	Log analysis, IDS alerts, threat intelligence,

	scope and severity	SIEM
Containment	Stop the spread — isolate affected systems	Network segmentation, block IPs, disable accounts
Eradication	Remove malware, patch vulnerabilities, fix root cause	AV scan, re-image systems, patch CVEs
Recovery	Restore systems from clean backups, monitor closely	Backup restore, validate integrity, phased return
Post-Incident	Document what happened, update defences, train team	Incident report, lessons learned, tabletop exercise

1.18 Security Operations Center (SOC)

Definition: SOC (Security Operations Center)

A centralized unit of security professionals who monitor, detect, analyze, and respond to cybersecurity incidents 24/7 using tools like SIEM, IDS, and threat intelligence feeds.

SOC Roles & Responsibilities

SOC Analyst (Tier 1): Monitor SIEM alerts, triage incidents, escalate to Tier 2

SOC Analyst (Tier 2): Investigate escalated incidents, perform deeper analysis

SOC Analyst (Tier 3): Hunt for threats proactively, reverse engineer malware

SOC Manager: Oversee operations, reporting to CISO, manage team

Incident Responder: Handle active breaches, coordinate containment and recovery

Threat Intelligence Analyst: Track threat actors, share IOCs, update defences

Forensic Analyst: Digital forensics, evidence collection for legal cases

1.19 Cryptography Introduction (Unit 1 Preview)

Definition: Confidentiality vs Privacy

Confidentiality means data is only accessible to authorized users — a security property. Privacy means individuals control their own personal information — a legal/ethical right. Both are protected by network security measures.

Concept	Confidentiality	Privacy
Focus	Data protection from unauthorized access	Individual control over personal info
Protected by	Encryption, access control, firewalls	Laws (GDPR, IT Act), policies, consent
Violation example	Hacker reads encrypted database	App sells your data without consent
Overlap	Strong security helps protect privacy	Privacy laws require security measures

1.20 Exam Q&A — Unit 1 Extended

Q: What is Defence in Depth? Why is it important? [5 Marks Marks]

Ans: Defence in Depth is a layered security strategy where multiple security controls protect an asset. If one layer fails, others continue to protect. Layers: Physical (locks, guards), Network perimeter (firewall, IDS), Internal network (VLANs, NAC), Host (antivirus, HIDS), Application (WAF, secure coding), Data (encryption, DLP). Importance: No single control is 100% effective. Attackers who bypass one layer still face others. Reduces risk of total compromise. Based on military principle — castle with moat, walls, guards, locks all together. Example: Firewall blocks most attacks; for those that sneak through, IDS detects; antivirus catches any malware that installs.

Q: What is risk management? Explain the four risk treatment options. [10 Marks Marks]

Ans: Risk Management: process of identifying threats/vulnerabilities, assessing impact, and deciding how to treat risks. Steps: (1) Identify: find assets, threats, vulnerabilities. (2) Analyze: calculate risk = likelihood × impact. Quantitative: ALE = SLE × ARO. (3) Evaluate: compare to acceptable risk level. (4) Treat: Four options: AVOID — eliminate the risky activity (e.g., stop collecting sensitive data you don't need). REDUCE (Mitigate) — implement controls to lower likelihood or impact (e.g., install firewall, encrypt data). TRANSFER — shift risk to another party (e.g., buy cyber insurance, outsource to managed security provider). ACCEPT — acknowledge risk exists but cost of control exceeds risk value (only for low risks, needs management sign-off). Monitor: ongoing — risks change as threats evolve.

Q: What is a Security Operations Center (SOC)? [5 Marks Marks]

Ans: A SOC (Security Operations Center) is a 24/7 centralized facility staffed with security professionals who continuously monitor an organization's IT infrastructure for threats. Functions: real-time monitoring of logs, alerts, and events via SIEM; detecting and analyzing security incidents; responding to breaches (containment, eradication); threat hunting (proactively looking for hidden attackers); vulnerability management; compliance reporting. SOC is organized in tiers: Tier 1 monitors and triages, Tier 2 investigates, Tier 3 does advanced analysis and malware reverse engineering. Key tools: SIEM (Splunk, Microsoft Sentinel), IDS/IPS, Threat Intelligence platforms, EDR solutions.

1.21 Important Questions — Unit 1 Extended

2-Mark Questions

1. What is Defence in Depth? Give one example.
2. Define Risk Management. What is ALE?
3. What is a SOC? What do SOC analysts do?
4. Differentiate between internal and external threats.
5. What is an Acceptable Use Policy?
6. What is TCP Three-Way Handshake? Which attack exploits it?
7. List any 4 security frameworks/standards.
8. What is an Incident Response plan? Name its phases.

5-Mark Questions

1. Explain Defence in Depth with a layered diagram.
2. Explain Risk Management process. Define: AV, EF, SLE, ARO, ALE with example.
3. Compare preventive, detective, and corrective security controls with examples.
4. Explain the Incident Response lifecycle (NIST) with all phases.
5. What are threat actors? Classify them by motivation, skill, and resources.

10-Mark Questions

1. Explain Risk Management in detail. Include qualitative vs quantitative analysis, risk treatment options, and a real-world example with ALE calculation.
2. What is a Security Policy? Explain 5 types of security policies with examples. Why are policies essential for network security?
3. Explain the OSI/TCP-IP model from a security perspective. What attacks target each layer and what controls protect each layer?

UNIT 2: Cryptography

Cryptography is the science of securing information by transforming it into an unreadable format. It is the cornerstone of network security, providing confidentiality, integrity, and authentication. The word comes from Greek: 'kryptos' (hidden) + 'graphein' (to write).

2.1 Introduction to Cryptography

Definition: Cryptography

Cryptography is the science of secret writing — the practice of securing communication from third parties (adversaries) by converting plaintext into ciphertext using mathematical algorithms and keys.

Basic Terminology

Term	Definition
Plaintext	Original readable message or data before encryption
Ciphertext	Encrypted, unreadable form of the plaintext
Encryption	Process of converting plaintext to ciphertext using a key
Decryption	Process of converting ciphertext back to plaintext using a key
Key	Secret value used by encryption/decryption algorithm
Cipher	The algorithm used for encryption and decryption
Cryptanalysis	Science of breaking ciphers without knowing the key
Cryptology	Cryptography + Cryptanalysis combined

Basic Encryption/Decryption Model

```
  SENDER                                      RECEIVER
    |                                             |
  [Plaintext]                                 [Plaintext]
    |                                             |
    | + [Encryption Key]       [Decryption Key] +
    |                                             |
 [Encryption]                              [Decryption]
 Algorithm                                 Algorithm
    |                                             |
    +-----> [Ciphertext] ------Network------>   +

            Attacker can see Ciphertext
            but CANNOT read it without key
```

Types of Cryptography

Type	Key Used	Example	Speed	Security

Symmetric	Same key for encrypt & decrypt	DES, AES	Fast	Lower (key sharing problem)
Asymmetric	Public key encrypt, Private decrypt	RSA	Slow	Higher
Hash Function	No key (one-way function)	MD5, SHA	Very Fast	Irreversible

Exam Important:

Q: Define Cryptography and explain its basic terms. [5M]

Q: Differentiate between Symmetric and Asymmetric cryptography. [5M]

Q: What is plaintext, ciphertext, encryption and decryption? [2M]

2.2 Symmetric Key Cryptography

Definition: Symmetric Key Cryptography

Symmetric key cryptography uses the SAME key for both encryption and decryption. The sender and receiver must share a secret key before communicating. Also called Secret Key Cryptography or Conventional Cryptography.

Symmetric Key Model

```
  SENDER                  RECEIVER
    |                        |
    |<---- Shared Secret Key ---->|
    |        (Same Key K)          |
    |                        |
 Plaintext              Ciphertext
    |    + Key K                |    + Key K
 [Encrypt]  ----Ciphertext--> [Decrypt]
    |                        |
                        Plaintext

 Key must be exchanged securely BEFORE communication!
```

Advantages of Symmetric Cryptography

- Very fast — suitable for encrypting large amounts of data
- Simple implementation
- Less computational overhead

Disadvantages of Symmetric Cryptography

- Key distribution problem — how to securely share the key?
- Scalability problem — N users need N(N-1)/2 keys
- No digital signatures or non-repudiation

Note:

The biggest problem with symmetric cryptography is key distribution. How do sender and receiver share the secret key securely if they have no existing secure channel?

2.3 DES — Data Encryption Standard

Definition: DES (Data Encryption Standard)

DES is a symmetric block cipher developed by IBM and adopted by NIST in 1977. It encrypts data in 64-bit blocks using a 56-bit key through 16 rounds of substitution and permutation operations.

DES Property	Value
Block Size	64 bits
Key Size	56 bits (64 bits with 8 parity bits)
Number of Rounds	16
Structure	Feistel Network
Status	Insecure — broken in 22 hours (1999)
Successor	Triple DES (3DES), then AES

DES Working — Steps

DES Encryption Process

```
64-bit Plaintext Input
       |
[Initial Permutation (IP)]
       |
  +----+----+
  |         |
 L0(32)    R0(32)    <-- Split into Left and Right halves
  |         |
  |    [F-function]  <-- Expansion + XOR with subkey
  |         |              + S-Box Substitution
  |    [XOR with L0]       + Permutation
  |         |
 R1 = F(R0,K1) XOR L0
 L1 = R0
  |         |
 ... 16 rounds total ...
       |
[Final Permutation (FP = IP-1)]
       |
64-bit Ciphertext Output
```

5. Initial Permutation (IP): The 64-bit plaintext is permuted (rearranged) according to a fixed table
6. Key Generation: 56-bit key generates 16 subkeys (48 bits each) for 16 rounds

7. 16 Rounds: Each round applies the Feistel function: expansion, XOR with subkey, S-Box substitution, permutation
8. Final Permutation (IP-1): Inverse of initial permutation to produce 64-bit ciphertext

Triple DES (3DES)

Definition: Triple DES (3DES)

3DES applies DES algorithm three times to each data block. It uses either 2 or 3 different keys, providing 112-bit or 168-bit effective key length, making it much more secure than DES.

3DES Operation: C = EK3(DK2(EK1(P))) — Encrypt with K1, Decrypt with K2, Encrypt with K3

Exam Important:

Q: Explain DES algorithm with diagram. [10M]

Q: What is DES? Write its properties. [5M]

Q: What is Triple DES and why was it introduced? [5M]

Q: What is the block size and key size of DES? [2M]

2.4 AES — Advanced Encryption Standard

Definition: AES (Advanced Encryption Standard)

AES is a symmetric block cipher selected by NIST in 2001 to replace DES. It encrypts data in 128-bit blocks with key sizes of 128, 192, or 256 bits. It is the current gold standard for symmetric encryption.

AES Property	AES-128	AES-192	AES-256
Block Size	128 bits	128 bits	128 bits
Key Size	128 bits	192 bits	256 bits
Rounds	10	12	14
Security	High	Higher	Highest
Speed	Fastest	Fast	Slower

AES Round Operations

Each AES round (except last) consists of four operations:

9. SubBytes: Each byte replaced using S-Box substitution table — non-linear transformation
10. ShiftRows: Rows of 4x4 state matrix are cyclically shifted left by 0,1,2,3 positions
11. MixColumns: Each column multiplied with fixed polynomial — mixing of bytes
12. AddRoundKey: XOR the state with the round key derived from the original key

AES Encryption Structure

```
128-bit Plaintext
        |
[Initial AddRoundKey]
        |
Round 1: SubBytes -> ShiftRows -> MixColumns -> AddRoundKey
Round 2: SubBytes -> ShiftRows -> MixColumns -> AddRoundKey
...                                                        ...
Round 9: SubBytes -> ShiftRows -> MixColumns -> AddRoundKey
Round 10 (Last): SubBytes -> ShiftRows -> AddRoundKey
        |          (No MixColumns in final round!)
128-bit Ciphertext
```

Feature	DES	AES
Year	1977	2001
Block Size	64 bits	128 bits
Key Size	56 bits	128/192/256 bits
Rounds	16	10/12/14
Security	Broken (1999)	Secure
Speed	Slower	Faster
Current Status	Deprecated	Widely used

Exam Important:

Q: Explain AES algorithm with its structure. [10M]

Q: Compare DES and AES. [5M]

Q: What are the four operations in each AES round? [5M]

Q: What is the block size and key sizes of AES? [2M]

2.5 Asymmetric Key Cryptography

Definition: Asymmetric Key Cryptography

Asymmetric cryptography uses a pair of mathematically related keys: a PUBLIC key (known to everyone) for encryption and a PRIVATE key (kept secret) for decryption. Also called Public Key Cryptography. Introduced by Diffie and Hellman in 1976.

Asymmetric Key Model

```
RECEIVER generates a KEY PAIR:
Public Key (PUb)  — shared with everyone
Private Key (PRb) — kept secret by receiver

SENDER                                RECEIVER
  |                                      |
```

```
  Plaintext                          Plaintext
    |                                     |
    | + Public Key PUb     Private Key PRb +
    |                                     |
 [Encrypt with PUb] --Ciphertext--> [Decrypt with PRb]

  Anyone can ENCRYPT with Public Key
  ONLY receiver can DECRYPT with Private Key
```

Advantages

- Solves key distribution problem — public key can be shared openly
- Supports digital signatures and non-repudiation
- N users need only 2N keys (N public + N private)

Disadvantages

- Much slower than symmetric encryption
- Not suitable for bulk data encryption
- Computationally intensive

Remember:

In practice, asymmetric encryption is used to securely exchange a symmetric session key, then symmetric encryption encrypts the actual data. This is called Hybrid Encryption (used in HTTPS/TLS).

2.6 RSA Algorithm

Definition: RSA (Rivest-Shamir-Adleman)

RSA is the most widely used asymmetric encryption algorithm, invented in 1977 by Ron Rivest, Adi Shamir, and Leonard Adleman. Its security is based on the difficulty of factoring large prime numbers.

RSA Key Generation Steps

13. Choose two large prime numbers p and q (e.g., p=61, q=53)
14. Calculate $n = p \times q$ (e.g., $n = 61 \times 53 = 3233$) — this is the modulus
15. Calculate $\phi(n) = (p-1)(q-1) = 60 \times 52 = 3120$
16. Choose e such that: $1 < e < \phi(n)$ and $\gcd(e, \phi(n)) = 1$ (e.g., e = 17)
17. Calculate d such that: $d \times e \equiv 1 \pmod{\phi(n)}$ (e.g., d = 2753)
18. Public Key = (e, n) = (17, 3233), Private Key = (d, n) = (2753, 3233)

RSA Encryption and Decryption

RSA Formula

```
Key Generation:
```

```
n = p × q  (product of two large primes)
φ(n) = (p-1)(q-1)  (Euler's totient function)
Public Key: (e, n) where gcd(e, φ(n)) = 1
Private Key: (d, n) where d × e ≡ 1 (mod φ(n))

Encryption: C = M^e mod n
(M = plaintext, C = ciphertext, e = public exponent, n = modulus)

Decryption: M = C^d mod n
(C = ciphertext, M = plaintext, d = private exponent)
```

Note:

RSA security relies on the fact that it is computationally easy to multiply two large primes but extremely difficult to factor the resulting large number back into its prime factors.

Exam Important:

Q: Explain RSA algorithm with key generation, encryption and decryption. [10M]

Q: What is the principle behind RSA security? [2M]

Q: Compare Symmetric and Asymmetric Cryptography. [5M]

2.7 Diffie-Hellman Key Exchange

Definition: Diffie-Hellman Key Exchange

Diffie-Hellman is a key exchange protocol that allows two parties to establish a shared secret key over an insecure channel without prior secret communication. Proposed by Whitfield Diffie and Martin Hellman in 1976.

Diffie-Hellman Key Exchange

```
Public parameters: prime p, generator g (known to everyone)

ALICE                                      BOB
  |                                         |
Choose private a                        Choose private b
  |                                         |
A = g^a mod p  ------public A----------->   |
  |                                         |
  |   <---------public B---------  B = g^b mod p
  |                                         |
K = B^a mod p                           K = A^b mod p
  |                                         |
K = g^ab mod p                          K = g^ab mod p
  |                                         |
SAME SHARED SECRET KEY K! (without transmitting it)

Attacker sees: p, g, A, B — but CANNOT compute K
(Discrete Logarithm Problem is computationally infeasible)
```

Important:

Diffie-Hellman is vulnerable to Man-in-the-Middle (MITM) attack if there is no authentication. An attacker can intercept and replace both A and B with their own values.

2.8 Hash Functions — MD5 and SHA

Definition: Hash Function

A hash function is a mathematical one-way function that takes an input of any size and produces a fixed-size output called hash/digest/fingerprint. It is computationally infeasible to reverse the process — you cannot find input from output.

Properties of a Good Hash Function

- **Deterministic:** Same input always produces same output
- **One-way (Pre-image Resistance):** Cannot find input from hash output
- **Collision Resistance:** No two inputs should produce the same hash
- **Avalanche Effect:** Small change in input produces completely different hash
- **Fixed Output Size:** Output is always the same length regardless of input size

Hash Algorithm	Output Size	Status	Use
MD5 (Message Digest 5)	128 bits (32 hex chars)	Broken — not secure	Legacy, checksums only
SHA-1	160 bits (40 hex chars)	Deprecated	Not recommended
SHA-256 (SHA-2)	256 bits	Secure	Bitcoin, SSL/TLS
SHA-512	512 bits	Very Secure	High security systems

Hash Function Example

```
Input: "Hello World"
MD5 hash:   b10a8db164e0754105b7a99be72e3fe5
SHA-256:    a591a6d40bf420404a011733cfb7b190d62c65bf0bcda32b...

Input: "hello World"  (lowercase h)
MD5 hash:   e59ff97941044f85df5297e1c302d260  (completely different!)

This demonstrates the Avalanche Effect.

Hash functions are used for:
- Password storage (store hash, not password)
- File integrity verification (checksums)
- Digital signatures
- Blockchain (each block contains hash of previous block)
```

2.9 Digital Signatures

Definition: Digital Signature

A digital signature is a mathematical scheme for verifying the authenticity and integrity of digital messages or documents. It is the digital equivalent of a handwritten signature, providing authentication, integrity, and non-repudiation.

How Digital Signatures Work

Digital Signature Process

```
SIGNING (by Sender):                VERIFICATION (by Receiver):
                                                  |
Original Message                    Received Message
      |                                   |
[Hash Function]                     [Hash Function]
      |                                   |
 Message Hash                        Hash 1
      |                                   |
[Encrypt with                     Digital Signature
 SENDER'S PRIVATE KEY]                  |
      |                           [Decrypt with
Digital Signature                  SENDER'S PUBLIC KEY]
      |                                  |
Send: Message + Digital Sig       Hash 2
                                         |
                              Compare Hash 1 and Hash 2
                              If equal: Valid Signature!
```

Properties Provided by Digital Signatures

- **Authentication:** Proves the identity of the sender
- **Integrity:** Proves the message was not tampered with
- **Non-repudiation:** Sender cannot deny signing the message

Feature	Handwritten Signature	Digital Signature
Medium	Paper	Electronic document
Forgery	Easy to forge	Computationally infeasible
Verification	Visual inspection	Mathematical verification
Non-repudiation	Weak	Strong
Speed	Manual	Automated
Binding	Loosely bound to document	Strongly bound to document

Exam Important:

Q: Explain Digital Signatures with diagram. [10M]
Q: What is a Hash Function? Explain its properties. [5M]
Q: Differentiate between MD5 and SHA. [5M]
Q: What is Diffie-Hellman Key Exchange? [5M]
Q: What is Non-repudiation? How do digital signatures provide it? [2M]

2.10 Important Q&A — Unit 2

2 Mark Questions

Q: What is Cryptography? [2M Marks]

Ans: Cryptography is the science of securing information by transforming readable plaintext into unreadable ciphertext using mathematical algorithms and keys. It provides confidentiality, integrity, authentication, and non-repudiation.

Q: Define: Plaintext, Ciphertext, Key. [2M Marks]

Ans: Plaintext: Original readable message. Ciphertext: Encrypted unreadable form of plaintext. Key: Secret value used by the encryption algorithm to transform plaintext to ciphertext and vice versa.

Q: What is the key size of DES and AES? [2M Marks]

Ans: DES uses a 56-bit key (64 bits with parity) with 64-bit block size. AES uses 128, 192, or 256-bit keys with a 128-bit block size.

5 Mark Questions

Q: Explain Symmetric and Asymmetric Key Cryptography with differences. [5M Marks]

Ans: SYMMETRIC KEY: Uses same key for encryption and decryption. Fast, simple. Problem: Key distribution. Examples: DES, AES. ASYMMETRIC KEY: Uses two keys — Public Key for encryption, Private Key for decryption. Slow but no key distribution problem. Supports digital signatures. Examples: RSA. KEY DIFFERENCES: Symmetric — one key, fast, bulk data. Asymmetric — two keys, slow, key exchange and signatures. In practice both are combined — asymmetric exchanges symmetric key, then symmetric encrypts data (Hybrid Encryption).

Q: Explain Hash Functions and their properties. [5M Marks]

Ans: A hash function takes input of any size and produces a fixed-size output (hash/digest). Properties: 1. Deterministic — same input gives same output always. 2. One-way — cannot find input from output. 3. Collision Resistant — no two inputs give same hash. 4. Avalanche Effect — small input change gives completely different hash. 5. Fixed Output Size. Examples: MD5 (128-bit, broken), SHA-1 (160-bit, deprecated), SHA-256 (256-bit, secure). Uses: Password storage, file integrity, digital signatures, blockchain.

10 Mark Questions

Q: Explain RSA Algorithm in detail with example. [10M Marks]

Ans: RSA (Rivest-Shamir-Adleman) is an asymmetric encryption algorithm based on difficulty of factoring large primes. KEY GENERATION: 1. Choose large primes p and q. 2. n = p×q. 3. ϕ(n)=(p-1)(q-1). 4. Choose e where gcd(e,ϕ(n))=1. 5. Find d where d×e≡1 mod ϕ(n). Public Key=(e,n), Private Key=(d,n). ENCRYPTION: C = M^e mod n. DECRYPTION: M = C^d mod n. EXAMPLE: p=61,q=53, n=3233, ϕ(n)=3120, e=17, d=2753. Encrypt M=65: C=65^17 mod 3233=2790. Decrypt: M=2790^2753 mod 3233=65. SECURITY: Based on integer factorization problem. Knowing n it is computationally infeasible to find p and q for large values.

Unit 2 (Extended): Cryptography — Advanced Topics

2.6 Modes of Encryption — Deep Dive

Block ciphers like AES encrypt fixed 128-bit blocks. For real messages (which are longer), we chain blocks using modes of operation. Each mode has different security properties.

ECB vs CBC Mode Comparison

```
ECB (INSECURE):
  [Block1] -> [Encrypt K] -> [Cipher1]
  [Block2] -> [Encrypt K] -> [Cipher2]   <- same block = same cipher!

CBC (SECURE):
  [IV] XOR [Block1] -> [Encrypt K] -> [Cipher1]
         [Cipher1] XOR [Block2] -> [Encrypt K] -> [Cipher2]
  Each block depends on previous — no patterns visible
```

Mode	IV Needed?	Parallel Encrypt	Parallel Decrypt	Error Propagation	Best Use
ECB	No	Yes	Yes	1 block only	Avoid — insecure!
CBC	Yes	No	Yes	2 blocks	File encryption, TLS
CFB	Yes	No	Yes	Limited	Byte streams
OFB	Yes	No	No	No propagation	Satellite comms
CTR	Yes (counter)	Yes	Yes	1 block only	High-speed, disk
GCM	Yes	Yes	Yes	Auth tag added	HTTPS, TLS 1.3

2.7 Hashing Algorithms — MD5, SHA Family

Definition: Hash Function

A one-way mathematical function that converts ANY input (any size) into a FIXED-SIZE output called a hash/digest. It is irreversible — you cannot recover input from the hash.

Properties of a Good Hash Function

Deterministic: Same input always gives same output
Fast computation: Quick to calculate hash
Pre-image resistance: Given hash H, impossible to find M such that hash(M) = H
Second pre-image resistance: Given M1, impossible to find M2 where hash(M1) = hash(M2)
Collision resistance: Impossible to find any two inputs M1 ≠ M2 with same hash
Avalanche effect: Tiny change in input causes completely different hash output

Algorithm	Output Size	Block Size	Status	Use Case
MD5	128 bits (32 hex chars)	512 bits	BROKEN — collisions found	Legacy only, not for security
SHA-1	160 bits (40 hex chars)	512 bits	DEPRECATED — weak	Legacy TLS, being retired
SHA-256	256 bits (64 hex chars)	512 bits	SECURE — current standard	TLS, digital signatures, Bitcoin
SHA-512	512 bits (128 hex chars)	1024 bits	SECURE — very strong	High-security applications
SHA-3	224/256/384/512 bits	Varies	SECURE — newest	Future standard, post-quantum
BLAKE2	256/512 bits	512/1024 bits	SECURE — fastest	Password hashing, checksums

MD5 Example

Input: 'Hello'
MD5: 8b1a9953c4611296a827abf8c47804d7 (128 bits = 32 hex chars)

Input: 'hello' (lowercase h!)
MD5: 5d41402abc4b2a76b9719d911017c592 (completely different!)

This is the AVALANCHE EFFECT — 1 bit change -> totally different hash
MD5 is BROKEN: researchers can create two files with same MD5 hash

2.8 Message Authentication Code (MAC)

Definition: MAC (Message Authentication Code)

A short tag generated from a message AND a secret key. Used to verify both the integrity (not tampered) and authenticity (came from right sender) of a message. Unlike hash, MAC requires a shared key.

HMAC Construction

```
HMAC(Key, Message) = Hash( (Key XOR opad) || Hash( (Key XOR ipad) ||
Message ) )

Where: opad = 0x5c5c5c... (outer padding)
       ipad = 0x363636... (inner padding)

Example: HMAC-SHA256 used in TLS, JWT tokens, API authentication

MAC vs Hash:
  Hash:  hash(M)       — no key, anyone can compute
  MAC:   mac(K, M)     — needs secret key K to compute or verify
```

2.9 Diffie-Hellman Key Exchange

Definition: Diffie-Hellman (DH)

A mathematical protocol that allows two parties to establish a shared secret key over an insecure channel WITHOUT ever transmitting the key. Based on the discrete logarithm problem.

Diffie-Hellman Protocol

```
PUBLIC (known to everyone): p = large prime, g = generator

  ALICE                           BOB
  Picks private: a                Picks private: b
  Computes: A = g^a mod p         Computes: B = g^b mod p
  Sends A --------[public]------>
            <----[public]------- Sends B
  secret = B^a mod p              secret = A^b mod p
         = g^(ab) mod p           = g^(ab) mod p

  Both get SAME secret g^(ab) mod p — attacker only sees A, B, p, g
  Cannot compute secret without solving discrete log (computationally
hard)
```

2.10 RSA — Step by Step Example

RSA Key Generation (Small Numbers)

Step 1: Choose primes p = 61, q = 53

Step 2: n = p × q = 61 × 53 = 3233

Step 3: ϕ(n) = (p-1)(q-1) = 60 × 52 = 3120

Step 4: Choose e = 17 (gcd(17, 3120) = 1 ✓)

Step 5: Find d: 17 × d ≡ 1 mod 3120 → d = 2753

PUBLIC KEY: (e=17, n=3233)

PRIVATE KEY: (d=2753, n=3233)

Encrypt M=65: C = 65^17 mod 3233 = 2790

Decrypt C=2790: M = 2790^2753 mod 3233 = 65 ✓

Real RSA uses 2048-4096 bit primes — unbreakable by current computers

2.11 Hybrid Encryption (Real World)

Pure RSA is 1000x slower than AES. Real systems use Hybrid Encryption: RSA to securely share an AES key, then AES for actual data.

Hybrid Encryption — How HTTPS Works

```
1. SERVER sends RSA Public Key to CLIENT
```

```
2. CLIENT generates random AES session key (128 or 256 bits)
3. CLIENT encrypts AES key using SERVER's RSA Public Key
4. CLIENT sends encrypted AES key to SERVER
5. SERVER decrypts using RSA Private Key — gets AES key
6. Both now share AES key — use it for all data encryption

Result: RSA security (key exchange) + AES speed (data encryption)
Used in: HTTPS, TLS, SSH, Email (S/MIME), Signal, WhatsApp
```

2.12 Exam Q&A — Cryptography Extended

Q: What is the difference between a hash function and MAC? [5 Marks Marks]

Ans: Hash function (like SHA-256) takes only the message as input and produces a fixed-size digest — no key involved, anyone can compute it. Used for integrity only. MAC (Message Authentication Code like HMAC) takes both a secret key and message as input — only parties with the key can compute or verify it. Provides both integrity and authenticity. Hash cannot confirm who sent the message; MAC can. Example: SHA-256 for file checksums, HMAC-SHA256 for API authentication.

Q: Explain Diffie-Hellman key exchange. What problem does it solve? [10 Marks Marks]

Ans: DH solves the key distribution problem: how to establish a shared secret over an insecure channel. Protocol: Both agree on public values g (generator) and p (large prime). Alice picks secret a, computes A = g^a mod p, sends A. Bob picks secret b, computes B = g^b mod p, sends B. Alice computes B^a mod p = g^(ab) mod p. Bob computes A^b mod p = g^(ab) mod p. Both reach same secret without ever transmitting it. Attacker sees A, B, g, p but cannot compute g^(ab) without solving discrete logarithm — computationally infeasible for large primes.

Q: What is hybrid encryption? Why is it used in HTTPS? [5 Marks Marks]

Ans: Hybrid encryption combines asymmetric (RSA) and symmetric (AES) encryption to get benefits of both. RSA is secure but slow (1000x slower than AES). AES is fast but has key distribution problem. Solution: Use RSA to securely exchange a random AES session key, then use AES for all actual data. HTTPS uses this: server sends RSA public key, client generates AES key, encrypts it with RSA public key, sends it. Server decrypts with RSA private key. Now both share AES key for fast, secure communication.

2.13 Important Questions — Unit 2 Extended

2-Mark Questions

1. What is an avalanche effect in hash functions?
2. What is MAC? How is it different from a digital signature?
3. What is Diffie-Hellman key exchange?
4. Define collision resistance in hash functions.
5. What is HMAC? Expand the abbreviation.
6. Why is MD5 considered insecure?

5-Mark Questions

1. Explain CBC mode of operation with a neat diagram.
2. Compare MD5, SHA-1, and SHA-256. Which is most secure?
3. Explain HMAC construction and its advantages over plain hash.
4. Explain hybrid encryption with an example from HTTPS.

10-Mark Questions

1. Explain Diffie-Hellman key exchange protocol with a diagram. What mathematical problem makes it secure?
2. Explain all five modes of block cipher operation (ECB, CBC, CFB, OFB, CTR). Compare with table.

UNIT 3: Authentication & Key Management

Authentication is the process of verifying the identity of a user, device, or system. It ensures that an entity is who it claims to be. Key management involves the generation, distribution, storage, and destruction of cryptographic keys.

3.1 Authentication Basics

Definition: Authentication

Authentication is the process of verifying the claimed identity of an entity (user, device, or process). It answers the question: 'Are you who you claim to be?' It is the first step in access control.

Types of Authentication Factors

Factor	Category	Example	Strength
Something you KNOW	Knowledge factor	Password, PIN, Security question	Low — can be guessed/stolen
Something you HAVE	Possession factor	Smart card, OTP token, Mobile phone	Medium — can be lost/stolen
Something you ARE	Biometric factor	Fingerprint, Face, Iris, Voice	High — hard to fake
Somewhere you ARE	Location factor	GPS location, IP address	Medium — can be spoofed

Multi-Factor Authentication (MFA)

Definition: Multi-Factor Authentication (MFA)

MFA requires users to provide two or more different authentication factors before gaining access. It significantly increases security because an attacker would need to compromise multiple independent factors.

- **Two-Factor Authentication (2FA):** Most common — e.g., Password + OTP sent to mobile
- **Example:** ATM requires: Card (something you HAVE) + PIN (something you KNOW)
- **Example:** Gmail login: Password + OTP on phone

Note:

Single-factor authentication (just password) is weak. Multi-factor authentication is strongly recommended for sensitive systems. Most modern security standards require MFA.

3.2 Password Authentication

Definition: Password Authentication

Password authentication verifies identity using a secret string of characters known only to the user. It is the most common and simplest form of authentication but also the weakest if not properly managed.

Password Storage — Hashing

Passwords should NEVER be stored in plaintext. They must be hashed using a one-way function. When user logs in, the entered password is hashed and compared with stored hash.

Password Storage and Verification

```
REGISTRATION:                    LOGIN:
User enters: 'mypassword'        User enters: 'mypassword'
     |                                |
[Hash Function: SHA-256]         [Hash Function: SHA-256]
     |                                |
'89e01536a...' (hash)            '89e01536a...' (hash)
     |                                |
Store hash in database          Compare with stored hash
(NOT the password!)                   |
                                If Match -> Login Success
                                If No Match -> Login Failed
```

Password Attacks

Attack	Description	Defense
Brute Force	Try all possible passwords	Strong passwords, account lockout
Dictionary Attack	Try common words from wordlist	Avoid common words, use complexity
Rainbow Table	Pre-computed hash lookup table	Use password salting
Phishing	Fake website to steal password	User education, 2FA
Shoulder Surfing	Watch user type password	Privacy screens, awareness
Password Sniffing	Capture passwords on network	Encryption (HTTPS, SSH)

Password Salting

Definition: Salt

A salt is a random value added to a password before hashing. This ensures that two users with the same password will have different hashes, and prevents rainbow table attacks.

Password Salting

```
User 1: Password = 'hello123'
Salt 1 = 'xK9pQ7rM' (random)
Hash = SHA-256('hello123' + 'xK9pQ7rM') = 'a7f2...'
```

```
User 2: Password = 'hello123' (SAME password!)
Salt 2 = 'bR4nL2wZ' (different random salt)
Hash = SHA-256('hello123' + 'bR4nL2wZ') = 'e9c1...' (DIFFERENT hash!)

Store: (username, salt, hash) in database
Attacker cannot use rainbow tables because of unique salts!
```

Exam Important:

Q: Explain different types of authentication. [5M]

Q: What is Multi-Factor Authentication? Give examples. [5M]

Q: What is password salting and why is it used? [5M]

Q: What are password attacks and how to prevent them? [5M]

3.3 Kerberos Authentication

Definition: Kerberos

Kerberos is a network authentication protocol that uses tickets to allow nodes communicating over a non-secure network to prove their identity securely. Developed at MIT, it uses symmetric key cryptography and requires a trusted third party.

Kerberos Components

Component	Full Form	Role
KDC	Key Distribution Center	Central trusted server — AS + TGS
AS	Authentication Server	Verifies user identity, issues TGT
TGS	Ticket Granting Server	Issues service tickets
TGT	Ticket Granting Ticket	Proof of authentication from AS
ST	Service Ticket	Access token for a specific service
Realm	—	Administrative domain managed by one KDC

Kerberos Authentication Process

```
CLIENT          AS (Auth Server)     TGS              SERVICE
  |                  |                |                  |
  |--1. Request TGT->|                |                  |
  |  (username)      |                |                  |
  |<-2. TGT + Session--|              |                  |
  |   Key (encrypted) |               |                  |
  |                  |                |                  |
  |------3. TGT + Service Request------>|                |
  |<---------4. Service Ticket (ST)-----|                |
  |                                   |                  |
  |------------------5. ST + Authenticator---------------->|
```

```
     |<-----------------6. Service Response-----------------|

   Steps: Login -> Get TGT -> Get Service Ticket -> Access Service
```

Kerberos Steps Explained

19. Client sends username to AS (Authentication Server)
20. AS verifies user, sends TGT (Ticket Granting Ticket) encrypted with user's password-derived key + session key
21. Client decrypts using password, sends TGT to TGS with service request
22. TGS verifies TGT, issues Service Ticket (ST) encrypted for the requested service
23. Client presents ST to the service — service verifies without contacting KDC
24. Service grants access — Kerberos authentication complete

Advantages and Disadvantages of Kerberos

Advantages	Disadvantages
Single Sign-On (SSO)	Single point of failure — if KDC down, no login
Mutual Authentication	Clocks must be synchronized (within 5 minutes)
Passwords never sent over network	Complex setup and administration
Tickets are time-limited (secure)	Does not work well across realms

Exam Important:

Q: Explain Kerberos authentication with diagram. [10M]

Q: What are the components of Kerberos? [5M]

Q: What is a TGT and why is it used in Kerberos? [2M]

3.4 Public Key Infrastructure (PKI)

Definition: Public Key Infrastructure (PKI)

PKI is a set of roles, policies, hardware, software, and procedures needed to create, manage, distribute, use, store, and revoke digital certificates and manage public-key encryption.

PKI Components

Component	Role
Certificate Authority (CA)	Issues and signs digital certificates — the trusted root
Registration Authority (RA)	Verifies identity of certificate applicants on behalf of CA
Digital Certificate	Binds public key to an identity — contains key + identity + CA signature
Certificate Repository	Database storing issued certificates

Certificate Revocation List (CRL)	List of revoked (invalid) certificates
End Entity	User or system that uses the certificate

PKI Trust Chain

```
ROOT CA (Self-signed, highest trust)
     |
     | Signs certificate of
     |
INTERMEDIATE CA
     |
     | Signs certificate of
     |
END ENTITY (Website, User, Device)
e.g., Certificate for www.example.com

Browser trusts Root CA -> trusts Intermediate CA -> trusts Website
This is called the Chain of Trust.
```

3.5 Digital Certificates

Definition: Digital Certificate

A digital certificate (also called a public key certificate or X.509 certificate) is an electronic document that binds a public key to an identity (person, organization, server). It is signed by a Certificate Authority (CA) to prove its authenticity.

X.509 Certificate Contents

Field	Description
Version	Certificate format version (V1, V2, V3)
Serial Number	Unique identifier assigned by CA
Signature Algorithm	Algorithm used by CA to sign the certificate
Issuer	Name of the CA that issued the certificate
Validity Period	Not Before and Not After dates
Subject	Identity the certificate belongs to (website, person)
Subject Public Key Info	The public key and algorithm
CA's Digital Signature	CA's signature — proves certificate authenticity

Certificate Verification Process

25. Browser receives server's digital certificate
26. Browser checks if certificate is within validity period
27. Browser checks if certificate is in the CRL (Certificate Revocation List)
28. Browser verifies CA's digital signature using CA's public key

29. Browser checks the domain name matches the certificate
30. If all checks pass: connection is trusted (green padlock in browser)

3.6 SSL / TLS Protocol

Definition: SSL/TLS

SSL (Secure Sockets Layer) and its successor TLS (Transport Layer Security) are cryptographic protocols that provide secure communication over a network. They combine asymmetric and symmetric cryptography to establish a secure channel. TLS is used in HTTPS.

Protocol	Version	Status	Notes
SSL 2.0	1995	Deprecated	Multiple vulnerabilities
SSL 3.0	1996	Deprecated	POODLE attack vulnerability
TLS 1.0	1999	Deprecated	Weak ciphers
TLS 1.1	2006	Deprecated	Deprecated by RFC 8996
TLS 1.2	2008	Widely Used	Still secure with good ciphers
TLS 1.3	2018	Current Standard	Fastest and most secure

TLS Handshake Process

TLS 1.2 Handshake

```
CLIENT                                          SERVER
  |                                               |
  |---1. ClientHello (supported ciphers, random)-->|
  |<--2. ServerHello (chosen cipher, random)-------|
  |<--3. Certificate (server's digital cert)-------|
  |<--4. ServerHelloDone--------------------------|
  |                                               |
  | (Client verifies certificate)                 |
  |                                               |
  |---5. ClientKeyExchange (pre-master secret)--->|
  |   (encrypted with server's public key)         |
  |                                               |
  | Both derive: Session Key = f(random1,random2,pre-master)
  |                                               |
  |---6. ChangeCipherSpec (switching to encrypt)->|
  |---7. Finished (handshake hash, encrypted)---->|
  |<--8. ChangeCipherSpec-------------------------|
  |<--9. Finished (handshake hash, encrypted)-----|
  |                                               |
  |<===== Secure Encrypted Channel Established ====>|
  |    (using symmetric session key from step 5)    |
```

Remember:

TLS uses Hybrid Encryption: Asymmetric crypto (RSA/ECDH) for the handshake/key exchange, then

Symmetric crypto (AES) for the actual data transfer. This gives best of both worlds: secure key exchange + fast bulk encryption.

Exam Important:

Q: Explain SSL/TLS Handshake with diagram. [10M]

Q: What is PKI? Explain its components. [10M]

Q: What is a Digital Certificate? What does it contain? [5M]

Q: Differentiate between SSL and TLS. [5M]

Q: What is Kerberos? Explain with diagram. [10M]

3.7 Important Q&A — Unit 3

2 Mark Questions

Q: What is Authentication? [2M Marks]

Ans: Authentication is the process of verifying the identity of a user, device, or system. It ensures an entity is who it claims to be. Common methods include passwords, biometrics, and digital certificates.

Q: What is PKI? [2M Marks]

Ans: PKI (Public Key Infrastructure) is a framework of roles, policies, and procedures for managing digital certificates and public-key encryption. Key components include Certificate Authority (CA), Registration Authority (RA), and digital certificates.

Q: What is TLS? [2M Marks]

Ans: TLS (Transport Layer Security) is a cryptographic protocol that provides secure communication over a network. It uses asymmetric cryptography for key exchange and symmetric cryptography for data encryption. HTTPS uses TLS.

5 Mark Questions

Q: Explain Multi-Factor Authentication with examples. [5M Marks]

Ans: MFA requires two or more authentication factors: 1. Something you KNOW (password, PIN). 2. Something you HAVE (smart card, mobile OTP). 3. Something you ARE (fingerprint, face recognition). Examples: ATM (card + PIN), Gmail (password + OTP), Bank (password + SMS OTP). MFA is more secure because even if password is stolen, attacker still cannot login without the second factor.

Q: Explain Digital Certificates and Certificate Authority. [5M Marks]

Ans: A Digital Certificate (X.509) is an electronic document binding a public key to an identity. It contains: version, serial number, issuer (CA name), subject (owner identity), validity period, public key, and CA's digital signature. Certificate Authority (CA) is a trusted third party that

issues and signs certificates. CA verifies the identity of the certificate applicant before issuing. Browsers pre-install trusted Root CA certificates. When visiting HTTPS site, browser verifies the site's certificate was signed by a trusted CA.

Unit 3 (Extended): Network Attacks — Advanced Topics

3.6 DoS and DDoS Attacks — Deep Dive

Definition: DoS (Denial of Service)

An attack that floods a target (server/network) with so much traffic or requests that legitimate users cannot access it. Like calling a phone number constantly so real callers get busy signal.

Definition: DDoS (Distributed Denial of Service)

A DoS attack launched from thousands/millions of compromised machines (botnet) simultaneously. Much harder to block because traffic comes from many different IPs worldwide.

DDoS Attack Architecture

```
ATTACKER (Command & Control Server)
        |
   +---------+---------+
   |         |         |
 [Bot1]   [Bot2]    [Bot3]  ... (thousands of infected machines)
   |         |         |
   +----+----+----+----+
        |
   [TARGET SERVER] <--- overwhelmed with millions of requests
        |
  LEGITIMATE USERS cannot connect — service denied
```

DoS Type	Technique	Layer	Example Tool	Mitigation
Volume Attack	Flood with huge traffic (UDP, ICMP)	Network (L3)	LOIC, HOIC	Rate limiting, blackholing
Protocol Attack	Exploit protocol weakness	Transport (L4)	SYN Flood, Ping of Death	SYN cookies, firewall rules
Application Attack	Target app layer (HTTP flood)	Application (L7)	Slowloris, RUDY	WAF, CAPTCHAs, rate limiting
Amplification	Small request → huge response	Network (L3)	DNS, NTP amplification	BCP38 filtering, rate limits

3.7 SQL Injection — Complete Guide

Definition: SQL Injection

An attack where malicious SQL code is inserted into application input fields to manipulate the database query. One of the most common and dangerous web application attacks (OWASP Top 10).

SQL Injection — Example Attack

Normal login query:

```
SELECT * FROM users WHERE username='alice' AND password='pass123'
```

Attacker enters in username field: admin'--

Modified query becomes:

```
SELECT * FROM users WHERE username='admin'--' AND password='xxx'
```

(-- is SQL comment, so password check is SKIPPED!)

Attacker logs in as admin without knowing password!

Another example — get all data:

Input: ' OR '1'='1

Query: SELECT * FROM users WHERE id='' OR '1'='1'

Returns ALL users! (because 1=1 is always true)

SQLi Type	Description	Example	Mitigation
Classic (In-band)	Results returned directly in response	' OR '1'='1	Parameterized queries
Error-based	Uses DB error messages to extract info	' AND CONVERT(int,'abc')--	Disable error messages
Blind Boolean	Asks true/false questions via query	' AND 1=1-- vs ' AND 1=2--	Input validation
Blind Time-based	Uses delays to infer data	'; WAITFOR DELAY '0:0:5'--	WAF, rate limiting
Out-of-band	Sends data via DNS/HTTP	'; exec xp_cmdshell(...)--	Least privilege DB accounts

SQL Injection Prevention

1. Parameterized Queries / Prepared Statements — MOST EFFECTIVE
2. Stored Procedures with proper permissions
3. Input Validation — whitelist allowed characters
4. Principle of Least Privilege — DB accounts with minimal permissions
5. Web Application Firewall (WAF) — detects and blocks SQLi patterns
6. Error handling — never show raw DB errors to users
7. ORM frameworks — auto-escape SQL special characters

3.8 Man-in-the-Middle (MITM) Attack

Definition: MITM Attack

An attack where the attacker secretly intercepts and possibly alters communications between two parties who believe they are communicating directly with each other.

MITM Attack Flow

```
ALICE                    ATTACKER (Eve)              BOB
  |                          |                         |
  |--- 'Hello Bob!' -----> |                         |
  |                          |--- 'Hello Bob!' -----> |
  |                          |<-- 'Hello Alice!' ---- |
  |<-- 'Hello Alice!' ---- |                         |
  |                          |                         |
Alice thinks she's         Eve reads/modifies       Bob thinks he's
talking to Bob             ALL messages             talking to Alice
```

MITM Technique	Method	Prevention
ARP Poisoning	Fake ARP replies to redirect LAN traffic	Dynamic ARP Inspection, static ARP
DNS Spoofing	Fake DNS responses to redirect to evil server	DNSSEC, DNS over HTTPS
SSL Stripping	Downgrade HTTPS to HTTP silently	HSTS, certificate pinning
Evil Twin	Fake WiFi AP with same SSID	VPN, verify SSID+BSSID, use HTTPS
BGP Hijacking	Announce false routes to redirect internet traffic	BGPsec, route filtering

3.9 Social Engineering Attacks

Definition: Social Engineering

Psychological manipulation of people into performing actions or divulging confidential information. Exploits human trust and behavior rather than technical vulnerabilities.

Attack	Description	Example	Prevention
Phishing	Fake email mimicking trusted sender	'Your bank account is suspended, click here'	Check sender domain, hover links before clicking
Spear Phishing	Targeted phishing using personal details	Email using victim's name, employer, colleagues	Security awareness training
Whaling	Targeting high-level executives (CEO, CFO)	'Urgent wire transfer needed — CEO'	Multi-approval for financial transactions
Vishing	Voice phishing — fake phone calls	'This is IRS, pay now or arrested'	Never give info over unexpected calls
Smishing	SMS phishing	'Your package held, click to release'	Don't click SMS links from unknown numbers
Baiting	Leaving malware-infected USB drives	USB labeled 'Salary List 2026'	Security policy: no unknown USB devices
Pretexting	Creating fake scenario to extract info	'IT department — need your password to fix	Verify identity through official channels

		account'	

3.10 Malware — Comprehensive Guide

Malware Type	Behavior	Self-Replicating?	Requires Host?	Example	Impact
Virus	Attaches to files, activates when run	Yes	Yes	ILOVEYOU	File corruption
Worm	Spreads via network independently	Yes	No	WannaCry	Network congestion
Trojan	Looks legitimate, hides malicious code	No	Yes	Zeus Banking Trojan	Data theft
Ransomware	Encrypts files, demands payment	No	No	CryptoLocker, WannaCry	Data/financial loss
Spyware	Secretly monitors user activity	No	Yes	Pegasus	Privacy violation
Adware	Shows unwanted ads, collects data	No	Yes	Fireball	Nuisance, data leak
Rootkit	Hides deep in OS, gives attacker control	No	Yes	Stuxnet rootkit	Full system compromise
Keylogger	Records every keystroke	No	Yes	Remote Access Trojans	Credential theft
Botnet	Network of infected machines (bots)	Yes	No	Mirai	DDoS, spam, crypto-mining

3.11 Advanced Persistent Threat (APT)

Definition: APT (Advanced Persistent Threat)

A sophisticated, long-term cyberattack where an attacker gains unauthorized access to a network and stays undetected for a long time to steal data continuously. Typically state-sponsored or by organized criminal groups.

APT Attack Lifecycle (Lockheed Martin Kill Chain)

```
1. RECONNAISSANCE — Research target (LinkedIn, website, DNS)
      |
2. WEAPONIZATION — Create malware/exploit for target vulnerability
      |
```

```
3. DELIVERY — Send via phishing email, watering hole, USB
      |
4. EXPLOITATION — Malware runs, exploits vulnerability
      |
5. INSTALLATION — Backdoor/RAT installed for persistence
      |
6. COMMAND & CONTROL (C2) — Attacker remotely controls system
      |
7. ACTIONS ON OBJECTIVES — Steal data, destroy systems, lateral
movement
```

3.12 Exam Q&A — Attacks Extended

Q: Explain DDoS attack. How is it different from DoS? [5 Marks Marks]

Ans: DoS (Denial of Service): attack from a SINGLE source flooding target with requests making it unavailable. Easy to block by blocking that one IP. DDoS (Distributed DoS): attack launched from THOUSANDS of compromised machines (botnet) simultaneously. Attacker first infects many computers with malware forming a botnet, then commands all to attack target simultaneously. Much harder to defend — traffic from millions of legitimate-looking IPs. Types: Volume attacks (UDP flood), Protocol attacks (SYN flood), Application attacks (HTTP flood). Mitigation: CDN, rate limiting, traffic scrubbing centers, blackholing.

Q: What is SQL injection? How can it be prevented? [10 Marks Marks]

Ans: SQL Injection: Attacker inserts malicious SQL code into input fields to manipulate database queries. Example: login form with input ' OR '1'='1 causes query to return all users. Types: Classic (direct output), Blind Boolean, Blind Time-based, Error-based, Out-of-band. Impact: unauthorized data access, data deletion, admin bypass, remote code execution. Prevention: (1) Parameterized queries/prepared statements — most effective; (2) Stored procedures; (3) Input validation and sanitization; (4) Principle of least privilege for DB accounts; (5) Web Application Firewall; (6) Never display raw DB errors; (7) Use ORM frameworks. OWASP rates SQLi in Top 10 web vulnerabilities.

Important Questions — Unit 3 Extended

[2 Marks] What is a botnet? How is it used in DDoS?

[2 Marks] Define APT. Name one real-world example.

[2 Marks] What is ARP poisoning?

[5 Marks] Explain Man-in-the-Middle attack with diagram. How is it prevented?

[5 Marks] Compare different types of malware: virus, worm, trojan, ransomware.

[10 Marks] Explain social engineering attacks. Describe 5 types with examples and prevention.

[10 Marks] Explain the APT kill chain with diagram. What is each phase?

UNIT 4: Network Attacks & Threats

Network attacks are deliberate actions taken by malicious actors to compromise the security, functionality, or integrity of computer networks and systems. Understanding these attacks is essential to defending against them.

4.1 Types of Network Attacks

Definition: Network Attack

A network attack is any intentional effort to damage, disrupt, or gain unauthorized access to a computer network, system, or data using malicious methods.

Attack Category	Examples	Goal
Denial of Service	DoS, DDoS, Ping of Death	Crash/overload the system
Man-in-the-Middle	ARP Spoofing, SSL Stripping	Intercept communications
Spoofing	IP Spoofing, DNS Spoofing, Email Spoofing	Fake identity
Sniffing/Eavesdropping	Packet sniffing, Wireshark	Capture data
Malware	Virus, Worm, Trojan, Ransomware	Damage/steal data
Social Engineering	Phishing, Vishing, Baiting	Trick users
Injection Attacks	SQL Injection, XSS, LDAP Injection	Exploit vulnerabilities
Password Attacks	Brute Force, Dictionary, Keylogger	Gain credentials

4.2 IP Security (IPSec)

Definition: IPSec (Internet Protocol Security)

IPSec is a suite of protocols that provides security services at the IP (Network) layer. It authenticates and encrypts each IP packet in a communication session. IPSec is used in VPNs and secure communications.

IPSec Modes

Mode	What is Protected	Use Case	Overhead
Transport Mode	Only the payload (data) of IP packet	Host-to-host communication	Lower
Tunnel Mode	Entire original IP packet (header + data)	Gateway-to-gateway, VPN	Higher

IPSec Protocols

Protocol	Full Name	Function	Provides
AH	Authentication Header	Authenticates source, ensures integrity	Authentication + Integrity (No encryption)
ESP	Encapsulating Security Payload	Encrypts data + optional authentication	Confidentiality + Integrity + Auth
IKE	Internet Key Exchange	Negotiates and establishes security associations	Key Management

IPSec Transport Mode vs Tunnel Mode

```
TRANSPORT MODE (host to host):
[IP Header | AH/ESP | TCP | Data]
            |<-- IPSec protects this part -->|

TUNNEL MODE (gateway to gateway - VPN):
[New IP Hdr | AH/ESP | Original IP Header | TCP | Data]
            |<--------- IPSec protects this ----------->|
 (New header added for tunnel endpoints)
```

Security Association (SA)

Definition: Security Association (SA)

A Security Association is a relationship between two or more entities describing how they will use IPSec security services to communicate. It defines the cryptographic algorithm, key, and other parameters for a one-way connection.

Exam Important:

Q: Explain IPSec with its protocols (AH and ESP). [10M]

Q: Differentiate between Transport Mode and Tunnel Mode in IPSec. [5M]

Q: What is a Security Association in IPSec? [2M]

4.3 Denial of Service (DoS) Attacks

Definition: Denial of Service (DoS)

A DoS attack attempts to make a network resource unavailable to its intended users by overwhelming it with illegitimate requests, consuming all available bandwidth, memory, or processing power.

Types of DoS Attacks

Attack	Method	Effect
SYN Flood	Sends many SYN packets without completing TCP handshake	Exhausts connection table
Ping of Death	Sends oversized ICMP ping	Crashes target system

	packets (>65535 bytes)	
Smurf Attack	Sends ICMP to broadcast address with spoofed source	Amplified flood to victim
UDP Flood	Floods with UDP packets to random ports	Overwhelms bandwidth
HTTP Flood	Sends massive HTTP GET/POST requests	Crashes web server

DDoS — Distributed Denial of Service

Definition: DDoS (Distributed Denial of Service)

A DDoS attack uses multiple compromised systems (called a botnet) to simultaneously attack a single target, making it much harder to block than a regular DoS attack.

DDoS Attack Architecture

```
  ATTACKER (Botmaster)
       |
       | Commands (via C&C server)
       |
  +----+----+----+----+----+
  |    |    |    |    |    |
 Bot1 Bot2 Bot3 Bot4 Bot5 ... (Thousands of compromised computers)
  |    |    |    |    |
  +----+----+----+----+--- FLOOD of requests ------>  TARGET
                                                     (Server/Website)

  Bots are regular computers infected with malware
  The collection of bots is called a BOTNET
  Target cannot block attack because requests come from many IPs
```

TCP SYN Flood — Detailed

TCP Three-Way Handshake vs SYN Flood

```
  NORMAL TCP HANDSHAKE:         SYN FLOOD ATTACK:
  Client    Server               Attacker   Server
    |          |                    |          |
    |---SYN--->|                    |--SYN(fake IP)->| (many!)
    |<-SYN+ACK-|                    |          | (Server waits for ACK)
    |---ACK--->|                    |          | (ACK never comes)
    |          |                    |          | (connection table
full!)
  Connection Established          Legitimate clients cannot connect!
```

DoS Countermeasures

- **Rate limiting:** Limit requests per IP per second
- **SYN Cookies:** Stateless SYN protection — don't allocate resources until handshake complete

- **Ingress Filtering:** Filter packets with spoofed source IP addresses
- **CDN and DDoS Protection:** Use cloud services like Cloudflare that absorb DDoS traffic
- **Black Hole Routing:** Route attack traffic to null route (discard)
- **Intrusion Detection System (IDS):** Detect and alert on attack patterns

Exam Important:

Q: Explain DoS and DDoS attacks with diagram. [10M]

Q: What is SYN Flood attack? How to prevent it? [5M]

Q: Differentiate between DoS and DDoS attacks. [5M]

Q: What is a Botnet? [2M]

4.4 Malware — Viruses, Worms, Trojans

Definition: Malware

Malware (Malicious Software) is any software intentionally designed to cause disruption to a computer, server, client, or network, leak private information, gain unauthorized access, deprive users of access, or interfere with computer security.

Types of Malware

Malware Type	Definition	Spreads How	Effect
Virus	Attaches to legitimate programs, replicates when program runs	User action (opening infected file)	Corrupts files, programs
Worm	Self-replicating malware that spreads without user action	Network automatically	Consumes bandwidth/memory
Trojan Horse	Disguised as legitimate software	User downloads 'useful' software	Opens backdoor, steals data
Ransomware	Encrypts files, demands ransom for decryption key	Email attachments, malicious links	File/system lockout
Spyware	Secretly monitors user activity	Bundled software	Steals passwords, data
Adware	Displays unwanted advertisements	Software bundles	Annoying ads, slows PC
Rootkit	Hides malware presence from OS	Exploits vulnerabilities	Deep system control
Keylogger	Records keystrokes	Trojans, infected USB	Steals passwords, credit cards

Virus vs Worm vs Trojan — Comparison

Feature	Virus	Worm	Trojan

Needs Host File	Yes — attaches to program	No — standalone	No — pretends to be app
Self-replicates	Yes, with host	Yes, independently	No
Spreads	Requires user action	Automatically via network	User downloads it
Primary Goal	File corruption	Network congestion	Backdoor access
Example	Boot sector virus	Code Red, ILOVEYOU	Emotet, Zeus

Ransomware — In Detail

Definition: Ransomware

Ransomware is a type of malware that encrypts the victim's files or locks the system, then demands payment (usually cryptocurrency) in exchange for the decryption key to restore access.

Famous ransomware attacks: WannaCry (2017) — infected 230,000 computers in 150 countries. NotPetya (2017) — caused $10 billion in damages worldwide.

Ransomware Attack Flow

```
  1. [Phishing Email] -> User clicks malicious link
  2. [Ransomware Downloaded] to victim's computer
  3. [Ransomware Executes] - contacts attacker's C&C server
  4. [Encryption Key] sent from attacker to malware
  5. [Files Encrypted] - Documents, Images, Database files locked
  6. [Ransom Note] displayed: 'Pay $500 Bitcoin to get your files back'
  7. [Victim Pays or Loses Data]

  Prevention: Regular backups, email filtering, patch systems, user
training
```

Exam Important:

Q: Explain different types of malware with examples. [10M]

Q: Differentiate between Virus, Worm, and Trojan. [5M]

Q: What is Ransomware? Explain with example. [5M]

Q: What is a Keylogger? [2M]

4.5 Intrusion Detection Systems (IDS)

Definition: IDS (Intrusion Detection System)

An IDS is a device or software application that monitors network traffic or system activities for malicious activity or policy violations and generates alerts when suspicious activity is detected.

Types of IDS

Type	Full Form	What it Monitors	Location

NIDS	Network-Based IDS	Network traffic	At network perimeter/key segments
HIDS	Host-Based IDS	System logs, files, processes	On individual computers
WIDS	Wireless IDS	Wireless network activity	Wireless network segments

IDS Detection Methods

Method	How it Works	Pros	Cons
Signature-Based (Rule-Based)	Compares traffic with known attack signatures (like antivirus)	Low false positives	Cannot detect new/unknown attacks
Anomaly-Based (Statistical)	Establishes normal behavior baseline, alerts on deviations	Detects new/zero-day attacks	High false positives
Stateful Protocol Analysis	Compares protocol behavior against vendor-defined normal states	Thorough analysis	Resource intensive

IDS vs IPS

Definition: IPS (Intrusion Prevention System)

An IPS is like an IDS but can also take action to block or prevent detected intrusions. IDS only detects and alerts; IPS detects AND prevents.

Feature	IDS	IPS
Action	Detects and alerts only	Detects and blocks
Placement	Out of band (passive)	Inline (active)
Impact on traffic	None	Can block legitimate traffic (false positive)
Response time	Needs human intervention	Automatic real-time response
Risk	Miss attacks (false negative)	Block legitimate traffic (false positive)

Man-in-the-Middle (MITM) Attack

Definition: Man-in-the-Middle (MITM) Attack

In a MITM attack, the attacker secretly intercepts and possibly alters communications between two parties who believe they are directly communicating with each other.

Man-in-the-Middle Attack

```
NORMAL:                                MITM ATTACK:
Alice <-----------------> Bob
(Think they talk directly)             Alice  <--> Attacker <--> Bob
                                       Alice thinks Attacker is Bob
```

```
                                        Bob thinks Attacker is Alice
                                        Attacker can READ and MODIFY all
messages

  Common MITM techniques:
  - ARP Spoofing (links attacker MAC to victim IP)
  - DNS Spoofing (redirects domain to wrong IP)
  - SSL Stripping (downgrades HTTPS to HTTP)
  - Rogue Wi-Fi (fake hotspot captures traffic)

  Prevention: HTTPS, Certificate Pinning, VPN, Network Monitoring
```

Exam Important:

Q: Explain Intrusion Detection System (IDS) and its types. [10M]

Q: Differentiate between IDS and IPS. [5M]

Q: What is Man-in-the-Middle attack? [5M]

Q: What is signature-based detection in IDS? [2M]

4.6 Important Q&A — Unit 4

2 Mark Questions

Q: What is DoS attack? [2M Marks]

Ans: A Denial of Service (DoS) attack attempts to make a network service unavailable by overwhelming it with traffic or requests. The attacker floods the target with illegitimate packets, consuming all resources so legitimate users cannot access the service.

Q: What is a Virus? [2M Marks]

Ans: A computer virus is malicious software that attaches itself to legitimate programs and replicates when the infected program is executed. It requires user action to spread (opening infected file/email attachment) and can corrupt files, delete data, or slow down systems.

Q: What is IPSec? [2M Marks]

Ans: IPSec (Internet Protocol Security) is a suite of protocols that provides security at the IP layer by authenticating and encrypting IP packets. It provides confidentiality, integrity, and authentication for network communications and is widely used in VPNs.

5 Mark Questions

Q: Differentiate between Virus, Worm, and Trojan Horse. [5M Marks]

Ans: VIRUS: Attaches to legitimate files. Needs user action to spread (opening infected file). Replicates with host file. Goal: file corruption. Example: Boot sector virus. WORM: Standalone program, no host file needed. Spreads automatically through networks without user action. Replicates independently. Goal: network congestion/damage. Example: WannaCry, ILOVEYOU.

TROJAN: Disguised as legitimate software. Spreads when user downloads and runs it. Does not self-replicate. Goal: backdoor access, data theft. Example: Zeus, Emotet.

Q: Explain IPSec Authentication Header (AH) and ESP protocols. [5M Marks]

Ans: AH (Authentication Header): Provides authentication and integrity for IP packets. Creates a hash of packet contents that receiver can verify. Does NOT provide encryption (no confidentiality). Protects against replay attacks using sequence numbers. ESP (Encapsulating Security Payload): Provides encryption (confidentiality) in addition to authentication and integrity. Encrypts the payload (data) portion of IP packet. Also provides replay protection. ESP is more commonly used than AH because it provides all three security services.

10 Mark Questions

Q: Explain DDoS attack in detail with diagram. [10M Marks]

Ans: DDoS (Distributed Denial of Service) is an attack where multiple compromised computers (botnet) simultaneously attack a single target. COMPONENTS: 1. Attacker/Botmaster: Controls the attack. 2. C&C Server: Command and Control server. 3. Bots/Zombies: Thousands of infected computers. 4. Target: The victim system. HOW IT WORKS: Attacker infects thousands of computers with malware, creating a botnet. When ready, attacker commands all bots via C&C to flood the target simultaneously. Target gets overwhelmed by millions of requests from different IPs. Cannot block by IP filtering — too many sources. Service becomes unavailable to legitimate users. TYPES: SYN Flood, UDP Flood, HTTP Flood, DNS Amplification. PREVENTION: Rate limiting, SYN cookies, CDN/DDoS protection services (Cloudflare), ingress filtering, anomaly detection IDS.

Unit 4 (Extended): Firewalls & IDS — Advanced Topics

4.8 Stateful vs Stateless Firewalls

Definition: Stateless Firewall (Packet Filter)

Examines each packet in isolation. Checks source IP, destination IP, port numbers, and protocol against rules. No memory of previous packets — fast but less secure.

Definition: Stateful Firewall

Tracks the STATE of network connections. Maintains a state table of active connections. Can determine if a packet is part of established session or a new unauthorized connection. Much more secure than stateless.

Stateful Firewall — Connection Tracking

```
State Table:
+------------------+--------+----------+--------+----------+
| Src IP:Port      | Dst IP:Port       | State  | Protocol |
+------------------+-------------------+--------+----------+
| 192.168.1.5:4523 | 8.8.8.8:443      | ESTAB  | TCP      |
| 192.168.1.8:2341 | 142.250.1.1:80   | SYN    | TCP      |
+------------------+-------------------+--------+----------+

Incoming packet: checks if it matches any existing connection
If no match AND not allowed by rules -> DROPPED
Protects against unsolicited inbound packets
```

Feature	Stateless (Packet Filter)	Stateful	Next-Gen (NGFW)
Inspection	Per-packet only	Connection state	App + user + content
Speed	Very fast	Fast	Moderate (deep inspection)
Security	Basic	Good	Excellent
Can detect	Port scanning	Half-open attacks	Malware, DPI, IPS
Layer	L3/L4	L3/L4	L3-L7
Example	iptables basic rules	iptables conntrack	Palo Alto, Fortinet

4.9 Next-Generation Firewall (NGFW)

Definition: NGFW (Next-Generation Firewall)

An advanced firewall that combines traditional stateful inspection with deep packet inspection (DPI), application awareness, user identity tracking, and integrated IPS. Can inspect encrypted traffic.

NGFW Capabilities

Application Control: Block/allow specific apps (YouTube, Torrent, WhatsApp) regardless of port
User Identity: Rules per user/group, not just IP address (integrates with Active Directory)
Deep Packet Inspection (DPI): Inspect payload content, not just headers
SSL/TLS Inspection: Decrypt, inspect, re-encrypt HTTPS traffic to find hidden malware
Integrated IPS: Block known attack patterns in real-time
URL Filtering: Block categories of websites (gambling, adult, social media)
Sandboxing: Run suspicious files in isolated virtual environment
Threat Intelligence: Real-time updates of known malicious IPs/domains

4.10 DMZ — Demilitarized Zone

Definition: DMZ (Demilitarized Zone)

A separate network zone between the internal (trusted) network and the internet (untrusted). Public-facing servers (web, email, DNS) are placed here — if compromised, attacker cannot directly reach internal network.

Network Architecture with DMZ

```
INTERNET (Untrusted)
     |
[OUTER FIREWALL] — blocks most traffic
     |
+---------DMZ---------+
| [Web Server]        |
| [Mail Server]       |  <- Public-facing servers
| [DNS Server]        |
+---------------------+
     |
[INNER FIREWALL] — strict rules, protects internal
     |
INTERNAL NETWORK (Trusted)
[DB Server] [File Server] [Workstations]
```

4.11 IDS Types — Signature vs Anomaly

IDS Type	Detection Method	Pros	Cons	Example
Signature-based	Matches traffic against known attack signatures	Very fast, low false positives	Cannot detect new/unknown attacks (zero-day)	Snort, Suricata
Anomaly-based	Learns normal baseline, flags deviations	Can detect zero-day, new attacks	High false positive rate, needs training period	Zeek, ML-based IDS
Stateful Protocol Analysis	Checks protocol compliance against RFC standards	Detects protocol abuse	Resource intensive	Cisco NBAR

Hybrid	Combines signature + anomaly	Best coverage	Complex to manage	Cisco Firepower, Darktrace

4.12 Honeypot & Honeynets

Definition: Honeypot

A decoy system designed to attract attackers. Appears to be a legitimate target but is isolated and monitored. Used to detect attacks, study attacker methods, and waste attacker time and resources.

Type	Description	Purpose
Low-interaction Honeypot	Simulates limited services (fake open ports)	Alert on port scans, quick to deploy
High-interaction Honeypot	Full real OS/applications exposed	Study advanced attacker techniques, gather intelligence
Honeynet	Network of multiple honeypots	Study coordinated attacks, botnet behavior
Honey Credentials	Fake passwords/tokens planted in files	Detect credential theft — alert when credentials used
Honey Files	Fake sensitive documents with tracking beacons	Detect unauthorized access to sensitive data

4.13 Firewall Rules — Best Practices

Firewall Rule Design Principles

Default Deny (Whitelist): Block ALL traffic by default, only allow what is explicitly needed
Least Privilege: Allow minimum access required for function
Rule Order Matters: Rules evaluated top-to-bottom — specific rules before general
Implicit Deny: Last rule should be 'deny any any' (even if invisible)
Regularly Audit: Remove obsolete rules, review annually
Log Everything: Log all denied traffic, periodic sampling of allowed traffic
Separate Duties: Different firewalls for different network zones
Test Rules: Verify rules work as intended in test environment

Sample Firewall Rule Table

```
Rule# | Source          | Destination      | Port | Action
------|-----------------|-----------------|------|-------
  1   | Internal Network | Any             | 443  | ALLOW (HTTPS outbound)
  2   | Internal Network | Any             | 80   | ALLOW (HTTP outbound)
  3   | Internal Network | DNS Server      | 53   | ALLOW (DNS)
  4   | Any              | Web Server (DMZ) | 443  | ALLOW (HTTPS inbound)
  5   | Any              | Web Server (DMZ) | 80   | ALLOW (HTTP inbound)
```

6	Web Server (DMZ)	DB Server	3306	ALLOW (DB access)
7	Any	Any	Any	DENY (default deny)

4.14 Exam Q&A — Firewalls Extended

Q: What is a DMZ? Why is it important in network security? [5 Marks Marks]

Ans: DMZ (Demilitarized Zone) is a separate network segment placed between the internal trusted network and the untrusted internet, protected by two firewalls. Public-facing servers (web, email, DNS) are placed in the DMZ. If an attacker compromises a DMZ server, they cannot directly access the internal network — the inner firewall blocks them. Benefits: isolates internet-facing services, limits blast radius of compromise, allows external access without exposing internal systems. Used in enterprise networks, e-commerce, banking infrastructure.

Q: Compare NIDS and HIDS. When would you use each? [5 Marks Marks]

Ans: NIDS (Network IDS) monitors network traffic at strategic points (network tap/span port) — can detect attacks against any device on the network, low overhead on endpoints, cannot see encrypted traffic or host-level events. HIDS (Host IDS) runs on individual hosts, monitors system calls, file changes, log files — can detect insider threats, rootkits, privilege escalation, sees local encrypted traffic after decryption. Use NIDS for broad network-level attack detection. Use HIDS for critical servers (database, domain controller). Best practice: deploy BOTH for defense in depth — NIDS catches network attacks, HIDS catches post-exploitation activity.

Important Questions — Unit 4 Extended

[2 Marks] What is a stateful firewall? How does it differ from packet filter?

[2 Marks] What is a honeypot? Name two types.

[2 Marks] Define DMZ. Why are web servers placed in DMZ?

[5 Marks] Explain Next-Generation Firewall (NGFW) capabilities.

[5 Marks] Compare signature-based and anomaly-based IDS.

[10 Marks] Draw a complete enterprise network diagram with internet, DMZ (outer firewall, web server, email server, DNS server), inner firewall, and internal network. Explain the role of each component.

UNIT 5: Firewalls, VPN & Wireless Security

This unit covers the key defensive technologies used to protect networks: firewalls that control traffic, VPNs that create secure tunnels, wireless security protocols that protect Wi-Fi, and email security systems.

5.1 Firewalls — Introduction

Definition: Firewall

A firewall is a network security device (hardware or software) that monitors and controls incoming and outgoing network traffic based on predefined security rules. It acts as a barrier between a trusted internal network and untrusted external networks (like the Internet).

The term 'firewall' comes from the concept of physical firewalls — walls that contain fires. In networking, a firewall contains/blocks malicious traffic from spreading into a trusted network.

Firewall Position in Network

```
INTERNET (Untrusted)                    INTERNAL NETWORK (Trusted)
[Hackers, Malware, Attackers]           [Computers, Servers, Data]
        |                                          |
        |                                          |
        +---------------[FIREWALL]----------------+
                       /         \
                Blocks bad       Allows good
                traffic          traffic

Firewall checks every packet:
- Source IP / Destination IP
- Port number (service)
- Protocol (TCP, UDP, ICMP)
- State of connection
ALLOW or DENY based on rules
```

Firewall Functions

- **Packet filtering:** Inspects each packet and allows/blocks based on rules
- **Network Address Translation (NAT):** Hides internal IP addresses from outside
- **Logging & Auditing:** Keeps records of all traffic for analysis
- **VPN support:** Terminates VPN connections
- **Application-level inspection:** Understands application protocols

5.2 Types of Firewalls

Firewall Type	How it Works	OSI Layer	Pros	Cons

Packet Filter	Checks IP/port rules on each packet	Network (Layer 3)	Fast, simple	No state, easy to bypass
Stateful Inspection	Tracks connection state + packet rules	Network + Transport	Better security	Slower than packet filter
Application Gateway (Proxy)	Acts as proxy, understands application data	Application (Layer 7)	Deep inspection	Slow, complex
Next-Gen Firewall (NGFW)	DPI + IDS/IPS + App awareness + User identity	All layers	Most comprehensive	Expensive, complex

5.2.1 Packet Filtering Firewall

Definition: Packet Filtering Firewall

A packet filtering firewall examines each packet passing through the network and accepts or rejects it based on rules defined by the administrator. Rules are based on source IP, destination IP, port number, and protocol.

Packet Filtering Rules Example

```
RULE TABLE (Access Control List):
+------+----------+------+----------+------+--------+
| Rule | Src IP   | Src  | Dst IP   | Dst  | Action |
|      |          | Port |          | Port |        |
+------+----------+------+----------+------+--------+
|  1   | Any      | Any  | 10.0.0.1 |  80  | ALLOW  | (web server)
|  2   | Any      | Any  | 10.0.0.1 | 443  | ALLOW  | (HTTPS)
|  3   | Any      | Any  | 10.0.0.1 |  23  | DENY   | (block Telnet)
|  4   | 192.168  | Any  | Any      | Any  | ALLOW  | (internal OK)
|  5   | Any      | Any  | Any      | Any  | DENY   | (default deny)
+------+----------+------+----------+------+--------+

Packets matched top-to-bottom — first match wins!
```

Advantages and Disadvantages of Packet Filtering

Advantages	Disadvantages
Very fast — minimal processing per packet	Cannot detect application-layer attacks
Simple to implement and configure	No awareness of connection state
Low cost	Susceptible to IP spoofing
Transparent to applications	Cannot inspect encrypted data
Good for basic traffic control	No user authentication

5.2.2 Stateful Inspection Firewall

Definition: Stateful Inspection Firewall

A stateful inspection firewall (also called dynamic packet filter) tracks the state of active connections and uses this information to determine which packets to allow or deny. It maintains a state table of all established connections.

Stateful Firewall — Connection State Table

```
STATE TABLE (maintained by firewall):
+---------------+----------+-------+--------+----------+
| Src IP:Port   | Dst IP:Port | Proto | State  | Timeout  |
+---------------+----------+-------+--------+----------+
| 192.168.1.5:1234 | 8.8.8.8:80  | TCP   | ESTABLISHED| 300s  |
| 192.168.1.5:1235 | 8.8.8.8:443 | TCP   | SYN_SENT   | 30s   |
| 192.168.1.10:5678| 1.1.1.1:53  | UDP   | OPEN       | 30s   |
+---------------+----------+-------+--------+----------+

INCOMING PACKET: 8.8.8.8:80 -> 192.168.1.5:1234
Check state table -> Connection exists -> ALLOW

INCOMING PACKET: 1.2.3.4:9999 -> 192.168.1.5:8080
Check state table -> No matching connection -> DENY
```

5.2.3 Application Gateway (Proxy Firewall)

Definition: Application Gateway / Proxy Firewall

An application gateway (proxy firewall) operates at the application layer (Layer 7). It acts as a proxy — all traffic passes through it and it establishes separate connections to both client and server, fully understanding the application protocol.

Proxy Firewall Operation

```
CLIENT                PROXY FIREWALL              SERVER
  |                       |                         |
  |---HTTP Request-------->|                         |
  |  (connection to proxy) |                         |
  |                       |---HTTP Request-------->|
  |                       |  (new connection)       |
  |                       |<--HTTP Response--------|
  |<--HTTP Response--------|                         |
  |  (from proxy)         |                         |

Proxy inspects ENTIRE HTTP request/response
Can block: specific URLs, file types, malware in HTTP
Server never directly communicates with client
Hides internal network topology
```

Exam Important:

Q: Explain different types of firewalls with diagrams. [10M]

Q: Explain Packet Filtering Firewall with example. [5M]
Q: What is Stateful Inspection? How does it differ from Packet Filtering? [5M]
Q: What is a Firewall? What are its functions? [5M]
Q: What is a Proxy Firewall? [2M]

5.3 VPN — Virtual Private Network

Definition: VPN (Virtual Private Network)

A VPN creates a secure, encrypted tunnel over a public network (Internet) to connect remote users or sites as if they are directly connected to a private network. It provides confidentiality, integrity, and authentication over untrusted networks.

VPN Concept

```
  WITHOUT VPN:                    WITH VPN:
  Home PC ----Internet----> Company    Home PC ===Encrypted Tunnel===>
Company
           (insecure, anyone            (secure, attacker sees only
            can intercept)              encrypted gibberish)

  VPN TUNNEL MODEL:
  [Home PC] -- [Encrypted Packet] -- [Internet] -- [Encrypted Packet] -
- [VPN Server] -- [Company Network]
              <---- Original packet is wrapped in encrypted envelope --
-->

  Analogy: VPN is like a secure armored car carrying your data
  through a dangerous public road (Internet)
```

Types of VPN

VPN Type	Use Case	Protocol	Example
Remote Access VPN	Individual user connects to corporate network from home	SSL/TLS, IPSec	Work from home employee
Site-to-Site VPN	Two branch offices connected securely over Internet	IPSec	Company HQ to Branch Office
Client-to-Site VPN	Mobile users connect to company network	IPSec, L2TP	Sales team in field
MPLS VPN	Service provider managed VPN for enterprises	MPLS	Large enterprise WAN

VPN Protocols

Protocol	Full Name	Security	Speed	Port

PPTP	Point-to-Point Tunneling Protocol	Weak — deprecated	Fast	1723/TCP
L2TP/IPSec	Layer 2 Tunneling + IPSec	Good	Medium	500/UDP
OpenVPN	Open source SSL/TLS VPN	Very Good	Medium	1194/UDP
WireGuard	Modern lightweight VPN	Excellent	Very Fast	51820/UDP
SSTP	Secure Socket Tunneling Protocol	Good	Medium	443/TCP

VPN Working — IPSec Tunnel Mode

VPN Tunnel Encapsulation

```
  ORIGINAL PACKET from Home PC:
  [IP Header: 192.168.1.5 -> 10.0.0.20 | TCP | DATA]

  AFTER VPN ENCAPSULATION:
  [New IP: HomeVPN -> CompanyVPN | ESP Header | Encrypted(Original
Packet)]
                                  |<-------- Encrypted Payload --------
-->|

  On Internet: Only the outer IP header is visible
  Content is fully encrypted — ISP/attacker cannot read data

  At Company VPN Gateway:
  Decrypt ESP -> Get original packet -> Forward to 10.0.0.20
```

Exam Important:

Q: What is VPN? Explain its types and working. [10M]

Q: Compare different VPN protocols. [5M]

Q: What is the difference between Remote Access VPN and Site-to-Site VPN? [5M]

Q: Why is VPN used? What are its advantages? [5M]

5.4 Wireless Security — WEP, WPA, WPA2

Definition: Wireless Network Security

Wireless network security protects Wi-Fi networks from unauthorized access and eavesdropping. Because wireless signals travel through air, they can be intercepted by anyone in range, making security especially critical.

Wireless Security Protocols Evolution

Protocol	Year	Encryption	Authentication	Status	Key Issues
WEP	1997	RC4 (40/104-bit)	Shared Key	Broken — Avoid	Weak IV, static key,

					easily cracked
WPA	2003	TKIP + RC4	PSK / 802.1X	Deprecated	Better than WEP but TKIP has weaknesses
WPA2	2004	AES-CCMP	PSK / 802.1X	Current Standard	KRACK attack (patched), secure if updated
WPA3	2018	AES-GCMP	SAE	Best — Use this	Fixes WPA2 weaknesses, secure handshake

WEP — Wired Equivalent Privacy

Definition: WEP (Wired Equivalent Privacy)

WEP was the first wireless security protocol, introduced in 1997. It uses RC4 stream cipher with a 40 or 104-bit key combined with a 24-bit Initialization Vector (IV). WEP is completely broken and should never be used.

WEP's fatal flaw: The 24-bit IV is too small, causing IV reuse. When IVs repeat, attackers can XOR two ciphertexts to cancel the key and recover plaintext. Tools like Aircrack-ng can crack WEP in minutes.

WPA — Wi-Fi Protected Access

Definition: WPA

WPA was introduced in 2003 as an emergency fix for WEP. It uses TKIP (Temporal Key Integrity Protocol) which generates a new key for every packet. While much better than WEP, TKIP has its own vulnerabilities and WPA is now deprecated.

WPA2 — Wi-Fi Protected Access 2

Definition: WPA2

WPA2 (2004) uses AES-CCMP encryption instead of RC4/TKIP. It is the current widely deployed standard. Two modes: WPA2-Personal (PSK — pre-shared key for home) and WPA2-Enterprise (802.1X with RADIUS server for corporate).

WPA2 Authentication — 4-Way Handshake

```
CLIENT (Supplicant)              ACCESS POINT (Authenticator)
     |                                    |
     | Both know: PSK (password)          |
     | Both derive: PMK from PSK          |
     |                                    |
```

```
        |<-------1. ANonce (random)----------|
        |                                    |
        | Derive PTK (session key)           |
        |                                    |
        |--------2. SNonce + MIC------------>|
        |                                    |
        |                     Derive PTK     |
        |<-------3. GTK (group key) + MIC----|
        |                                    |
        |--------4. ACK (install keys)------>|
        |                                    |
   [Encrypted Communication with PTK]        |

   KRACK attack exploits step 3 replay to reinstall keys
```

Wireless Security Best Practices

- Use WPA3 if devices support it; minimum WPA2
- Use strong, random Wi-Fi password (20+ characters)
- Disable WPS (Wi-Fi Protected Setup) — it has known vulnerabilities
- Change default router admin password
- Enable network encryption — never use open/unsecured Wi-Fi
- Use VPN on public Wi-Fi networks
- Keep router firmware updated
- Use MAC address filtering as additional layer (not sole protection)

Exam Important:

Q: Explain WEP, WPA, WPA2 with their security features and differences. [10M]

Q: Why is WEP considered insecure? [5M]

Q: What is WPA2 4-Way Handshake? [5M]

Q: Differentiate between WPA2-Personal and WPA2-Enterprise. [5M]

5.5 Email Security — PGP and S/MIME

Definition: Email Security

Email security protects email communications from unauthorized access, loss, or compromise. Email is one of the most common attack vectors for phishing, malware distribution, and business email compromise.

Email Security Threats

- **Phishing:** Fake emails tricking users into revealing credentials or clicking malicious links
- **Spam:** Unsolicited bulk email — wastes resources and may contain malware
- **Email Spoofing:** Forging sender address to appear as trusted entity
- **Malware Attachments:** Executable files, macro-enabled documents, infected PDFs

- **Man-in-the-Middle:** Intercepting email in transit

PGP — Pretty Good Privacy

Definition: PGP (Pretty Good Privacy)

PGP is an email encryption program that provides cryptographic privacy and authentication for data communication. Created by Phil Zimmermann in 1991. It uses a combination of symmetric and asymmetric encryption plus digital signatures.

PGP Email Encryption Process

```
  SENDER (Alice) -> RECEIVER (Bob)

  ENCRYPTION STEPS:
  1. Alice writes email (plaintext)
  2. PGP generates random session key (symmetric)
  3. Email encrypted with session key (AES/IDEA)
  4. Session key encrypted with Bob's PUBLIC KEY (RSA)
  5. Alice signs with her PRIVATE KEY -> Digital Signature
  6. Send: Encrypted Email + Encrypted Session Key + Signature

  DECRYPTION STEPS (at Bob):
  1. Decrypt session key with Bob's PRIVATE KEY
  2. Decrypt email with session key
  3. Verify Alice's signature with Alice's PUBLIC KEY
  4. Read plaintext email

  PGP provides: Confidentiality + Integrity + Authentication + Non-
repudiation
```

PGP Web of Trust

Definition: Web of Trust

PGP uses a decentralized trust model called Web of Trust instead of Certificate Authorities. Users sign each other's public keys to vouch for their authenticity. If Alice trusts Bob and Bob trusts Carol, Alice can trust Carol's key.

S/MIME — Secure/Multipurpose Internet Mail Extensions

Definition: S/MIME

S/MIME is a standard for public key encryption and signing of MIME data (email). It provides authentication, message integrity, non-repudiation, and data encryption for email. Unlike PGP, S/MIME uses a hierarchical PKI with Certificate Authorities.

Feature	PGP	S/MIME
Trust Model	Web of Trust (decentralized)	PKI with Certificate Authorities
Certificate	PGP public key certificates	X.509 certificates from CA

Adoption	Individual users, developers	Corporate email (Outlook, Exchange)
Setup	Manual key exchange	Buy/get certificate from CA
Encryption	Hybrid (RSA + symmetric)	Hybrid (RSA + symmetric)
Standard	OpenPGP (RFC 4880)	S/MIME (RFC 5751)

⍰ Exam Important:

Q: Explain PGP email security with encryption process. [10M]

Q: Differentiate between PGP and S/MIME. [5M]

Q: What is Web of Trust in PGP? [5M]

Q: What are the main threats to email security? [5M]

5.6 Important Q&A — Unit 5

2 Mark Questions

Q: What is a Firewall? [2M Marks]

Ans: A firewall is a network security device that monitors and controls incoming and outgoing network traffic based on predefined security rules. It acts as a barrier between trusted internal networks and untrusted external networks like the Internet.

Q: What is VPN? [2M Marks]

Ans: VPN (Virtual Private Network) creates a secure encrypted tunnel over the Internet, connecting remote users to private networks as if directly connected. It provides confidentiality and authentication over untrusted public networks.

Q: What is WEP? [2M Marks]

Ans: WEP (Wired Equivalent Privacy) was the first wireless security protocol (1997) using RC4 encryption. It is completely broken due to weak 24-bit Initialization Vectors that allow attackers to crack the key in minutes. WEP should never be used.

Q: What is PGP? [2M Marks]

Ans: PGP (Pretty Good Privacy) is an email encryption program providing confidentiality, authentication, and digital signatures for email communication. It uses hybrid encryption: symmetric key for email content and asymmetric key (RSA) for encrypting the symmetric key.

5 Mark Questions

Q: Compare Packet Filtering and Stateful Inspection Firewalls. [5M Marks]

Ans: PACKET FILTERING: Examines each packet individually based on IP/port rules. No memory of connections. Simple, fast, low cost. Cannot detect IP spoofing or application attacks.

STATEFUL INSPECTION: Tracks state of all active connections in a state table. Knows if a packet is part of existing connection or new. Allows return traffic for established connections automatically. Better security than packet filtering. Slower but smarter. Example: allows client's HTTP response only if client sent HTTP request first.

Q: Explain WPA2 security and its advantages over WEP. [5M Marks]

Ans: WEP (1997) weaknesses: RC4 encryption, small 24-bit IV causing key reuse, static keys, no integrity protection — cracked in minutes. WPA2 improvements: 1. AES-CCMP encryption instead of weak RC4. 2. 128-bit keys instead of 40/104-bit. 3. Dynamic key generation per session. 4. Message Integrity Check (MIC). 5. 4-Way Handshake for key agreement. 6. Two modes: Personal (PSK for home) and Enterprise (802.1X + RADIUS for corporate). WPA2 is the current standard, though WPA3 is recommended for new deployments.

10 Mark Questions

Q: Explain different types of Firewalls in detail. [10M Marks]

Ans: FIREWALLS are security devices controlling network traffic. TYPES: 1. PACKET FILTERING FIREWALL: Examines IP/port headers of each packet. Rules in ACL allow/deny based on source IP, destination IP, port, protocol. Fast and simple but no state awareness. 2. STATEFUL INSPECTION FIREWALL: Tracks connection state table. Understands context of packets — is this part of established connection? More secure than packet filter. 3. APPLICATION GATEWAY (PROXY FIREWALL): Operates at Layer 7. Acts as proxy between client and server. Fully understands application protocols (HTTP, FTP). Can inspect content, block URLs, detect application attacks. Slowest but most thorough. 4. NEXT-GENERATION FIREWALL (NGFW): Combines all above + DPI (Deep Packet Inspection), IDS/IPS, user identity awareness, application control. Most comprehensive but expensive. FIREWALL PLACEMENT: Typically at network perimeter, between Internet and internal network. DMZ (Demilitarized Zone) places public servers between two firewalls.

Unit 5 (Extended): VPN & Security Protocols — Deep Dive

5.8 TLS Handshake — Detailed

Definition: TLS (Transport Layer Security)

The current standard protocol for securing internet communications. TLS 1.3 is the latest version (2018). Used in HTTPS, email (IMAPS, SMTPS), and any TCP-based protocol needing security.

TLS 1.3 Handshake (Simplified)

```
CLIENT                                SERVER
  |                                     |
  |--- ClientHello -----------------> |  (supported ciphers, TLS
version, random)
  |                                     |
  |<-- ServerHello ------------------|  (chosen cipher, random,
certificate)
  |<-- Certificate ------------------|  (server's digital certificate)
  |<-- ServerHelloDone --------------|
  |                                     |
  | [Verify certificate signature]    |
  | [Generate pre-master secret]      |
  |--- ClientKeyExchange -----------> |  (encrypted pre-master secret)
  |--- ChangeCipherSpec ------------> |  (switching to encrypted mode)
  |--- Finished --------------------> |  (HMAC of all handshake
messages)
  |                                     |
  |<-- ChangeCipherSpec -------------|
  |<-- Finished --------------------|
  |                                     |
  |=== Encrypted Application Data ===> |  (HTTP, etc.)
```

TLS Version	Year	Key Exchange	Cipher Support	Status
SSL 3.0	1996	RSA	RC4, DES	BROKEN — POODLE attack
TLS 1.0	1999	RSA, DH	RC4, 3DES, AES	DEPRECATED — 2021
TLS 1.1	2006	RSA, DH	AES	DEPRECATED — 2021
TLS 1.2	2008	RSA, ECDH	AES-GCM, ChaCha20	Still widely used
TLS 1.3	2018	ECDH only	AES-GCM, ChaCha20	RECOMMENDED — current

5.9 IPSec — Detailed Modes and Protocols

Component	AH (Authentication Header)	ESP (Encapsulating Security Payload)
Provides	Authentication + Integrity	Authentication + Integrity + Confidentiality

Encryption	NO	YES — full payload encrypted
IP Header Protected	YES — includes IP header in auth	Partially — new IP header not protected in tunnel mode
Protocol Number	51	50
NAT Compatible	NO — NAT changes IP, breaks auth	YES (ESP with NAT-T on port 4500)
Use Case	Integrity-only needs	Most VPN deployments (preferred)

IPSec Tunnel Mode vs Transport Mode

```
TRANSPORT MODE (host-to-host):
  [Original IP Hdr] [AH/ESP] [TCP Hdr] [Data]
  Only payload protected, IP header visible

TUNNEL MODE (gateway-to-gateway — VPN):
  [New IP Hdr] [AH/ESP] [Original IP Hdr] [TCP Hdr] [Data]
  Entire original packet encrypted inside new IP packet
  Original source/destination hidden from internet

Tunnel mode used for: Site-to-site VPN, Remote access VPN
Transport mode used for: Host-to-host secure comms (rarely used)
```

5.10 VPN Types Comparison

VPN Type	Protocol	Use Case	Security	Speed	Setup
Remote Access VPN	SSL/TLS, IPSec	Single user connecting to corporate network	High	Good	Client software needed
Site-to-Site VPN	IPSec	Connect two office networks	High	Good	Router/firewall config
SSL VPN	TLS (HTTPS)	Browser-based, clientless access	High	Good	Works through any browser
PPTP VPN	PPTP	Legacy — being phased out	WEAK — broken	Fast	Easy setup
L2TP/IPSec	L2TP + IPSec	General purpose	Good	Moderate	Built into most OS
OpenVPN	SSL/TLS	Open-source, flexible	High	Good	Open-source client
WireGuard	Custom	Modern, fast, simple	Very High	Excellent	Lightweight, ~4000 lines of code

5.11 SSH — Secure Shell

Definition: SSH (Secure Shell)

A cryptographic network protocol for operating network services securely over an unsecured network. Primarily used for remote login to Linux/Unix servers, secure file transfer (SFTP), and tunneling.

SSH Features

Replaces insecure Telnet, rlogin, rsh (all send data as plaintext)

Authentication: Password, Public key (recommended), Certificate-based

Encryption: AES, ChaCha20 for confidentiality

Integrity: HMAC-SHA2 for data integrity

Port Forwarding: Tunnel other protocols through SSH (SSH tunneling)

SFTP/SCP: Secure file transfer built on SSH

Default port: 22 (change this to reduce attacks!)

Public key auth: Store public key on server (~/.ssh/authorized_keys), keep private key on client

5.12 Key Protocols Summary

Protocol	Port	Purpose	Encryption	Replaces
HTTPS	443	Secure web browsing	TLS	HTTP (80) — plaintext
FTPS/SFTP	990/22	Secure file transfer	TLS/SSH	FTP (21) — plaintext
SMTPS	465/587	Secure email sending	TLS	SMTP (25) — plaintext
IMAPS	993	Secure email receiving	TLS	IMAP (143) — plaintext
POP3S	995	Secure email retrieval	TLS	POP3 (110) — plaintext
SSH	22	Secure remote login	SSH protocol	Telnet (23) — plaintext
LDAPS	636	Secure directory access	TLS	LDAP (389) — plaintext
DNSSEC	53	DNS with auth	Digital signatures	DNS (unsigned)

5.13 Exam Q&A — VPN & Protocols Extended

Q: Explain TLS 1.3 handshake step by step. [10 Marks Marks]

Ans: TLS 1.3 handshake: (1) Client sends ClientHello with supported cipher suites, TLS version, random number, and key share. (2) Server responds with ServerHello choosing cipher suite, its random, certificate, and key share. (3) Client verifies server certificate against trusted CA. (4) Both compute session keys from key shares using ECDH — no key transmitted! (5) Client sends Finished message (HMAC of all handshake messages). (6) Server sends Finished. Now encrypted

communication begins. TLS 1.3 improvements over 1.2: 1-RTT handshake (vs 2-RTT), removed weak ciphers (RC4, DES, RSA key exchange), perfect forward secrecy mandatory, 0-RTT resumption for repeat connections.

Q: What is IPSec? Explain its two modes and two protocols. [10 Marks Marks]

Ans: IPSec (Internet Protocol Security) is a suite of protocols for authenticating and encrypting IP packets. It operates at Network Layer (L3) and can protect any TCP/UDP traffic above it. Two protocols: (1) AH (Authentication Header, protocol 51): provides authentication and integrity using HMAC — does NOT encrypt payload, not NAT-compatible. (2) ESP (Encapsulating Security Payload, protocol 50): provides authentication, integrity AND confidentiality — encrypts payload, NAT-compatible (with NAT-T). Two modes: (1) Transport Mode: protects only payload, original IP header visible, used for host-to-host. (2) Tunnel Mode: wraps entire original packet in new IP packet, hides original addresses, used for VPN (site-to-site, remote access). ESP in Tunnel Mode is the most common for VPN.

Important Questions — Unit 5 Extended

[2 Marks] What is the difference between TLS 1.2 and TLS 1.3?

[2 Marks] Why is PPTP VPN considered insecure?

[2 Marks] What is the difference between SFTP and FTPS?

[5 Marks] Explain AH and ESP protocols in IPSec.

[5 Marks] Compare Remote Access VPN and Site-to-Site VPN.

[10 Marks] Explain TLS handshake in detail. Why is certificate verification important?

Unit 6 (Extended): Digital Signatures & PKI — Deep Dive

6.8 Digital Signature — Step by Step

Digital Signature — Complete Process

```
SIGNING (Sender — Alice):
  Message M
     |
  [Hash function SHA-256] -> Hash H
     |
  [Encrypt H with Alice's PRIVATE KEY] -> Signature S
     |
  Send: Message M + Signature S

VERIFICATION (Receiver — Bob):
  Receive: Message M + Signature S
     |
  Step 1: [Decrypt S with Alice's PUBLIC KEY] -> Hash H1
  Step 2: [Hash received M with SHA-256] -> Hash H2
  Step 3: Compare H1 == H2?
          YES -> Signature VALID (message authentic, unmodified, non-
repudiation)
          NO  -> Signature INVALID (tampered or wrong sender)
```

Property Provided	Digital Signature	MAC (HMAC)	Encryption
Authentication	YES — only private key holder can sign	YES — only key holders can compute	Partial — proves possession of key
Integrity	YES — any modification invalidates sig	YES	YES
Non-repudiation	YES — only signer has private key	NO — both parties share same key	NO
Confidentiality	NO — doesn't hide content	NO	YES
Public Verification	YES — anyone with public key can verify	NO — need shared secret	N/A

6.9 RSA vs ECDSA vs DSA

Algorithm	Key Size (equivalent security)	Speed	Use Case	Status
RSA	2048-4096 bits	Slow sign, fast verify	Signatures, key exchange	Still widely used
DSA	2048 bits (+ SHA)	Moderate	Digital signatures only	Being replaced by ECDSA
ECDSA	256 bits	Fast sign and	TLS, Bitcoin, code	Recommended —

		verify	signing	current
EdDSA (Ed25519)	256 bits	Very fast	SSH keys, TLS 1.3	Modern — best choice

6.10 PKI — Public Key Infrastructure

Definition: PKI (Public Key Infrastructure)

A comprehensive system of hardware, software, policies, and standards used to manage digital certificates and public-key encryption. PKI establishes trust in digital identities at scale.

PKI Hierarchy (Chain of Trust)

```
ROOT CA (Root Certificate Authority)
  Self-signed certificate — offline, maximum security
  Trusted by all browsers/OS by default (pre-installed)
  Example: DigiCert Root, Let's Encrypt Root
       |
       | signs
       v
INTERMEDIATE CA
  Certificate signed by Root CA
  Issues end-entity certificates
  Can be revoked without invalidating Root
       |
       | signs
       v
END-ENTITY CERTIFICATE
  Your website's SSL certificate (e.g., www.jayviklabs.online)
  Contains: public key, domain name, validity period, issuer
```

6.11 X.509 Certificate — Contents

Field	Description	Example
Version	Certificate format version	Version 3
Serial Number	Unique number assigned by CA	1A:2B:3C:4D...
Signature Algorithm	Algorithm used to sign certificate	SHA256withRSA
Issuer	CA that issued the certificate	DigiCert Inc
Validity Period	Not Before / Not After dates	2024-01-01 to 2025-01-01
Subject	Entity the certificate was issued to	CN=www.jayviklabs.online
Public Key	Subject's public key	RSA 2048-bit or EC 256-bit
Subject Alt Names	Additional domains/IPs covered	*.jayviklabs.online
Key Usage	What certificate can be used for	Digital Signature, Key Encipherment
CA Signature	CA's digital signature on all above fields	Proves certificate is authentic

6.12 Certificate Revocation

Definition: Certificate Revocation

Process of invalidating a certificate before its expiry date, due to compromise of private key, change in ownership, or CA mistake. Browsers must check revocation status before trusting a certificate.

Method	How It Works	Pros	Cons
CRL (Certificate Revocation List)	CA publishes list of revoked serial numbers	Simple, complete list	Large file, not real-time, must be downloaded
OCSP (Online Certificate Status Protocol)	Real-time query to CA: 'Is this cert valid?'	Real-time, small response	Requires internet, CA knows which sites you visit (privacy)
OCSP Stapling	Server pre-fetches OCSP response, attaches to TLS handshake	Real-time, no privacy issue, faster	Server must support stapling
Certificate Transparency (CT)	Public log of all issued certificates	Detect rogue certificates	Not revocation — detection only

6.13 Code Signing & Email Security

Definition: Code Signing

Digital signatures applied to software/executables to prove they come from a known publisher and haven't been tampered with since signing. Used by Microsoft (Windows drivers), Apple (App Store), Java JAR files.

Email Security Standard	What It Does	Protocol
S/MIME	Signs and/or encrypts email content using X.509 certificates	Certificate-based
PGP/GPG	Signs and/or encrypts email using web-of-trust key model	Key-pair based
SPF	Verifies email came from authorized mail server for domain	DNS TXT record
DKIM	Email headers signed by sending domain — proves not tampered	DNS public key
DMARC	Policy: what to do if SPF/DKIM fail (reject, quarantine, report)	DNS TXT record

6.14 Exam Q&A — PKI Extended

Q: Explain PKI and the concept of chain of trust. [10 Marks Marks]

Ans: PKI (Public Key Infrastructure) is a system for managing digital certificates and public key encryption to establish trust. Chain of Trust: Root CA at top — self-signed, trusted by all OS/browsers (pre-installed). Root CA signs Intermediate CA certificates. Intermediate CA issues end-entity (website) certificates. Browser verification: (1) Receive website certificate. (2) Check it's signed by known Intermediate CA. (3) Check Intermediate CA certificate is signed by Root CA. (4) Root CA is in browser trust store — verified! Chain only trusted if all links valid. Certificate Revocation: certificates can be revoked before expiry using CRL or OCSP. Real-world CAs: DigiCert, Let's Encrypt, Comodo, GlobalSign.

Q: What is a digital signature? How does it ensure non-repudiation? [5 Marks Marks]

Ans: Digital signature: sender hashes the message with SHA-256, then encrypts the hash with their private key — this encrypted hash is the signature. Anyone can verify using sender's public key. Non-repudiation: only the sender has their private key — if signature verifies correctly with sender's public key, only that sender could have created it. Sender cannot deny sending the message. This is unlike MAC where both parties share the same key — either could have created the MAC, so neither can be proven the originator. Digital signatures used in: TLS certificates, code signing, email (S/MIME), blockchain transactions, legal e-documents (DocuSign).

Important Questions — Unit 6 Extended

[2 Marks] What is a CA? What is a Root CA vs Intermediate CA?

[2 Marks] What is certificate revocation? Name two methods.

[2 Marks] What is OCSP Stapling? Why is it better than OCSP?

[5 Marks] Explain X.509 certificate fields with examples.

[5 Marks] Explain code signing and its importance.

[10 Marks] Explain PKI with complete diagram showing Root CA, Intermediate CA, end-entity certificate, and browser verification process.

Unit 7 (Extended): Cyber Laws & IT Act — Complete Guide

7.10 IT Act 2000 — All Important Sections

Section	Topic	Offense	Punishment
Sec 43	Unauthorized access/damage	Hacking, damaging computer systems, downloading data without permission	Compensation up to ₹1 crore (civil)
Sec 43A	Data protection by corporates	Failure to implement reasonable security — data breach	Compensation to affected persons
Sec 65	Tampering source code	Knowingly concealing, destroying, altering computer source code	3 years jail OR ₹2 lakh fine OR both
Sec 66	Computer-related offenses	Dishonestly/fraudulently committing acts under Sec 43	3 years jail OR ₹5 lakh fine OR both
Sec 66A	Offensive messages (REPEALED)	Sending offensive/menacing messages — STRUCK DOWN by Supreme Court 2015	N/A — unconstitutional
Sec 66B	Receiving stolen computer resources	Dishonestly receiving stolen data/device	3 years jail OR ₹1 lakh fine OR both
Sec 66C	Identity theft	Fraudulently using another's electronic signature, password, unique ID	3 years jail AND ₹1 lakh fine
Sec 66D	Cheating by impersonation	Impersonating online to cheat	3 years jail AND ₹1 lakh fine
Sec 66E	Privacy violation	Capturing/transmitting private images without consent	3 years jail OR ₹2 lakh fine OR both
Sec 66F	Cyber terrorism	Attacking critical infrastructure (power, banking) threatening national security	Life imprisonment
Sec 67	Publishing obscene material	Obscene electronic content	5 years jail AND ₹10 lakh fine
Sec 67A	Sexually explicit content	Publishing sexually explicit acts online	7 years jail AND ₹10 lakh fine
Sec 67B	Child pornography	Publishing child sexual abuse material online	5-7 years jail AND ₹10 lakh fine
Sec 69	Interception of data	Government interception of information in national interest	7 years jail (if decryption refused)
Sec 70	Protected systems	Unauthorized access to government critical infrastructure	10 years jail AND fine
Sec 72	Breach of confidentiality	Disclosing private info obtained during lawful access	2 years jail OR ₹1 lakh fine OR both
Sec 75	Extra-territorial jurisdiction	IT Act applies to offenses outside India if computer is in India	Applicable globally

7.11 Indian Cyber Crime Reporting

How to Report Cyber Crime in India

National Cybercrime Reporting Portal: cybercrime.gov.in
Helpline Number: 1930 (24x7 National Cyber Crime Helpline)
Report to local Cyber Crime Cell in your city/district
Categories to report: Financial fraud, online abuse, hacking, identity theft
Documents needed: Screenshots, bank statements, email headers, URLs
Time limit: Report financial fraud within 24 hours for best chance of recovery
For women/children related crimes: Separate priority reporting on portal

7.12 GDPR vs Indian PDPB

Aspect	GDPR (EU — 2018)	PDPB/DPDP Act (India — 2023)
Full Name	General Data Protection Regulation	Digital Personal Data Protection Act
Applies To	Any org processing EU citizens' data	Any org processing Indian citizens' data
Data Principal Rights	Access, rectify, erase, port, object	Access, correction, erasure, grievance redressal
Consent	Explicit, informed, withdrawable	Explicit, informed, withdrawable
Data Localization	No strict localization	Certain data must stay in India (to be notified)
Max Penalty	€20 million or 4% global revenue	₹250 crore per violation
DPO Required	Yes, for large processors	Yes, for significant data fiduciaries

7.13 Important Cyber Law Cases — India

Case/Incident	Year	Issue	Outcome/Significance
Avnish Bajaj vs State (Bazee.com)	2005	Obscene MMS video listed on site	CEO arrested under IT Act — ISP liability established
Sec 66A Struck Down	2015	Shreya Singhal vs Union of India	Supreme Court: Sec 66A unconstitutional — violated free speech
WhatsApp Privacy Policy	2021	WhatsApp sharing data with Facebook	CCI inquiry — data protection in focus
AIIMS Delhi Ransomware	2022	Ransomware attack on hospital systems	Patient data encrypted — highlighted critical infrastructure vulnerability
Aadhaar Data Breach Concerns	2018	Alleged breach of Aadhaar database	UIDAI denied breach — highlighted data protection gaps

7.14 Cyber Ethics

Definition: Cyber Ethics

A set of moral principles and code of conduct that governs how individuals should behave in the digital/online world. Cyber ethics emphasizes responsible, respectful, and legal use of technology.

Key Principles of Cyber Ethics

Thou shalt not use a computer to harm other people
Thou shalt not interfere with other people's computer work
Thou shalt not snoop around in other people's computer files
Thou shalt not use a computer to steal
Thou shalt not use a computer to bear false witness
Thou shalt not copy or use proprietary software without paying (piracy)
Thou shalt not use other people's computer resources without authorization
Thou shalt think about the social consequences of programs you create
Thou shalt always use a computer in ways that ensure respect for others
(Source: Ten Commandments of Computer Ethics — CEI 1992)

7.15 Exam Q&A — Cyber Laws Extended

Q: What are the important sections of the IT Act 2000? Explain with examples. [10 Marks Marks]

Ans: The IT Act 2000 (Information Technology Act) is India's primary law for cybercrime and e-commerce. Key sections: Sec 43 — unauthorized access, hacking (compensation up to ₹1 crore). Sec 65 — tampering source code (3 years jail). Sec 66 — computer fraud (3 years jail, ₹5 lakh fine). Sec 66C — identity theft (3 years jail). Sec 66D — cheating by impersonation online. Sec 66E — privacy violation (capturing private images). Sec 66F — CYBER TERRORISM (life imprisonment — most severe). Sec 67B — child pornography. Sec 70 — attacking protected government systems (10 years). IT Act 2008 amendment strengthened provisions for data protection, cyber terrorism, and gave more powers to government for interception.

Q: What is cyber terrorism? What punishment does the IT Act prescribe? [5 Marks Marks]

Ans: Cyber terrorism (Section 66F of IT Act 2000) means threatening the unity, integrity, security, or sovereignty of India by using computer networks to: deny authorized access to critical systems, penetrate critical information infrastructure (banking, power, defense), introduce malware into critical systems, or steal information used for threatening or striking terror. Punishment: Life imprisonment. This is the most severe punishment in the IT Act. Examples: Attacking the Indian power grid, hacking SEBI/RBI systems, compromising defense networks.

Important Questions — Unit 7 Extended

[2 Marks] What is Section 66F of IT Act? What is the punishment?
[2 Marks] What is cybercrime.gov.in? What helpline number is available?
[2 Marks] What is the difference between GDPR and India's DPDP Act?

[5 Marks] List and explain any 6 important sections of the IT Act 2000.

[5 Marks] What is cyber ethics? List the Ten Commandments of Computer Ethics.

[10 Marks] Explain the IT Act 2000 in detail — objectives, key provisions, and important sections with punishments.

Unit 8 (Extended): Ethical Hacking & Penetration Testing — Deep Dive

8.9 Penetration Testing — Phases in Detail

Complete Penetration Testing Methodology

```
Phase 1: PLANNING & RECONNAISSANCE
  - Define scope, rules of engagement, legal authorization
  - Passive recon: OSINT (Google, LinkedIn, WHOIS, Shodan)
  - Active recon: port scanning (nmap), service fingerprinting
      |
Phase 2: SCANNING & ENUMERATION
  - Vulnerability scanning (Nessus, OpenVAS)
  - Service enumeration (banner grabbing, version detection)
  - Network mapping (traceroute, netdiscover)
      |
Phase 3: EXPLOITATION
  - Use found vulnerabilities to gain access
  - Metasploit Framework, manual exploits
  - Password attacks (Hydra, John the Ripper)
      |
Phase 4: POST-EXPLOITATION
  - Privilege escalation, lateral movement
  - Data exfiltration testing, persistence
      |
Phase 5: REPORTING
  - Document all findings with severity ratings
  - Provide remediation recommendations
  - Executive summary + technical details
```

8.10 Reconnaissance Techniques

Technique	Type	Tools	What You Find
WHOIS Lookup	Passive	whois.domaintools.com	Domain owner, registrar, contact, name servers
DNS Enumeration	Passive/Active	nslookup, dig, dnsx	Subdomains, MX records, SPF/DMARC, IP ranges
Google Dorking	Passive	Google search operators	Exposed files, login pages, vulnerable parameters
Shodan	Passive	shodan.io	Internet-exposed devices, open ports, banners, CVEs
LinkedIn OSINT	Passive	LinkedIn, Hunter.io	Employees, email formats, technologies used
Network Scanning	Active	nmap	Open ports, running services, OS fingerprint
Vulnerability Scan	Active	Nessus, OpenVAS	Known CVEs, misconfigurations, weak passwords

Nmap — Common Commands

```
nmap -sV 192.168.1.1        # Service/version detection
nmap -sS 192.168.1.0/24     # Stealth SYN scan on subnet
nmap -A 192.168.1.1         # Aggressive: OS detect + scripts + traceroute
nmap -p 80,443 10.0.0.1     # Scan only ports 80, 443
nmap -p- 192.168.1.1        # Scan ALL 65535 ports
nmap --script vuln 10.0.0.1 # Run vulnerability scripts
nmap -sU 192.168.1.1        # UDP scan
```

8.11 Password Attacks

Attack Type	Description	Tools	Defense
Brute Force	Try every possible combination	Hydra, Medusa, John	Account lockout, strong passwords
Dictionary Attack	Try words from wordlist	John the Ripper, Hashcat	Complex passwords, passphrases
Rainbow Table	Pre-computed hash lookups	Ophcrack, RainbowCrack	Password salting
Credential Stuffing	Use leaked username/password pairs	Sentry MBA, OpenBullet	MFA, breach monitoring
Pass-the-Hash	Use captured NTLM hash without cracking	Mimikatz, Metasploit	Protected Users group, Credential Guard
Phishing	Trick user to enter credentials	GoPhish, SET	Security awareness training, MFA

8.12 Common Exploitation Frameworks

Metasploit Framework

Most widely used penetration testing framework (open-source)
Components: msfconsole (CLI), msfvenom (payload generator), Armitage (GUI)
Modules: Exploits, Payloads, Encoders, Auxiliary, Post
Meterpreter: Advanced payload — file system, network, screenshot, keylog
Usage flow: search -> use exploit -> set options -> run
Example: search ms17-010 -> use exploit/windows/smb/ms17_010_eternalblue
Used in authorized penetration tests ONLY — illegal without permission

Tool	Category	Purpose
Metasploit	Exploitation framework	Complete pentest framework — exploit, payload, post-exploit
Burp Suite	Web app testing	Intercept/modify HTTP, find web vulnerabilities

Wireshark	Network analysis	Capture and analyze network packets
Aircrack-ng	Wireless testing	WiFi password cracking, monitor mode, packet injection
John the Ripper	Password cracking	Offline hash cracking with wordlists/rules
Hashcat	Password cracking	GPU-accelerated hash cracking (fastest)
SQLmap	SQL injection	Automated SQL injection detection and exploitation
Nikto	Web scanning	Web server vulnerability scanner
Kali Linux	OS/platform	All pentesting tools pre-installed distribution
OWASP ZAP	Web app testing	Open-source web proxy for finding vulnerabilities

8.13 OWASP Top 10 Web Vulnerabilities (2021)

Rank	Vulnerability	Description	Prevention
A01	Broken Access Control	Users can act outside their intended permissions	Server-side access control, deny by default
A02	Cryptographic Failures	Weak/missing encryption — data exposed in transit/rest	TLS, AES-256, hash+salt passwords
A03	Injection (SQLi, XSS)	Untrusted data sent as command/query	Parameterized queries, input validation
A04	Insecure Design	Architectural flaws in design phase	Threat modeling, security design review
A05	Security Misconfiguration	Default/incomplete/wrong security config	Hardening, remove defaults, patch management
A06	Vulnerable Components	Using libraries with known CVEs	SCA tools, update dependencies, SBOM
A07	Identity & Auth Failures	Broken authentication, session management	MFA, strong passwords, secure session tokens
A08	Software & Data Integrity	CI/CD pipeline compromised, insecure updates	Code signing, integrity verification
A09	Security Logging Failures	Attacks not logged/detected	Comprehensive logging, SIEM, alerting
A10	SSRF	Server-side request forgery — server makes unintended requests	Validate/sanitize URLs, network policies

8.14 Exam Q&A — Ethical Hacking Extended

Q: What is the difference between white hat, black hat, and grey hat hackers? [5 Marks Marks]

Ans: White hat hackers (ethical hackers): security professionals who hack systems WITH permission to find vulnerabilities and improve security. They follow rules of engagement, document findings, and report to organization. Certifications: CEH, OSCP, CISSP. Black hat hackers (crackers): hack systems WITHOUT permission for personal gain, to cause damage, or to steal data. Criminal activity — prosecuted under IT Act. Grey hat hackers: operate between white and black hat — may hack without explicit permission but report findings (sometimes for a fee). Still technically illegal without authorization. Key distinction: AUTHORIZATION. Same skills, different ethics and legality.

Q: Explain the phases of penetration testing. [10 Marks Marks]

Ans: Pen testing has 5 phases: (1) Planning & Reconnaissance: Define scope and get written authorization, passive recon (WHOIS, LinkedIn, Google dorking), active recon (Nmap scanning). (2) Scanning & Enumeration: Vulnerability scanning (Nessus), service enumeration, network mapping. (3) Exploitation: Use vulnerabilities to gain access — Metasploit, manual exploits, password attacks. (4) Post-Exploitation: Privilege escalation, lateral movement, data exfiltration testing, persistence. (5) Reporting: Document ALL findings with CVSS severity scores, proof-of-concept screenshots, remediation recommendations, executive summary. Deliverable: Penetration Test Report. Critical: WRITTEN AUTHORIZATION before any testing — without it, it's a crime.

Important Questions — Unit 8 Extended

[2 Marks] What is OWASP? Name the top 3 web vulnerabilities from OWASP Top 10 2021.

[2 Marks] What is Metasploit? Name its main components.

[2 Marks] What is the difference between active and passive reconnaissance?

[5 Marks] Explain password attack types: brute force, dictionary, rainbow table. How to defend?

[5 Marks] What is Google Dorking? Give 3 examples of useful dorks.

[10 Marks] Explain the five phases of penetration testing with detailed activities in each phase.

Unit 9 (Extended): Wireless Network Security — Deep Dive

9.8 WiFi Security Protocols — Complete Comparison

Protocol	Year	Encryption	Key Management	Handshake	Vulnerabilities	Status
WEP	1997	RC4 (40/104-bit key)	Static PSK	None (broken)	IV reuse, FMS attack — cracked in minutes	DEPRECATED — NEVER USE
WPA	2003	RC4 + TKIP	Dynamic per-packet	4-way handshake	TKIP attacks, MITM	DEPRECATED
WPA2-Personal	2004	AES-CCMP	PSK (shared password)	4-way handshake	KRACK, offline dict attack on handshake	Still widely used
WPA2-Enterprise	2004	AES-CCMP	802.1X/EAP + RADIUS	EAP + 4-way	Rogue AP attacks	Recommended for corporate
WPA3-Personal	2018	AES-GCMP-256	SAE (replaces PSK)	Dragonfly handshake	Timing side-channels (patched)	RECOMMENDED — current
WPA3-Enterprise	2018	AES-GCMP-256	802.1X/EAP	192-bit security mode	Complex setup	Best — use for sensitive networks

9.9 WPA2 Attacks — KRACK & Handshake Capture

Definition: KRACK (Key Reinstallation Attack)

A 2017 vulnerability in WPA2 that allowed attackers to force nonce reuse in the 4-way handshake by replaying handshake messages, potentially decrypting encrypted WPA2 traffic. Patched via OS updates.

Definition: WPA2 Handshake Capture Attack

Attacker captures the 4-way WPA2 handshake (by deauthenticating a client to force reconnection), then performs offline dictionary/brute-force attack against the captured handshake to find the WiFi password.

WPA2 4-Way Handshake

```
  ACCESS POINT (AP)                CLIENT (STA)
       |                                |
       |--- ANonce (random) ---------> |  Message 1
       |                                | [Derives PTK using ANonce +
SNonce + PSK]
       | <-- SNonce + MIC ----------- |  Message 2  <- CAPTURED BY
ATTACKER
       | [Derives PTK, verifies MIC]  |
```

```
        |--- GTK (group key) + MIC --> |  Message 3
        | <-- ACK -------------------- |  Message 4
        |                              |
   Handshake captured -> attacker tries passwords offline
   Tool: aircrack-ng -w wordlist.txt capture.pcap
   Defense: LONG random password (20+ chars), WPA3
```

9.10 Wireless Attacks

Attack	Description	Tools	Prevention
Evil Twin / Rogue AP	Create fake WiFi with same SSID as legitimate network	hostapd-wpe, airbase-ng	802.1X auth, VPN, verify BSSID
Deauthentication Attack	Send spoofed deauth frames to disconnect clients (DoS)	aireplay-ng	802.11w (Management Frame Protection)
WPS PIN Attack	WPS PIN has design flaw — 11,000 max guesses to crack	Reaver, Bully	DISABLE WPS on router
PMKID Attack	Capture single PMKID packet (no need for 4-way handshake)	hcxdumptool + hashcat	Strong password, WPA3
Wardriving	Driving around to map/collect WiFi network info	Kismet, WiFi Pineapple	Hide SSID (partial), MAC filtering
Bluesnarfing	Unauthorized access to Bluetooth device data	BTCrack	Disable Bluetooth discovery, pair carefully
Bluejacking	Sending unsolicited Bluetooth messages	Custom scripts	Disable Bluetooth when not needed

9.11 WPA3 — New Features

WPA3 Improvements over WPA2

SAE (Simultaneous Authentication of Equals): Replaces PSK — immune to offline dictionary attacks

Forward Secrecy: Even if password discovered later, past sessions remain secure

OWE (Opportunistic Wireless Encryption): Encrypts open/public WiFi networks (no password needed)

192-bit Security: WPA3-Enterprise uses 192-bit cryptographic strength (CNSA suite)

Protected Management Frames (PMF): Mandatory in WPA3 — protects deauth/disassoc frames

Easy Connect: QR code based device onboarding (replaces WPS)

Dragonfly Handshake: Zero-knowledge proof — password never transmitted, even hashed

9.12 Bluetooth Security

BT Attack	Description	Target	Prevention
Bluejacking	Sending unsolicited messages via Bluetooth	Any BT device	Reject unknown BT requests
Bluesnarfing	Unauthorized access to contacts, calendars, messages	BT phones	Disable discoverability
Bluebugging	Full control of BT device — calls, SMS, listen in	BT phones (older)	Firmware updates, disable BT
Eavesdropping	Intercept BT communications	BT devices in range	BT 4.2+ LE Secure Connections
BIAS Attack (2020)	Bypass authentication in BT Classic using impersonation	BT Classic devices	Firmware patches

9.13 802.1X & RADIUS — Enterprise WiFi

Definition: 802.1X

An IEEE standard for port-based Network Access Control (NAC). Before a device is allowed on the network, it must authenticate using EAP through a RADIUS server. Used in corporate WiFi (WPA2/3-Enterprise).

802.1X Authentication Flow

```
CLIENT (Supplicant)      AP (Authenticator)     RADIUS Server
      |                        |                      |
      |---- EAP-Start -------> |                      |
      |                        |-- Access-Request --> |
      |<--- EAP-Request ------ |<--- EAP-Challenge -- |
      |---- EAP-Response (credentials) ---------->    |
      |                        |                      |
      |                        | [RADIUS validates]   |
      |                        |<-- Access-Accept ----| (or Reject)
      |<--- EAP-Success ------|                      |
      |                        |                      |
  CLIENT gets network access   Port opened            |
  (receives IP from DHCP)                             |
```

9.14 Wireless Security Best Practices

Enterprise WiFi Security Checklist

Use WPA3-Enterprise (or minimum WPA2-Enterprise with AES)

Deploy 802.1X authentication with RADIUS server (Active Directory integration)

Use certificates for EAP-TLS instead of passwords

Enable Management Frame Protection (802.11w) — prevents deauth attacks

DISABLE WPS completely — cannot be secured

Separate networks: Corporate VLAN, Guest VLAN, IoT VLAN

Change default SSID — don't reveal router brand
Use 5GHz/6GHz band — shorter range, fewer walls penetrated
Regular wireless site surveys — detect rogue APs
Monitor for deauth floods and Evil Twin APs
Implement NAC (Network Access Control) for device compliance

9.15 Exam Q&A — Wireless Extended

Q: Compare WEP, WPA, WPA2, and WPA3. Which is most secure? [10 Marks Marks]

Ans: WEP (1997): RC4 with static 40/104-bit key. Uses IV (Initialization Vector) but IVs repeat after 16 million packets — FMS attack can crack in minutes. COMPLETELY BROKEN. WPA (2003): RC4 with TKIP — dynamic per-packet keys, better than WEP but TKIP has weaknesses. DEPRECATED. WPA2 (2004): AES with CCMP — strong encryption. Vulnerable to KRACK (patched), offline handshake capture + dictionary attack, WPS pin attack. Still widely used. WPA3 (2018): AES-GCMP-256, SAE handshake (immune to offline attacks), mandatory PMF, forward secrecy, OWE for open networks. MOST SECURE. Recommendation: Use WPA3 where possible; minimum WPA2 with strong 20+ char random password and WPS disabled.

Q: What is an Evil Twin attack? How can it be prevented? [5 Marks Marks]

Ans: Evil Twin: Attacker creates a rogue WiFi Access Point with the SAME SSID as a legitimate network (e.g., 'CafeWiFi'). The attacker's AP broadcasts a stronger signal, forcing clients to connect to it. Attacker becomes MITM — can see all unencrypted traffic, capture credentials, serve malware. Attack tools: hostapd-wpe, WiFi Pineapple. Prevention: (1) Use 802.1X authentication — client verifies AP identity with certificate, cannot be faked. (2) Always use VPN — encrypt traffic even on untrusted networks. (3) Verify BSSID (MAC address) of known APs. (4) Enable 802.11w (Management Frame Protection). (5) Avoid sensitive activities on public WiFi.

Important Questions — Unit 9 Extended

[2 Marks] Why is WEP insecure? What attack breaks it?
[2 Marks] What is KRACK? Which WPA version is vulnerable?
[2 Marks] What is WPS? Why should it be disabled?
[2 Marks] What is 802.1X? What is a RADIUS server?
[5 Marks] Explain WPA2 handshake capture attack. How is it performed and prevented?
[5 Marks] List 5 wireless network attacks with descriptions and preventions.
[10 Marks] Explain WPA3 improvements over WPA2 in detail.

Key Definitions Glossary

All important terms from Network Security — BCA Solapur University. Learn these definitions for 2-mark questions in exams.

Term	Definition
Access Control	The process of restricting access to network resources to authorized users only.
AES	Advanced Encryption Standard — current symmetric encryption standard using 128-bit blocks and 128/192/256-bit keys.
AH (Auth Header)	IPSec protocol providing authentication and integrity but NOT confidentiality.
Asymmetric Crypto	Public key cryptography using key pairs — public key encrypts, private key decrypts.
Authentication	Process of verifying the identity of a user, device, or system.
Availability	Security goal ensuring systems and data are accessible to authorized users when needed.
Botnet	Network of compromised computers (bots/zombies) controlled by an attacker for malicious purposes.
Brute Force	Attack that tries all possible combinations of passwords/keys until correct one found.
CA (Certificate Authority)	Trusted third party that issues and signs digital certificates.
CIA Triad	Three core security goals: Confidentiality, Integrity, and Availability.
Ciphertext	Encrypted, unreadable form of plaintext produced by encryption algorithm.
Confidentiality	Security goal ensuring data is accessible only to authorized parties.
Cryptography	Science of securing information by converting plaintext to ciphertext using mathematical algorithms.
DDoS	Distributed Denial of Service — DoS attack using multiple compromised computers (botnet).
Decryption	Process of converting ciphertext back to readable plaintext using a key.
DES	Data Encryption Standard — old 64-bit block cipher with 56-bit key; now considered insecure.
Diffie-Hellman	Key exchange protocol allowing two parties to establish a shared secret over an insecure channel.
Digital Certificate	Electronic document binding a public key to an identity, signed by a Certificate Authority.
Digital Signature	Cryptographic mechanism proving authenticity, integrity, and non-repudiation of a message.
DoS	Denial of Service — attack preventing legitimate users from accessing network resources.

Encryption	Process of converting plaintext to unreadable ciphertext using a key and algorithm.
ESP	Encapsulating Security Payload — IPSec protocol providing confidentiality, integrity, and authentication.
Firewall	Network security device controlling incoming/outgoing traffic based on security rules.
Hash Function	One-way mathematical function converting any input to fixed-size output (digest).
IDS	Intrusion Detection System — monitors network/system for malicious activity and alerts.
Integrity	Security goal ensuring data is accurate and has not been tampered with.
IP Spoofing	Forging the source IP address in a packet to disguise the attacker's identity.
IPSec	IP Security — suite of protocols providing security at the network (IP) layer.
Kerberos	Network authentication protocol using tickets and a Key Distribution Center (KDC).
Key	Secret value used by encryption algorithm to transform plaintext to ciphertext.
Keylogger	Malware that records keystrokes to steal passwords and other sensitive information.
Malware	Malicious software designed to damage, disrupt, or gain unauthorized access to systems.
MITM	Man-in-the-Middle — attacker secretly intercepts and possibly alters communication between two parties.
MFA	Multi-Factor Authentication — requires two or more authentication factors for access.
MD5	Message Digest 5 — hash function producing 128-bit hash; now considered broken.
Non-repudiation	Security service preventing a party from denying they sent or received a message.
Passive Attack	Attack involving monitoring/eavesdropping without modifying data (e.g., traffic analysis).
PGP	Pretty Good Privacy — email encryption using hybrid cryptography and digital signatures.
Phishing	Social engineering attack using fake emails/websites to steal credentials.
PKI	Public Key Infrastructure — framework for managing digital certificates and public keys.
Plaintext	Original readable message before encryption.
Ransomware	Malware that encrypts victim's files and demands payment for the decryption key.

Replay Attack	Attacker captures valid data and retransmits it later to gain unauthorized access.
RSA	Asymmetric encryption algorithm based on difficulty of factoring large prime numbers.
Salt	Random value added to password before hashing to prevent rainbow table attacks.
SHA	Secure Hash Algorithm — family of hash functions (SHA-1 deprecated, SHA-256 secure).
S/MIME	Secure/Multipurpose Internet Mail Extensions — standard for email encryption using X.509 certificates.
Sniffing	Capturing network packets to read their contents — passive eavesdropping attack.
Spoofing	Faking identity — IP spoofing, email spoofing, DNS spoofing.
SSL/TLS	Protocols providing secure communication over the Internet (HTTPS uses TLS).
Stateful Firewall	Firewall tracking connection state to make more intelligent allow/deny decisions.
Symmetric Crypto	Cryptography using the SAME key for both encryption and decryption (e.g., AES, DES).
Trojan Horse	Malware disguised as legitimate software that creates a backdoor when installed.
VPN	Virtual Private Network — encrypted tunnel over Internet connecting remote users to private network.
Virus	Malware attaching to legitimate programs and replicating when infected program executes.
WEP	Wired Equivalent Privacy — first wireless security protocol; completely broken, do not use.
WPA2	Wi-Fi Protected Access 2 — current wireless security standard using AES-CCMP encryption.
Worm	Self-replicating malware spreading automatically through networks without user action.
X.509	Standard format for digital certificates used in PKI, SSL/TLS, and S/MIME.

Quick Revision — One Page Cheat Sheet

JAYVIK LABS — Exam Ready Summary | Network Security BCA 2026

Key Algorithms at a Glance

Algorithm	Type	Key Size	Block	Rounds	Status
DES	Symmetric	56 bits	64 bits	16	BROKEN
3DES	Symmetric	112/168 bits	64 bits	48	Deprecated
AES-128	Symmetric	128 bits	128 bits	10	SECURE ✓
AES-256	Symmetric	256 bits	128 bits	14	Military grade ✓
RSA	Asymmetric	2048-4096 bits	—	—	SECURE ✓
MD5	Hash	No key	—	—	BROKEN
SHA-256	Hash	No key	512 bits	64	SECURE ✓
SHA-3	Hash	No key	Varies	24	Latest ✓

Attack Quick Reference

Attack	Target	One-Line Description	Prevention
DoS/DDoS	Availability	Flood server with traffic	Rate limiting, CDN, Blackholing
SQL Injection	Data integrity	Inject SQL via input fields	Parameterized queries
XSS	Web users	Inject script into web page	Input validation, CSP headers
MITM	Confidentiality	Intercept communication	TLS, certificate pinning
Phishing	Users	Fake email to steal creds	MFA, security awareness training
Ransomware	Availability	Encrypt files, demand ransom	Backups, patching, email filter
Brute Force	Authentication	Try all passwords	Account lockout, MFA
ARP Poisoning	Network	Fake ARP to redirect LAN traffic	Dynamic ARP Inspection
Evil Twin	WiFi users	Fake WiFi AP same SSID	802.1X, VPN
SYN Flood	TCP layer	Half-open connections exhaust server	SYN cookies, firewall

Ports to Remember

Port	Service	Secure Version
21	FTP (plaintext)	22 SFTP / 990 FTPS

23	Telnet (plaintext)	22 SSH
25	SMTP	465/587 SMTPS
80	HTTP	443 HTTPS
110	POP3	995 POP3S
143	IMAP	993 IMAPS
389	LDAP	636 LDAPS
3389	RDP	VPN + RDP / NLA

IT Act 2000 — Must Remember Sections

Section	Crime	Punishment
Sec 43	Unauthorized hacking/damage	Up to ₹1 crore compensation
Sec 65	Tampering source code	3 years jail OR ₹2 lakh
Sec 66	Computer fraud	3 years jail OR ₹5 lakh
Sec 66C	Identity theft	3 years jail AND ₹1 lakh
Sec 66F	Cyber TERRORISM	LIFE IMPRISONMENT
Sec 67B	Child pornography	5-7 years jail AND ₹10 lakh
Sec 70	Attack on protected govt systems	10 years jail AND fine

Last Minute Tips — Before the Exam

Top 10 Most Important Topics for Solapur University Exam

1. CIA Triad — definition + example of each + which attack violates which
2. DES vs AES — key sizes, block sizes, rounds, why DES is broken
3. RSA Algorithm — key generation steps with small number example
4. Firewall types — Packet filter vs Stateful vs NGFW — compare in table
5. IDS vs IPS — NIDS vs HIDS — signature vs anomaly detection
6. VPN — SSL VPN vs IPSec VPN — tunnel mode vs transport mode
7. Digital Signature — step-by-step process diagram
8. IT Act 2000 — Section 66F (cyber terrorism = life imprisonment) always in exam!
9. WPA2 vs WPA3 — KRACK attack on WPA2, SAE in WPA3
10. Ethical Hacking — 5 phases of pen testing, white/black/grey hat

2-Mark Answer Formula

Step 1: Write DEFINITION (1 line) — use exact technical terms

Step 2: Write KEY POINTS (2-3 bullet points)

Step 3: Give ONE EXAMPLE

Total: 4-5 lines = full 2 marks

Example — 'Define Firewall' (2 marks):

Def: A firewall is a network security device that monitors and controls incoming/outgoing traffic based on predefined security rules.

Points: Acts as barrier between trusted internal and untrusted external networks. Can be hardware or software. Types: Packet filter, Stateful, NGFW.

Example: Windows Firewall, Cisco ASA, pfSense.

10-Mark Answer Formula

Introduction (2-3 lines): Define the topic

Main Content (6-7 points OR diagram + explanation):

- Always draw a DIAGRAM if possible — gets extra marks!
- Use a TABLE to compare — saves time, looks professional
- Cover: definition, working, types, advantages, disadvantages

Conclusion (1-2 lines): Summarize importance

Time: 10-mark answer should take 10-12 minutes max

Length: Fill at least 1.5 pages in answer booklet

Common Exam Mistakes to Avoid

Don't confuse Authentication (who are you?) vs Authorization (what can you do?)

Don't confuse Symmetric (1 key) vs Asymmetric (2 keys — public + private)

Don't say 'AES uses 64-bit block' — AES uses 128-bit block (DES uses 64-bit!)

Don't forget: DES = 56-bit key, 64-bit block, 16 rounds — all three together!

IDS = DETECTS only, IPS = DETECTS and PREVENTS (blocks) — common confusion!
Digital Signature = hash encrypted with PRIVATE key (not public key!)
IT Act Sec 66F = Cyber Terrorism = LIFE IMPRISONMENT — remember this always!
WPA3 uses SAE (not PSK like WPA2) — this is its key improvement

Best of luck for your exams! — **Jayvik Labs** | jayviklabs.online | +91 8855843841

REAL WORLD CASE STUDIES

These are real cyberattacks that happened globally. Understanding them helps you apply theoretical concepts to real scenarios. Each case study follows: What happened → How it worked → Technical details → Impact → Lessons learned.

Case Study 1: WannaCry Ransomware (2017)

Overview

Date: May 12, 2017
Type: Ransomware + Worm
Affected: 200,000+ computers in 150 countries
Demand: $300–$600 in Bitcoin per system
Total damage: Estimated $4–8 billion USD
Notable victims: NHS (UK hospitals), FedEx, Telefonica, Indian Railways

What Happened?

On May 12, 2017, a massive cyberattack spread across the world within hours. Computers suddenly displayed a red lock screen demanding Bitcoin payment. Hospitals in the UK could not access patient records. Factory assembly lines stopped. ATMs went offline. It was the largest ransomware attack in history at that time.

Technical Breakdown

WannaCry Attack Chain

```
Step 1: INITIAL INFECTION
  Target: Windows machines with SMBv1 enabled (port 445)
  Exploit: EternalBlue (NSA exploit leaked by Shadow Brokers group)
  CVE: CVE-2017-0144 — Buffer overflow in SMBv1

Step 2: LATERAL MOVEMENT (Worm behavior)
  WannaCry scans entire network for other vulnerable machines
  Spreads automatically — no user interaction needed
  Uses DoublePulsar backdoor to install itself on new machines

Step 3: ENCRYPTION
  Generates unique AES-128 key for each file
  Encrypts: .doc, .pdf, .jpg, .mp4, .db — 176 file types
  AES key encrypted with RSA-2048 (attacker holds RSA private key)
  Victim cannot decrypt without paying

Step 4: RANSOM NOTE
  Displays demand: "Ooops, your files have been encrypted!"
```

```
    Bitcoin wallet address shown — $300 within 3 days or $600

  Step 5: KILL SWITCH (accidental hero)
    Marcus Hutchins (UK researcher) found hardcoded domain in code
    Registered domain for £8 — attack stopped automatically!
    WannaCry checked if domain was live — if yes, it stopped spreading
```

Aspect	Detail
Exploit Used	EternalBlue — developed by NSA, leaked by Shadow Brokers
Vulnerability	SMBv1 — Windows file sharing protocol, unpatched systems
Patch Available?	YES — Microsoft released MS17-010 in March 2017 (6 weeks before attack)
Why Still Spread?	Many organizations had not applied the patch — poor patch management
Attribution	North Korean Lazarus Group (confirmed by US, UK governments)
Kill Switch	Unregistered domain — registered by researcher stopped the worm

Lessons Learned

1. PATCH MANAGEMENT is critical — apply security patches immediately
2. Disable unnecessary protocols — SMBv1 should have been disabled
3. Network segmentation — limits lateral movement of worms
4. Offline backups — only way to recover without paying ransom
5. Government exploit hoarding is dangerous — NSA exploit caused global damage
6. Even patched systems at risk if network contains unpatched machines

Case Study 2: Pegasus Spyware (2021)

Overview

Developer: NSO Group (Israeli cyber intelligence company)
Type: Advanced spyware / RAT (Remote Access Trojan)
Target: High-profile individuals — journalists, activists, politicians, heads of state
Revelation: July 2021 — "Pegasus Project" by 17 media organizations
Affected: 50,000+ phone numbers targeted across 50 countries
Notable targets: Jeff Bezos, Emmanuel Macron, Rahul Gandhi, journalists

Technical Breakdown

Feature	Details
Platform	iOS and Android — exploited zero-day vulnerabilities
Installation method	Zero-click exploit — victim does NOT need to tap/click anything
iOS exploit (2021)	iMessage zero-click — simply receiving a message installs Pegasus

Capabilities	Read all messages (WhatsApp, Signal, SMS), access camera/mic, GPS location, passwords
Persistence	Survives phone restart, hides from user, minimal battery usage
C&C Communication	Encrypts data, sends to attacker server, disguised as normal traffic
Detection	Extremely difficult — designed to be invisible even to security tools

Pegasus Zero-Click Attack Flow

```
Attacker (NSO Group client)
  |
  | Sends specially crafted iMessage/WhatsApp message
  v
TARGET PHONE (receives message silently)
  |
  | Message triggers buffer overflow in image parsing library
  | (CVE-2021-30860 — FORCEDENTRY exploit)
  v
Pegasus installed automatically — no user interaction
  |
  +-- Reads: WhatsApp, Signal, Telegram, iMessage, emails
  +-- Activates: microphone (live listening), camera
  +-- Tracks: GPS location in real-time
  +-- Captures: passwords, keystrokes, browser history
  |
  v
All data encrypted → sent to attacker C&C server
Victim has NO IDEA their phone is compromised
```

Lessons Learned

1. Zero-day exploits can compromise even fully updated devices
2. Even "secure" apps like Signal can be bypassed at OS level
3. Spyware-for-hire companies operate in legal grey areas
4. Journalists and activists need special threat models
5. Regular phone restarts and factory resets help (temporary fix)
6. iVerify and Amnesty Tech Toolkit used to detect Pegasus

Case Study 3: SolarWinds Supply Chain Attack (2020)

Overview

Date: Discovered December 2020 (attack started March 2020)
Type: Supply chain attack + APT
Vector: Trojanized software update of SolarWinds Orion (IT monitoring tool)
Affected: 18,000+ organizations including US Treasury, Pentagon, Microsoft, FireEye
Attribution: APT29 / Cozy Bear — Russian SVR intelligence agency
Considered: Most sophisticated cyberattack in history

SolarWinds Attack Chain

```
Step 1: Compromise SolarWinds build system (Oct 2019)
  Attackers infiltrate SolarWinds developer environment
  Insert malicious code (SUNBURST backdoor) into Orion software

Step 2: Trojanized update released (March 2020)
  SolarWinds releases Orion update 2020.2 — trusted, signed update
  18,000 organizations install the update — unknowingly install
backdoor

Step 3: SUNBURST backdoor activates (after 14 day delay)
  Checks if domain ends in .gov, .mil or security company — avoids
detection
  Masquerades as Orion traffic — blends with legitimate network traffic
  Beacons to attacker C&C: avsvmcloud.com

Step 4: Selective targeting
  Attackers manually select high-value targets from 18,000 compromised
orgs
  Deploy TEARDROP second-stage malware for persistent access

Step 5: Lateral movement + data theft
  Move through networks, access email systems, steal data
  Remain undetected for 9 months (March-December 2020)
```

Lessons Learned

1. Supply chain attacks bypass all perimeter defences — trusted software as weapon
2. Zero-trust architecture needed — verify everything even internal traffic
3. Software build pipelines must be secured and audited
4. Behavioral monitoring catches attacks signature-based tools miss
5. Code signing alone is insufficient — verify build environment integrity
6. Threat hunting required — passive monitoring not enough for APTs

Case Study 4: AIIMS Delhi Ransomware (2022)

Overview

Date: November 23, 2022
Type: Ransomware attack on critical healthcare infrastructure
Target: All India Institute of Medical Sciences (AIIMS), New Delhi
Impact: 5 servers compromised, ~1.3 terabytes of data encrypted
Services affected: OPD, billing, lab reports, radiology — all went offline
Duration: Manual operations for 15+ days, full recovery took weeks

This attack demonstrated the critical vulnerability of Indian healthcare infrastructure. AIIMS handles over 1.5 million patients annually. When systems went down, patients had to wait hours for manual registration. Emergency operations continued manually but efficiency dropped severely.

Aspect	Detail
Attack vector	Suspected phishing email + unpatched vulnerabilities
Data at risk	Patient records, medical history, staff data of 30+ million patients
Ransom demand	Initially reported as ₹200 crore (later denied by AIIMS)
Response	CERT-In, NIC, Delhi Police, IB involved in investigation
Attribution	Suspected Chinese state-sponsored group (not officially confirmed)
Recovery	Backups used but restoration took 2+ weeks due to scale

Lessons Learned

1. Critical infrastructure (hospitals, power, water) needs highest security priority
2. Air-gapped backups are essential — online backups get encrypted too
3. Manual fallback procedures must be rehearsed regularly
4. Network segmentation — hospital admin network separate from medical systems
5. India needs stronger cybersecurity framework for critical infrastructure
6. IT Act Section 70 covers critical infrastructure — serious legal consequences

STORY-STYLE EXPLANATIONS — Alice & Bob

The best way to understand cryptography and network security concepts is through stories. In cryptography, Alice and Bob are the two people who want to communicate securely. Eve is the eavesdropper trying to intercept. Mallory is the active attacker who modifies messages.

Story 1: Why We Need Cryptography

The Postcard Problem

Imagine Alice lives in Mumbai and wants to send her bank password to Bob in Delhi.
She writes it on a POSTCARD and mails it.

Problem: Everyone who handles the postcard — the postman, sorting office staff,
anyone — can READ the password!

This is exactly what happens when you send data over the internet WITHOUT encryption.
Your data passes through many routers, ISPs, and servers — all can read it.

Solution: Put the message in a LOCKED BOX that only Bob can open.
That locked box = ENCRYPTION.
The lock = CIPHER (DES, AES, RSA).
The key = CRYPTOGRAPHIC KEY.

Story 2: Symmetric Encryption — The Safe with One Key

Alice and Bob want to exchange secret messages. They agree on a secret key — say, the number 7.

Caesar Cipher Story (Simplest Symmetric Example)

```
Alice wants to send: "ATTACK AT DAWN"

They agreed key = 3 (shift each letter by 3)
A→D, T→W, T→W, A→D, C→F, K→N ...

Alice sends:  "DWWDFN DW GDZQ"  (encrypted)

Eve intercepts: "DWWDFN DW GDZQ" — looks like gibberish!

Bob receives it, applies key=3 in reverse:
D→A, W→T, W→T, D→A, F→C, N→K ...
Bob reads: "ATTACK AT DAWN"  ← original message!

This is symmetric encryption — SAME key to encrypt and decrypt.
Modern version: AES uses a 256-bit key instead of "3".
Problem: How do Alice and Bob share the key securely in first place?
```

```
Answer: Asymmetric encryption (RSA) solves this!
```

Story 3: Asymmetric Encryption — The Magic Padlock

Alice has a special magic padlock. She makes 1000 copies of this open padlock and sends them to everyone in the world. She keeps the KEY to herself — only she can open it.

RSA Explained as Magic Padlock

```
Bob wants to send Alice a secret message.

Step 1: Bob gets Alice's open padlock (her PUBLIC KEY)
        — freely available, anyone can have it

Step 2: Bob puts his message in a box and clicks Alice's padlock shut
        — ENCRYPTION with Alice's public key

Step 3: Bob sends the locked box to Alice
        — only Alice's KEY can open it!

Step 4: Eve intercepts the box — but she only has the padlock (public
key)
        — she CANNOT open the box without Alice's private key!

Step 5: Alice uses her PRIVATE KEY to open the padlock
        — DECRYPTION — reads Bob's message

Public Key  = The padlock (anyone can lock, no one can unlock)
Private Key = The key     (only Alice can unlock)

This is RSA — mathematically, factoring large numbers is the "magic".
```

Story 4: Digital Signature — The Wax Seal

In medieval times, kings used a unique wax seal on their letters. Anyone could READ the letter, but the seal proved it came from the king. If someone tampered with the letter and resealed it, the seal pattern would be different.

Digital Signature as Wax Seal

```
Alice (the "king") wants to send an official announcement.

Step 1: Alice writes the announcement (the message)

Step 2: Alice creates a "wax seal" (digital signature):
   → Hash the message with SHA-256 → get digest H
   → Encrypt H with Alice's PRIVATE KEY → Signature S
   → Signature S is like the unique wax seal pattern

Step 3: Alice sends: Message + Signature S
```

```
Bob receives it and wants to verify:
   → Decrypt Signature S with Alice's PUBLIC KEY → gets H1
   → Hash the received message himself → gets H2
   → If H1 == H2 → seal is genuine → message is from Alice, unmodified!
   → If H1 != H2 → tampered! Like a broken or wrong wax seal!

Non-repudiation: Alice CANNOT deny signing it.
Only her private key could create that signature.
```

Story 5: TLS/HTTPS — The Secure Glass Booth

Imagine you are in a bank. Before speaking to the teller about your account, you are taken to a special soundproof glass booth. No one outside can hear what you say. But first, the bank proves it is really the bank (not a fake counter) by showing you its official government-issued certificate.

HTTPS = ID verification + Soundproof booth

```
Step 1: You walk to the counter (browser visits website)

Step 2: Bank shows its CERTIFICATE (TLS Certificate)
   "I am SBI. Here is my certificate signed by RBI (Certificate
Authority)"
   Browser checks: Is this certificate valid? Is it signed by trusted
CA?

Step 3: If certificate is valid → you are in the real bank, not a fake!
   (Prevents MITM attacks — no one can pretend to be the bank)

Step 4: You and the teller agree on a secret code for today
   (TLS handshake → generate session key)

Step 5: All conversation in the soundproof booth
   (AES encryption with session key — HTTPS)

HTTP  = Shouting your account number in a crowded market
HTTPS = Speaking privately in a verified, soundproof booth
```

Story 6: Firewall — The Security Guard

Imagine your company office building. A security guard sits at the entrance. He has a list of rules: employees can enter, delivery people can enter only if expected, strangers are stopped. He checks ID of everyone entering and leaving.

Firewall = Security Guard with a Rule Book

```
INTERNET (outside) ⟷ FIREWALL (guard) ⟷ YOUR NETWORK (inside)

Rule 1: ALLOW — employees (192.168.x.x) to go anywhere inside
Rule 2: ALLOW — external users to access ONLY the web server (port 443)
```

```
Rule 3: BLOCK — external users accessing database server (port 3306)
Rule 4: BLOCK — everything else (default deny)

Packet Filter Firewall = Guard who only checks ID cards (IP/port)
Stateful Firewall      = Guard who remembers: "Did you go in? Yes. OK,
you can come out."
NGFW                   = Guard who checks ID + bag contents + past
behavior

Without firewall = No guard — anyone walks in!
```

Story 7: SQL Injection — The Fake Passport

Imagine a nightclub bouncer who checks names on a guest list. He asks "What is your name?" and looks it up in a book. An attacker gives a special name that tricks the system.

SQL Injection as Fake Passport Trick

```
Normal query (honest guest):
  Bouncer asks: "Name?"
  Guest: "Alice"
  Bouncer checks: SELECT * FROM guestlist WHERE name = 'Alice'
  → Found Alice → Let in!

SQL Injection (attacker):
  Attacker says: "anything' OR '1'='1"
  Query becomes: SELECT * FROM guestlist WHERE name='anything' OR
'1'='1'
  → 1=1 is ALWAYS true → Returns everyone → Attacker gets in!

  Even worse: "admin'--"
  Query: SELECT * FROM users WHERE name='admin'--' AND password='xxx'
  → -- comments out password check → Logged in as admin!

Fix: Bouncer should not let the name CHANGE the checking process.
= Parameterized queries → treat input as data, never as SQL code.
```

PRACTICAL COMMANDS — Nmap, Wireshark, iptables

Important Note

These commands are for EDUCATIONAL and AUTHORIZED use only.
Always get written permission before scanning or testing any network.
Unauthorized scanning is a criminal offence under IT Act Section 43 & 66.
Recommended practice environment: Set up a virtual lab using VirtualBox + Kali Linux.

Tool 1: Nmap — Network Mapper

Definition: Nmap

Free, open-source network scanning tool used to discover hosts, open ports, running services, and OS details on a network. Used by both attackers (reconnaissance) and defenders (network auditing).

Nmap Command Reference

```
# BASIC HOST DISCOVERY
nmap 192.168.1.1              # Scan single IP
nmap 192.168.1.1-50           # Scan IP range
nmap 192.168.1.0/24           # Scan entire subnet
nmap -iL targets.txt          # Scan from file list

# PORT SCANNING
nmap -p 80,443 192.168.1.1    # Scan specific ports
nmap -p- 192.168.1.1          # Scan ALL 65535 ports (slow)
nmap -p 1-1000 192.168.1.1   # Scan ports 1 to 1000

# SERVICE & VERSION DETECTION
nmap -sV 192.168.1.1          # Detect service versions
nmap -O 192.168.1.1           # OS detection
nmap -A 192.168.1.1           # All: OS + version + scripts +
traceroute

# SCAN TYPES
nmap -sS 192.168.1.1          # SYN/Stealth scan (default, fast)
nmap -sT 192.168.1.1          # TCP Connect scan (slower, no root
needed)
nmap -sU 192.168.1.1          # UDP scan (very slow)
nmap -sn 192.168.1.0/24       # Ping scan only (no port scan)

# VULNERABILITY SCANNING
nmap --script vuln 192.168.1.1        # Run all vuln scripts
nmap --script smb-vuln-ms17-010 IP    # Check for EternalBlue/WannaCry
nmap --script http-sql-injection IP   # Check for SQLi

# OUTPUT
nmap -oN output.txt 192.168.1.1  # Save to text file
nmap -oX output.xml 192.168.1.1  # Save to XML
```

Nmap Flag	Meaning	Use Case
-sS	SYN Stealth Scan	Fast, less detectable — default scan type
-sV	Service Version	Identify what software is running on open ports
-O	OS Detection	Guess target operating system
-A	Aggressive	All detection in one — use carefully
-p-	All ports	Thorough audit — finds non-standard ports
--script	NSE Script	Run specific vulnerability or enumeration scripts
-T4	Timing (fast)	Faster scan — T0 (slowest) to T5 (fastest)
-Pn	Skip ping	Scan even if host does not respond to ping

Tool 2: Wireshark — Packet Analyzer

Definition: Wireshark

Open-source graphical network protocol analyzer. Captures live network traffic and displays each packet in detail. Used for network troubleshooting, protocol analysis, and learning how protocols work.

Wireshark Display Filter Reference

```
# FILTER BY PROTOCOL
http              → Show only HTTP traffic
https             → Show only HTTPS
dns               → Show only DNS queries
tcp               → Show only TCP packets
udp               → Show only UDP packets
icmp              → Show only ping packets
arp               → Show ARP packets (useful for ARP poisoning
detection)

# FILTER BY IP
ip.addr == 192.168.1.1         → Any traffic to/from this IP
ip.src == 192.168.1.1          → Traffic FROM this IP only
ip.dst == 8.8.8.8              → Traffic TO this IP only
ip.addr == 10.0.0.1 && http    → HTTP from specific IP

# FILTER BY PORT
tcp.port == 80                 → HTTP traffic
tcp.port == 443                → HTTPS traffic
tcp.port == 22                 → SSH traffic

# FILTER USEFUL FOR SECURITY ANALYSIS
http.request.method == "POST"  → Find form submissions (may contain
passwords)
dns.qry.name contains "evil"   → Find suspicious DNS queries
tcp.flags.syn == 1             → Find SYN packets (SYN flood detection)
frame contains "password"      → Search all packets for keyword
```

```
"password"
```

Wireshark Common Use Cases

1. Verify HTTP traffic is unencrypted — see credentials in plain text
2. Analyze DNS queries — see what domains a host is looking up
3. Detect ARP poisoning — multiple MACs claiming same IP
4. Analyze TLS handshake — see certificate exchange (not encrypted content)
5. Debug network issues — see why connection is failing
6. Capture FTP/Telnet sessions — demonstrate why plaintext protocols are dangerous

Tool 3: iptables — Linux Firewall

Definition: iptables

Linux kernel firewall tool that allows administrators to configure packet filtering rules. Controls incoming, outgoing, and forwarded network traffic. Three main chains: INPUT, OUTPUT, FORWARD.

iptables Basic Command Reference

```
# VIEW CURRENT RULES
iptables -L                    # List all rules
iptables -L -v -n              # Verbose with packet counts, no DNS
lookup
iptables -L INPUT --line-numbers  # Show INPUT chain with line numbers

# BASIC ALLOW/BLOCK RULES
iptables -A INPUT -p tcp --dport 22 -j ACCEPT   # Allow SSH (port 22)
iptables -A INPUT -p tcp --dport 80 -j ACCEPT   # Allow HTTP
iptables -A INPUT -p tcp --dport 443 -j ACCEPT  # Allow HTTPS
iptables -A INPUT -s 192.168.1.0/24 -j ACCEPT   # Allow entire subnet
iptables -A INPUT -s 10.0.0.5 -j DROP           # Block specific IP

# DEFAULT POLICY (DENY ALL)
iptables -P INPUT DROP         # Block all incoming by default
iptables -P FORWARD DROP       # Block all forwarding by default
iptables -P OUTPUT ACCEPT      # Allow all outgoing

# STATEFUL RULES
iptables -A INPUT -m state --state ESTABLISHED,RELATED -j ACCEPT
# Allow return traffic for established connections

# DELETE RULES
iptables -D INPUT 3            # Delete rule number 3 from INPUT chain
iptables -F                    # Flush (delete) ALL rules — careful!

# SAVE RULES (persist after reboot)
iptables-save > /etc/iptables/rules.v4
```

iptables Chain	Traffic Type	Example Use
INPUT	Traffic coming INTO this machine	Block/allow connections to your server
OUTPUT	Traffic going OUT from this machine	Restrict what your server can connect to
FORWARD	Traffic passing THROUGH (routing)	Router/gateway rules between networks

Tool 4: Common Security Commands Reference

Linux Security Commands Cheat Sheet

```
# NETWORK RECONNAISSANCE
netstat -tulnp          # Show all open ports and listening services
ss -tulnp               # Modern replacement for netstat
ifconfig / ip addr      # Show network interfaces and IP addresses
route -n / ip route     # Show routing table
traceroute google.com   # Trace network path to destination

# DNS TOOLS
nslookup jayviklabs.online     # DNS lookup
dig jayviklabs.online          # Detailed DNS query
dig +short MX gmail.com        # Find mail servers for domain
whois jayviklabs.online        # Domain registration info

# PACKET CAPTURE (command line)
tcpdump -i eth0                # Capture all traffic on eth0
tcpdump -i eth0 port 80        # Capture only HTTP traffic
tcpdump -i eth0 -w capture.pcap  # Save to file for Wireshark

# LOG ANALYSIS
tail -f /var/log/auth.log      # Watch SSH login attempts live
grep "Failed password" /var/log/auth.log | tail -20  # See failed
logins
last                           # Show recent login history

# FILE INTEGRITY
md5sum filename.txt            # Generate MD5 hash of file
sha256sum filename.txt         # Generate SHA-256 hash (more secure)
diff original.txt modified.txt # Compare two files — detect tampering
```

MCQ PRACTICE — 50 Questions with Answers

These 50 multiple choice questions cover all 9 units. Answers are given at the end of each section. Try to answer before looking at the answer!

Section 1: Fundamentals (Q1–Q10)

Questions 1–10

```
Q1. Which of the following is NOT a component of the CIA Triad?
    a) Confidentiality   b) Integrity   c) Authenticity   d)
Availability

Q2. Which attack violates INTEGRITY of data?
    a) Eavesdropping   b) Data modification   c) Traffic analysis   d)
Replay attack

Q3. A firewall is an example of which type of security control?
    a) Detective   b) Corrective   c) Preventive   d) Compensating

Q4. Which layer of the OSI model does IPSec operate at?
    a) Application (L7)   b) Transport (L4)   c) Network (L3)   d) Data
Link (L2)

Q5. What does ALE stand for in risk management?
    a) Annual Loss Expectancy   b) Asset Liability Exposure
    c) Actual Loss Estimate     d) Annual Liability Evaluation

Q6. Which attack sends thousands of SYN packets without completing
handshake?
    a) MITM   b) SYN Flood   c) Phishing   d) ARP Spoofing

Q7. Non-repudiation ensures that:
    a) Data is confidential   b) Sender cannot deny sending a message
    c) Data is available      d) Data is not modified

Q8. The principle of "least privilege" means:
    a) Give users maximum access   b) Give users minimum necessary
access
    c) Deny all access by default  d) Allow all access by default

Q9. Which port does SSH use by default?
    a) 21   b) 23   c) 22   d) 25

Q10. Defence in Depth is based on which security principle?
     a) Single strong control   b) Multiple layered controls
     c) Perimeter-only security d) Trust but verify
```

Answers — Section 1

Q1: c) Authenticity — CIA = Confidentiality, Integrity, Availability
Q2: b) Data modification — changes the actual content
Q3: c) Preventive — firewall prevents attacks before they succeed
Q4: c) Network (L3) — IPSec secures IP packets at Network layer
Q5: a) Annual Loss Expectancy — ALE = SLE × ARO
Q6: b) SYN Flood — exploits TCP three-way handshake
Q7: b) Sender cannot deny sending — digital signatures provide non-repudiation
Q8: b) Give users minimum necessary access — reduces attack surface
Q9: c) 22 — Telnet uses 23, FTP uses 21, SMTP uses 25
Q10: b) Multiple layered controls — if one fails, others protect

Section 2: Cryptography (Q11–Q22)

Questions 11–22

```
Q11. DES uses a key size of:
     a) 128 bits   b) 56 bits   c) 64 bits   d) 112 bits

Q12. AES block size is:
     a) 64 bits   b) 56 bits   c) 128 bits   d) 256 bits

Q13. RSA is which type of algorithm?
     a) Symmetric   b) Hash   c) Asymmetric   d) Block cipher

Q14. Which is a hash function (not encryption)?
     a) AES   b) DES   c) RSA   d) SHA-256

Q15. Which mode of operation makes block cipher produce identical
ciphertext for identical plaintext blocks?
     a) CBC   b) CTR   c) ECB   d) CFB

Q16. Diffie-Hellman is used for:
     a) Encrypting data   b) Secure key exchange
     c) Digital signatures  d) Hashing passwords

Q17. Which hash algorithm is currently considered BROKEN/insecure?
     a) SHA-256   b) SHA-3   c) MD5   d) BLAKE2

Q18. HMAC provides:
     a) Confidentiality only   b) Authentication + Integrity
     c) Non-repudiation        d) Availability

Q19. In RSA, which key is used to ENCRYPT a message to Bob?
     a) Bob's private key   b) Alice's public key
     c) Bob's public key    d) Alice's private key

Q20. AES-256 has how many rounds?
     a) 10   b) 12   c) 14   d) 16

Q21. The Feistel structure is used in:
     a) AES   b) DES   c) SHA-256   d) RSA
```

```
Q22. Which encryption is used in HTTPS for bulk data transfer?
     a) RSA   b) DH   c) AES (symmetric)   d) SHA
```

Answers — Section 2

Q11: b) 56 bits — DES has 56-bit effective key (64-bit with parity)
Q12: c) 128 bits — AES always uses 128-bit blocks (key can be 128/192/256)
Q13: c) Asymmetric — RSA uses public/private key pair
Q14: d) SHA-256 — hash function, one-way, no decryption
Q15: c) ECB — Electronic Codebook — same input = same output (insecure!)
Q16: b) Secure key exchange — not for encryption, establishes shared secret
Q17: c) MD5 — collisions found, do not use for security
Q18: b) Authentication + Integrity — MAC verifies sender and content
Q19: c) Bob's public key — anyone can encrypt for Bob, only Bob decrypts
Q20: c) 14 — AES-128:10 rounds, AES-192:12 rounds, AES-256:14 rounds
Q21: b) DES — Feistel network with 16 rounds
Q22: c) AES (symmetric) — RSA only for key exchange in hybrid encryption

Section 3: Attacks & Defences (Q23–Q35)

Questions 23–35

```
Q23. Which attack intercepts communication between two parties
secretly?
     a) DoS   b) SQL Injection   c) MITM   d) Brute Force

Q24. WannaCry spread using which Windows vulnerability?
     a) RDP   b) SMBv1 (EternalBlue)   c) IIS   d) FTP

Q25. SQL Injection is BEST prevented by:
     a) Encryption   b) Firewall   c) Parameterized queries   d) IDS

Q26. A virus REQUIRES which of the following to spread?
     a) Network connection   b) Host file   c) Internet access   d)
User credentials

Q27. Which social engineering attack uses VOICE calls?
     a) Phishing   b) Smishing   c) Vishing   d) Baiting

Q28. An APT attack is characterized by:
     a) Fast, noisy attack   b) Long-term, stealthy access
     c) Single ransomware hit d) Simple port scan

Q29. ARP Poisoning attacks which OSI layer?
     a) Layer 7   b) Layer 4   c) Layer 3   d) Layer 2

Q30. Rainbow tables are used to attack:
     a) Firewalls   b) Password hashes   c) SSL certificates   d) VPN
tunnels
```

```
Q31. Cross-Site Scripting (XSS) injects:
     a) SQL code   b) Malicious scripts into web pages
     c) Network packets  d) Executable binaries

Q32. Which is a characteristic of a worm compared to a virus?
     a) Needs a host file   b) Spreads independently via network
     c) Requires user action d) Cannot replicate

Q33. OWASP Top 10 #1 (2021) is:
     a) SQL Injection   b) XSS   c) Broken Access Control   d) Crypto
Failures

Q34. Which attack type sends a small query to get a HUGE response?
     a) Phishing   b) Amplification attack   c) MITM   d) Brute force

Q35. Pegasus spyware is known for:
     a) Ransomware on PCs   b) Zero-click phone compromise
     c) SQL injection       d) DDoS attacks
```

Answers — Section 3

Q23: c) MITM — intercepts without either party knowing
Q24: b) SMBv1 (EternalBlue) — CVE-2017-0144, patched but unpatched systems exploited
Q25: c) Parameterized queries — treats input as data, not code
Q26: b) Host file — virus attaches to executable files
Q27: c) Vishing — Voice phishing over phone calls
Q28: b) Long-term, stealthy access — months or years undetected
Q29: d) Layer 2 — ARP operates at Data Link layer
Q30: b) Password hashes — pre-computed hash lookup tables
Q31: b) Malicious scripts into web pages — runs in victim's browser
Q32: b) Spreads independently via network — no host file needed
Q33: c) Broken Access Control — A01 in OWASP Top 10 2021
Q34: b) Amplification attack — DNS/NTP amplification DDoS
Q35: b) Zero-click phone compromise — NSO Group spyware

Section 4: Network Security (Q36–50)

Questions 36–50

```
Q36. Which firewall type tracks the STATE of TCP connections?
     a) Packet filter   b) Stateful   c) Proxy   d) Application layer

Q37. A DMZ is placed:
     a) Inside the internal network   b) Between two firewalls
     c) Outside all firewalls          d) On the ISP router

Q38. IDS detects intrusions but IPS also:
     a) Encrypts traffic   b) Blocks/prevents the attack
     c) Logs packets only  d) Forwards alerts to SIEM
```

```
Q39. Which VPN protocol is considered MOST secure and modern?
     a) PPTP   b) L2TP   c) OpenVPN   d) WireGuard

Q40. IPSec ESP provides:
     a) Authentication only   b) Encryption only
     c) Authentication + Encryption   d) Neither

Q41. TLS replaced which protocol?
     a) HTTP   b) FTP   c) SSL   d) IPSec

Q42. A digital certificate is issued by:
     a) The website owner   b) Certificate Authority (CA)
     c) Internet user       d) ISP

Q43. X.509 is a standard for:
     a) Symmetric encryption   b) Digital certificates
     c) Hash functions         d) Firewall rules

Q44. Under IT Act 2000, cyber terrorism is covered under:
     a) Section 43   b) Section 66   c) Section 66F   d) Section 67

Q45. WEP is insecure because:
     a) Uses AES incorrectly   b) IV reuse in RC4 allows key recovery
     c) No encryption at all   d) Uses MD5 for authentication

Q46. WPA3 uses which handshake to replace PSK?
     a) TKIP   b) CCMP   c) SAE (Dragonfly)   d) EAP

Q47. 802.1X is used for:
     a) Wireless encryption   b) Port-based network access control
     c) IP routing            d) DNS security

Q48. In ethical hacking, a WHITE HAT hacker:
     a) Hacks without permission   b) Hacks with permission and reports
findings
     c) Sells exploits             d) Is a government spy

Q49. KRACK attack affects:
     a) WEP   b) WPA   c) WPA2   d) WPA3

Q50. The Indian cybercrime helpline number is:
     a) 112   b) 100   c) 1930   d) 1800
```

Answers — Section 4

Q36: b) Stateful — maintains connection state table

Q37: b) Between two firewalls — public servers exposed, internal protected

Q38: b) Blocks/prevents the attack — IDS=detect, IPS=detect+prevent

Q39: d) WireGuard — modern, fast, ~4000 lines clean code

Q40: c) Authentication + Encryption — ESP is preferred over AH

Q41: c) SSL — TLS is the secure successor to SSL

Q42: b) Certificate Authority (CA) — trusted third party issues certificates
Q43: b) Digital certificates — X.509 is the standard format
Q44: c) Section 66F — punishment: LIFE IMPRISONMENT
Q45: b) IV reuse in RC4 — allows FMS attack to recover key in minutes
Q46: c) SAE (Dragonfly) — Simultaneous Authentication of Equals
Q47: b) Port-based network access control — authenticate before network access
Q48: b) Hacks with permission and reports findings — ethical hacking
Q49: c) WPA2 — Key Reinstallation Attack on 4-way handshake
Q50: c) 1930 — National Cyber Crime Helpline, cybercrime.gov.in

TOP 50 INTERVIEW QUESTIONS — Network Security

These are the most commonly asked questions in campus placements, internship interviews, and job interviews for roles like Security Analyst, Network Engineer, SOC Analyst, and IT Support.

Basic Level (Q1–Q15)

Q: Q1. What is the CIA Triad? [2 Marks Marks]

Ans: CIA Triad = Confidentiality + Integrity + Availability. Confidentiality: only authorized users access data (encryption). Integrity: data is not tampered (hashing, digital signatures). Availability: systems accessible when needed (redundancy, DDoS protection). All three must be balanced — security is not just about hiding data.

Q: Q2. What is the difference between a virus and a worm? [2 Marks Marks]

Ans: Virus: attaches to a host file, needs user action to spread (running infected file), cannot spread on its own. Worm: standalone malware, spreads automatically through networks without user interaction. Worm is more dangerous for network spread (e.g., WannaCry). Both are malware but differ in spreading mechanism.

Q: Q3. What is a firewall? What are its types? [5 Marks Marks]

Ans: Firewall: network security device that monitors and controls traffic based on rules. Acts as barrier between trusted internal and untrusted external networks. Types: (1) Packet Filter — inspects IP/port headers only, fast but basic. (2) Stateful — tracks TCP connection state, more secure. (3) Proxy Firewall — deep inspection, acts as intermediary. (4) NGFW (Next-Gen) — application awareness, DPI, user identity, SSL inspection. Hardware firewalls: Cisco ASA, Palo Alto. Software firewalls: Windows Defender Firewall, iptables.

Q: Q4. What is the difference between IDS and IPS? [2 Marks Marks]

Ans: IDS (Intrusion Detection System): monitors network traffic, detects attacks, sends ALERTS — does NOT block. Passive system. IPS (Intrusion Prevention System): monitors AND actively BLOCKS attacks in real-time. Inline device. IDS = security camera that records. IPS = security guard who physically stops intruder. Both use signature-based and anomaly-based detection.

Q: Q5. What is a VPN and how does it work? [5 Marks Marks]

Ans: VPN (Virtual Private Network) creates an encrypted tunnel over the internet between your device and a VPN server. All your traffic passes through this tunnel — your ISP and others see only encrypted data. Working: (1) VPN client negotiates connection with VPN server. (2) Keys exchanged securely (IPSec/TLS). (3) All data encrypted end-to-end. (4) Your public IP appears as VPN server's IP. Uses: remote work (access office network), privacy (hide from ISP), bypass geo-restrictions. Protocols: IPSec, OpenVPN, WireGuard.

Q: Q6. What is phishing? How do you identify a phishing email? [5 Marks Marks]

Ans: Phishing: attacker sends fake email pretending to be a trusted entity (bank, company, government) to trick victim into revealing credentials or installing malware. Identification signs: (1) Sender email domain is slightly wrong (e.g., support@micros0ft.com). (2) Urgent language: "Act now or account will be closed!" (3) Suspicious links — hover shows different URL. (4) Request for password/OTP/card details — legitimate companies NEVER ask this via email. (5) Grammar/spelling mistakes. (6) Generic greeting: "Dear Customer" instead of your name. Prevention: MFA, email filtering, security awareness training.

Q: Q7. What is two-factor authentication (2FA)? [2 Marks Marks]

Ans: 2FA adds a second verification step beyond password. Three factor types: Something you KNOW (password), Something you HAVE (phone OTP, hardware token), Something you ARE (fingerprint, face ID). 2FA combines two of these. Even if attacker steals password, they cannot log in without the second factor. Most common: SMS OTP (weakest due to SIM swapping), Authenticator app (Google/Microsoft Authenticator — better), Hardware key (YubiKey — strongest).

Q: Q8. What is SQL injection and how is it prevented? [5 Marks Marks]

Ans: SQL injection: attacker inserts malicious SQL code into input fields to manipulate database queries. Example: entering ' OR '1'='1 in login form bypasses password check. Impact: unauthorized access, data theft, data deletion, admin account takeover. Prevention: (1) Parameterized queries/prepared statements — MOST EFFECTIVE. (2) Input validation — reject unexpected characters. (3) Least privilege DB accounts. (4) WAF (Web Application Firewall). (5) Error handling — never show raw DB errors. OWASP rates SQL injection in Top 10 web vulnerabilities.

Q: Q9. Explain symmetric vs asymmetric encryption. [5 Marks Marks]

Ans: Symmetric: same key for encryption and decryption. Fast — suitable for large data. Problem: secure key distribution. Examples: AES, DES. Asymmetric: two mathematically linked keys — public key (encrypt) and private key (decrypt). Slower. Solves key distribution. Examples: RSA, ECC. In practice, HYBRID encryption combines both: RSA to securely exchange an AES session key, then AES for data. This is how HTTPS works.

Q: Q10. What is a digital certificate? Who issues it? [2 Marks Marks]

Ans: A digital certificate (X.509) is an electronic document that binds a public key to an identity (domain name, organization). Contains: subject name, public key, validity dates, issuer, CA's digital signature. Issued by Certificate Authority (CA) — trusted third party. Examples: DigiCert, Let's Encrypt, Comodo. Browser trusts certificate because CA is pre-installed in browser trust store. Used in HTTPS to verify you are talking to the real website, not an impostor.

Q: Q11. What is the IT Act 2000? What is Section 66F? [5 Marks Marks]

Ans: IT Act 2000 (Information Technology Act) is India's primary law governing cybercrime and electronic commerce. Key sections: Sec 43 — hacking/unauthorized access (civil — up to ₹1 crore). Sec 66 — computer fraud (3 years jail). Sec 66C — identity theft (3 years). Sec 67 — publishing obscene content. Section 66F — CYBER TERRORISM: deliberate attacks on critical infrastructure (power grid, banking, defense systems) threatening national security. Punishment: LIFE IMPRISONMENT. This is the most severe punishment in the IT Act.

Q: Q12. What is a honeypot? [2 Marks Marks]

Ans: A honeypot is a decoy computer system designed to attract attackers. It appears to be a legitimate target with valuable data but is actually isolated and heavily monitored. Purpose: detect attacks early, study attacker techniques, waste attacker time, gather threat intelligence. Types: Low-interaction (simulates services) and High-interaction (full real system). When an attacker connects to a honeypot, security team is alerted — real systems are protected.

Q: Q13. What is the difference between authentication and authorization? [2 Marks Marks]

Ans: Authentication: verifying WHO you are. Prove your identity. Methods: password, OTP, biometrics, certificates. Example: logging into Gmail — Gmail verifies you are the account owner. Authorization: verifying WHAT you are allowed to do. Access control after authentication. Example: after logging into Gmail, you can only read your own emails, not others. Authentication comes first, then authorization. AAA framework: Authentication + Authorization + Accounting (logging).

Q: Q14. What is WPA3 and why is it better than WPA2? [5 Marks Marks]

Ans: WPA3 (Wi-Fi Protected Access 3) is the latest WiFi security standard (2018). Improvements over WPA2: (1) SAE (Simultaneous Authentication of Equals) replaces PSK — immune to offline dictionary attacks even if handshake captured. (2) Forward Secrecy — past sessions remain secure even if password later compromised. (3) OWE — encrypts open/public WiFi networks. (4) Mandatory PMF (Protected Management Frames) — prevents deauthentication attacks. (5) 192-bit security mode for enterprise. WPA2 vulnerabilities fixed: KRACK attack, offline handshake capture, deauth attacks.

Q: Q15. What is the OWASP Top 10? [2 Marks Marks]

Ans: OWASP (Open Web Application Security Project) Top 10 is a list of the 10 most critical web application security risks, updated periodically. 2021 list: A01-Broken Access Control, A02-Cryptographic Failures, A03-Injection (SQLi/XSS), A04-Insecure Design, A05-Security Misconfiguration, A06-Vulnerable Components, A07-Authentication Failures, A08-Software Integrity Failures, A09-Logging Failures, A10-SSRF. Used by developers as security checklist and by testers as testing guide.

Advanced Level (Q16–Q25)

Q: Q16. Explain the TLS handshake process. [10 Marks Marks]

Ans: TLS (Transport Layer Security) handshake establishes a secure connection. Steps: (1) ClientHello — client sends supported TLS version, cipher suites, random number. (2) ServerHello — server chooses cipher suite, sends its certificate and random number. (3) Certificate Verification — client verifies server certificate against trusted CA. (4) Key Exchange — client generates pre-master secret, encrypts with server's public key, sends it. (5) Session Key Derivation — both sides derive the same symmetric session key from randoms + pre-master secret. (6) ChangeCipherSpec + Finished — both sides confirm switching to encrypted mode. After handshake: all data encrypted with AES using the session key. TLS 1.3 improvements: 1-RTT (faster), removed weak ciphers, perfect forward secrecy mandatory.

Q: Q17. What is a MITM attack? How do you prevent it? [5 Marks Marks]

Ans: MITM (Man-in-the-Middle): attacker secretly intercepts and possibly modifies communication between two parties who believe they are communicating directly. Techniques: ARP poisoning (LAN), Evil Twin WiFi AP, SSL stripping, DNS spoofing. Example: on public WiFi, attacker performs ARP poisoning, all your traffic routes through their machine — they see unencrypted data. Prevention: (1) HTTPS everywhere — TLS prevents reading content. (2) Certificate pinning — app rejects unexpected certificates. (3) HSTS — browser forced to use HTTPS. (4) VPN on public networks. (5) 802.1X authentication on WiFi.

Q: Q18. What is penetration testing? What are its phases? [10 Marks Marks]

Ans: Penetration testing (pen test) is an authorized simulated attack on a system to find vulnerabilities before malicious attackers do. Phases: (1) Planning — define scope, get written authorization, rules of engagement. (2) Reconnaissance — passive (OSINT, WHOIS) and active (Nmap scanning). (3) Scanning — vulnerability scanning (Nessus), service enumeration. (4) Exploitation — use found vulnerabilities to gain access (Metasploit). (5) Post-Exploitation — privilege escalation, lateral movement, data access testing. (6) Reporting — document all findings, CVSS severity ratings, remediation recommendations, executive summary. Key: ALWAYS have written authorization. Without it, same activity is criminal.

Q: Q19. What is ransomware? How does WannaCry work? [10 Marks Marks]

Ans: Ransomware: malware that encrypts victim's files and demands payment (usually cryptocurrency) for decryption key. WannaCry (2017): exploited EternalBlue vulnerability (CVE-2017-0144) in Windows SMBv1. Mechanism: (1) Infected via EternalBlue exploit on port 445. (2) Worm component spread to other vulnerable machines automatically. (3) Encrypted files using AES-128 (unique key per file), AES key encrypted with RSA-2048. (4) Demanded $300-600 Bitcoin. (5) Kill switch: checking unregistered domain — registering it stopped spread. Impact: 200,000+ computers, 150 countries. Prevention: patch management, disable SMBv1, network segmentation, offline backups, email filtering.

Q: Q20. What is PKI? Explain chain of trust. [10 Marks Marks]

Ans: PKI (Public Key Infrastructure): complete system for managing digital certificates and public-key encryption to establish trust at scale. Chain of Trust: Root CA → Intermediate CA → End-entity Certificate. Root CA: self-signed, pre-installed in all browsers/OS, offline for security. Intermediate CA: signed by Root, issues website certificates, can be revoked without invalidating Root. End-entity cert: issued to website (e.g., jayviklabs.online), contains public key. Browser verification: receive certificate → check signed by known Intermediate CA → check Intermediate signed by Root CA → Root in trust store → TRUSTED! Revocation: CRL (list of revoked certs) or OCSP (real-time check). Real CAs: DigiCert, Let's Encrypt, GlobalSign.

Q: Q21. Explain the Diffie-Hellman key exchange. [5 Marks Marks]

Ans: Diffie-Hellman solves: how to establish a shared secret over an insecure channel without transmitting the secret. Math: both agree on public values g (generator) and p (large prime). Alice picks secret a, computes A=g^a mod p, sends A. Bob picks secret b, computes B=g^b mod p, sends B. Alice computes B^a mod p = g^(ab) mod p. Bob computes A^b mod p = g^(ab) mod p. Both get same secret g^(ab) mod p. Attacker sees A, B, g, p — cannot compute g^(ab) without solving discrete logarithm (computationally infeasible for 2048+ bit primes). Used in TLS, SSH, IPSec for session key establishment.

Q: Q22. What is a SOC? What tools do they use? [5 Marks Marks]

Ans: SOC (Security Operations Center): 24/7 centralized facility where security professionals monitor, detect, analyze, and respond to cybersecurity incidents. Roles: Tier 1 Analyst (monitor SIEM alerts, triage), Tier 2 (investigate escalated incidents), Tier 3 (threat hunting, malware analysis), Incident Responder (handle active breaches), SOC Manager. Tools: SIEM (Splunk, IBM QRadar, Microsoft Sentinel) — aggregates and correlates logs. EDR (CrowdStrike, SentinelOne) — endpoint detection. Threat Intelligence platforms — IOC feeds. SOAR — automates response workflows. Ticketing — ServiceNow, Jira.

Q: Q23. What is the difference between NIDS and HIDS? [5 Marks Marks]

Ans: NIDS (Network IDS): deployed at network chokepoints (behind firewall, on DMZ segment), monitors all network traffic, detects network-level attacks, single sensor protects many hosts. Cannot see encrypted traffic content. HIDS (Host IDS): installed on individual hosts, monitors system calls, file integrity, logs, processes. Detects: rootkits, privilege escalation, insider threats, host-level events. Can see decrypted traffic. Best practice: deploy BOTH — NIDS for network-level detection, HIDS for host-level. Combined with SIEM for centralized analysis.

Q: Q24. What is a supply chain attack? Give an example. [5 Marks Marks]

Ans: Supply chain attack: instead of attacking the target directly (which may have strong defences), attacker compromises a trusted third-party vendor/software/service used by the target. The malicious code enters target systems through a trusted update or dependency. Example: SolarWinds (2020) — attackers inserted SUNBURST backdoor into SolarWinds Orion software update. 18,000 organizations installed the trojanized update. Attackers then selectively attacked US government agencies. Why dangerous: bypasses all perimeter defences because the malicious software is trusted and digitally signed. Prevention: software integrity verification, secure build pipelines, zero-trust, vendor security assessment.

Q: Q25. What is zero-day vulnerability? Why is it dangerous? [5 Marks Marks]

Ans: Zero-day: a software vulnerability that is unknown to the software vendor and has no patch available. Called "zero-day" because the vendor has had zero days to fix it. Dangerous because: (1) No patch exists — all users vulnerable. (2) No signatures in AV/IDS — cannot detect attacks. (3) High value — sold on dark web for millions. (4) Nation-states stockpile zero-days for cyber weapons (e.g., EternalBlue by NSA, Pegasus zero-clicks). Defence: behavioural detection (anomaly-based IDS), sandboxing, network segmentation to limit blast radius, threat intelligence feeds, bug bounty programs to find vulnerabilities before attackers.

SOLVED UNIVERSITY PAPER PATTERN

Solapur University — BCA Network Security Exam Pattern

Total Marks: 80 (written) + 20 (practical/internal) = 100

Duration: 3 hours

Sections: Usually 5 sections with choice

Section A: Short answer — 2 marks each (attempt any 5 from 8)

Section B: Medium answer — 5 marks each (attempt any 4 from 6)

Section C: Long answer — 10 marks each (attempt any 2 from 4)

Section D: OR-based long answers — 10 marks each

Tip: Diagrams and tables get extra marks — always draw when possible!

Sample Paper — Network Security (BCA Sem 5/6)

SECTION A — Short Answer (2 Marks each, Attempt any 5)

Q1. Define CIA Triad with one example of each.

Q2. What is the difference between a virus and a worm?

Q3. Define digital signature and state its uses.

Q4. What is Section 66F of IT Act 2000?

Q5. What is WPA3? How is it better than WPA2?

Q6. Define honeypot and its purpose.

Q7. What is the difference between IDS and IPS?

Q8. What is HTTPS? Which protocol secures it?

SECTION B — Medium Answer (5 Marks each, Attempt any 4)

Q1. Explain DES algorithm with a neat diagram of Feistel structure.

Q2. Explain different types of network attacks with examples.

Q3. What is a firewall? Compare packet filtering and stateful inspection firewalls.

Q4. Explain public key infrastructure (PKI) with chain of trust diagram.

Q5. Explain WannaCry ransomware attack. What vulnerability did it exploit?

Q6. Explain the phases of penetration testing.

SECTION C — Long Answer (10 Marks each, Attempt any 2)

Q1. Explain AES algorithm in detail. Compare DES, 3DES, and AES.

Q2. Explain RSA algorithm with key generation and example. Why is it secure?

Q3. Explain IT Act 2000 — objectives, important sections with punishments.

Q4. Explain TLS handshake in detail. Why is HTTPS important for security?

Model Answers — Section A

Q: A1. Define CIA Triad with examples. [2 Marks Marks]

Ans: CIA Triad: three fundamental goals of information security. (1) CONFIDENTIALITY: only authorized users can access data. Example: AES encryption on a database — even if hacker steals the file, cannot read it. (2) INTEGRITY: data is accurate and unmodified. Example: SHA-256 hash of a downloaded file — if hash matches, file is not tampered. (3) AVAILABILITY: systems and data are accessible when needed. Example: load balancer + backup server ensures website stays online even if one server fails.

Q: A4. What is Section 66F of IT Act 2000? [2 Marks Marks]

Ans: Section 66F deals with CYBER TERRORISM. It applies when a person intentionally threatens the unity, integrity, security or sovereignty of India through computer systems — such as attacking critical infrastructure (power grid, banking systems, defense networks), introducing malware into critical systems, or denying access to authorized personnel. This is the most severe provision of the IT Act. Punishment: LIFE IMPRISONMENT.

Model Answers — Section B

Q: B3. Compare packet filtering and stateful inspection firewalls. [5 Marks Marks]

Ans: Packet Filtering Firewall: examines each packet independently based on source IP, destination IP, port number, and protocol. No memory of previous packets. Fast but less secure. Cannot detect attacks that span multiple packets. Example: iptables basic rules. Stateful Inspection Firewall: maintains a state table of active TCP/UDP connections. Checks if incoming packet is part of established, allowed session. More secure than packet filter — can block unsolicited inbound packets that match no active connection. Can detect half-open connection attacks (SYN flood). Example: iptables with connection tracking, Cisco ASA. Packet filter = bouncer checking ID. Stateful = bouncer who remembers "I let you in, so I know this is your return trip."

Q: B6. Explain the phases of penetration testing. [5 Marks Marks]

Ans: Penetration testing phases: (1) Planning & Reconnaissance: define scope, get written authorization. Passive recon: OSINT, WHOIS, LinkedIn. Active recon: Nmap port scan. (2) Scanning & Enumeration: run vulnerability scanner (Nessus), enumerate services, banner grabbing. (3) Exploitation: attempt to exploit found vulnerabilities using Metasploit or manual exploits. Password attacks if login pages found. (4) Post-Exploitation: if access gained — check privilege escalation, lateral movement, what data accessible. (5) Reporting: document ALL findings with evidence, CVSS risk scores, remediation recommendations, executive summary for management + technical details for IT team.

Model Answers — Section C

Q: C3. Explain IT Act 2000 — objectives, sections, punishments. [10 Marks Marks]

Ans: IT Act 2000 (Information Technology Act): India's primary law for cybercrime, electronic commerce, and digital signatures. Enacted: October 17, 2000. Amended: 2008 (significant strengthening). Objectives: (1) Provide legal recognition to electronic transactions. (2) Facilitate e-governance and e-commerce. (3) Prevent computer crimes. (4) Protect data privacy. Key

Sections: Sec 43 — unauthorized access/hacking — compensation up to ₹1 crore (civil). Sec 65 — tampering source code — 3 years jail OR ₹2 lakh. Sec 66 — computer fraud — 3 years jail OR ₹5 lakh. Sec 66C — identity theft — 3 years AND ₹1 lakh. Sec 66D — cheating by impersonation online — 3 years AND ₹1 lakh. Sec 66E — privacy violation (capturing private images) — 3 years OR ₹2 lakh. Sec 66F — CYBER TERRORISM — LIFE IMPRISONMENT. Sec 67 — obscene content — 5 years AND ₹10 lakh. Sec 67B — child pornography — 5-7 years AND ₹10 lakh. Sec 70 — attacking protected government systems — 10 years AND fine. Sec 72 — breach of confidentiality — 2 years OR ₹1 lakh. Report cybercrime: cybercrime.gov.in | Helpline: 1930.

All the best for your exams! — **Jayvik Labs** | jayviklabs.online | +91 8855843841

Previous Year Pattern Q&A

Questions modeled on Solapur University BCA examination patterns. Practice these before your exam.

Exam Pattern (Typical)

Section A: Short Answer — Attempt any 5 out of 8 questions [2 Marks each = 10 Marks]

Section B: Medium Answer — Attempt any 4 out of 6 questions [5 Marks each = 20 Marks]

Section C: Long Answer — Attempt any 2 out of 4 questions [10 Marks each = 20 Marks]

Total: 50 Marks | Duration: 2.5 Hours

Section A — 2 Mark Questions

Unit 1 — Introduction

Q: Define Network Security. [2M Marks]

Ans: Network Security refers to policies, practices, and technologies designed to protect computer networks and the data they carry from unauthorized access, misuse, modification, or denial — ensuring confidentiality, integrity, and availability.

Q: What is the CIA Triad? [2M Marks]

Ans: CIA Triad: Confidentiality (data accessible only to authorized users), Integrity (data is accurate and unmodified), Availability (systems accessible when needed). These are the three fundamental goals of information/network security.

Q: Define Active Attack and Passive Attack. [2M Marks]

Ans: Passive Attack: Only monitors/observes communication without modifying data (e.g., eavesdropping). Hard to detect. Active Attack: Modifies, disrupts, or fabricates data (e.g., DoS, replay). Violates integrity and availability.

Unit 2 — Cryptography

Q: What is Encryption and Decryption? [2M Marks]

Ans: Encryption: Converting readable plaintext into unreadable ciphertext using a key and algorithm. Decryption: Converting ciphertext back to readable plaintext using a key. Together they provide confidentiality in communication.

Q: What is a Hash Function? [2M Marks]

Ans: A hash function is a one-way mathematical function that takes input of any size and produces a fixed-size output called hash/digest. It is irreversible — cannot find original input from hash. Used for data integrity, password storage, and digital signatures.

Q: State the key size and block size of AES. [2M Marks]

Ans: AES uses a block size of 128 bits. Key sizes: AES-128 (128-bit key, 10 rounds), AES-192 (192-bit key, 12 rounds), AES-256 (256-bit key, 14 rounds). AES is the current standard symmetric encryption algorithm.

Unit 3 — Authentication

Q: What is Kerberos? [2M Marks]

Ans: Kerberos is a network authentication protocol that uses tickets to allow nodes to prove identity securely over an insecure network. It uses a trusted third party (Key Distribution Center) and symmetric key cryptography. Provides Single Sign-On.

Q: What is a Digital Certificate? [2M Marks]

Ans: A digital certificate (X.509) is an electronic document that binds a public key to an identity. It is issued and signed by a Certificate Authority (CA). It contains: subject name, public key, validity period, issuer (CA) name, and CA's digital signature.

Unit 4 — Attacks

Q: What is DoS attack? [2M Marks]

Ans: DoS (Denial of Service) is an attack that makes network resources unavailable to legitimate users by overwhelming them with illegitimate traffic/requests. Consumes bandwidth, memory, or CPU. Example: SYN Flood — sends many SYN packets without completing TCP handshake.

Q: Differentiate Virus and Worm. [2M Marks]

Ans: Virus: Attaches to host files, needs user action to spread, replicates with host. Worm: Standalone, self-replicating, spreads automatically through networks without user action. Both are types of malware but differ in how they spread.

Unit 5 — Firewalls & VPN

Q: What is a Firewall? [2M Marks]

Ans: A firewall is a network security device that monitors and controls incoming/outgoing traffic based on security rules. It acts as a barrier between trusted internal networks and untrusted networks. Types: Packet filter, Stateful, Proxy, NGFW.

Q: What is VPN? State its use. [2M Marks]

Ans: VPN (Virtual Private Network) creates a secure encrypted tunnel over a public network (Internet). Use: Allows remote employees to securely access company network, protects data on public Wi-Fi, connects branch offices securely, bypasses geographic restrictions.

Section B — 5 Mark Questions

Q: Explain CIA Triad with examples. [5M Marks]

Ans: 1. CONFIDENTIALITY: Ensures data accessible only to authorized users. Example: Only account holder can see bank details. Protection: Encryption (AES, RSA), VPN, Access Control. Threat: Eavesdropping. 2. INTEGRITY: Ensures data is accurate and unmodified. Example: Bank transfer of Rs.1000 should reach as Rs.1000. Protection: Hash functions (SHA-256), Digital Signatures. Threat: Data modification attacks. 3. AVAILABILITY: Ensures systems accessible when needed. Example: ATM should work 24/7. Protection: Redundancy, load balancing, DDoS protection. Threat: DoS/DDoS attacks.

Q: Compare DES and AES. [5M Marks]

Ans: DES (1977): 64-bit block, 56-bit key, 16 rounds, Feistel network, broken (cracked in 22 hours in 1999), deprecated. AES (2001): 128-bit block, 128/192/256-bit key, 10/12/14 rounds, substitution-permutation network, currently secure, widely used. AES advantages over DES: Larger block size (128 vs 64), variable key sizes (up to 256-bit vs 56-bit), faster performance, resistant to all known attacks. AES was selected by NIST after DES became insecure due to its short 56-bit key.

Q: Explain Digital Signature with diagram. [5M Marks]

Ans: Digital signature provides authentication, integrity, and non-repudiation. SIGNING: Sender creates hash of message using hash function (SHA-256). Hash encrypted with sender's PRIVATE KEY = Digital Signature. Send Message + Digital Signature. VERIFICATION: Receiver decrypts signature using sender's PUBLIC KEY = Hash 1. Receiver independently hashes received message = Hash 2. Compare Hash 1 and Hash 2. If equal: signature valid — message not tampered, sender confirmed. PROPERTIES: Authentication (proves who sent), Integrity (proves no modification), Non-repudiation (sender cannot deny).

Q: Explain types of Firewalls. [5M Marks]

Ans: 1. PACKET FILTERING: Checks IP/port rules per packet. Fast but no state awareness. 2. STATEFUL INSPECTION: Tracks connection state table. Smarter — knows if packet belongs to existing connection. 3. APPLICATION GATEWAY (PROXY): Layer 7, acts as proxy, understands application protocols (HTTP/FTP), deep content inspection, slowest but most thorough. 4. NEXT-GEN FIREWALL: Combines DPI, IDS/IPS, application awareness, user identity. Most comprehensive.

Q: Explain WEP and WPA2 wireless security protocols. [5M Marks]

Ans: WEP (1997): RC4 encryption, 40/104-bit key, 24-bit IV. INSECURE: Small IV causes reuse, attackers XOR ciphertexts to recover key, cracked in minutes by Aircrack-ng. Never use WEP. WPA2 (2004): AES-CCMP encryption, 128-bit key, dynamic keys per session, 4-Way Handshake for key agreement. Two modes: WPA2-Personal (PSK — password, for home), WPA2-Enterprise (802.1X with RADIUS server, for corporate). WPA2 is the current standard. Known vulnerability: KRACK attack (Key Reinstallation Attack) — fixed by software patches. Use WPA3 for new deployments.

Section C — 10 Mark Questions

Q: Explain RSA algorithm with key generation, encryption, and decryption. [10M Marks]

Ans: RSA is asymmetric encryption based on integer factorization. KEY GENERATION: 1. Choose large primes p, q. 2. n = p×q. 3. ϕ(n) = (p-1)(q-1). 4. Choose e: 1 < e < ϕ(n) and gcd(e,ϕ(n))=1. 5. Find d: d×e ≡ 1 mod ϕ(n). Public Key = (e,n). Private Key = (d,n). EXAMPLE: p=61, q=53. n=3233. ϕ(n)=3120. e=17. d=2753. ENCRYPTION: C = M^e mod n. (Anyone with public key can encrypt). DECRYPTION: M = C^d mod n. (Only holder of private key can decrypt). SECURITY: Based on fact that factoring n back to p and q is computationally infeasible for large n (2048+ bits). APPLICATIONS: HTTPS, email encryption, digital signatures, VPN key exchange.

Q: Explain Kerberos authentication system in detail with diagram. [10M Marks]

Ans: Kerberos is a network authentication protocol using trusted third party (KDC). COMPONENTS: KDC (Key Distribution Center), AS (Authentication Server), TGS (Ticket Granting Server), TGT (Ticket Granting Ticket), ST (Service Ticket). PROCESS: Step 1: Client sends username to AS. Step 2: AS verifies user, sends TGT encrypted with user's password-derived key + session key. Step 3: Client decrypts TGT, sends it to TGS with service request. Step 4: TGS verifies TGT, issues Service Ticket (ST) for requested service. Step 5: Client presents ST to service. Step 6: Service verifies ST without contacting KDC — grants access. ADVANTAGES: Single Sign-On, mutual authentication, passwords never sent over network, tickets are time-limited. DISADVANTAGES: Single point of failure (if KDC down, no logins), clock synchronization required (±5 minutes), complex setup.

Q: Explain DoS and DDoS attacks with types and prevention. [10M Marks]

Ans: DoS (Denial of Service): Attacker sends massive traffic to overwhelm target. TYPES: 1. SYN Flood: Sends many TCP SYN packets without completing handshake, exhausting connection table. 2. Ping of Death: Oversized ICMP packets crash target. 3. UDP Flood: Random UDP packets overwhelm bandwidth. 4. HTTP Flood: Massive GET/POST requests crash web server. DDoS (Distributed DoS): Uses botnet (thousands of compromised computers) to simultaneously attack. Harder to block — traffic from many IPs. BOTNET: Attacker infects computers with malware, controls via C&C server, launches coordinated attack. PREVENTION: Rate limiting, SYN cookies, ingress filtering, CDN/DDoS protection (Cloudflare), black hole routing, IDS/IPS, anycast network diffusion, load balancing.

Q: Explain IPSec and its protocols AH and ESP with modes. [10M Marks]

Ans: IPSec is a suite of protocols providing security at IP layer. PROTOCOLS: 1. AH (Authentication Header): Provides authentication and integrity. Creates hash of entire packet. Receiver verifies hash. Does NOT encrypt data. Protects against replay attacks using sequence numbers. 2. ESP (Encapsulating Security Payload): Provides confidentiality (encryption) + authentication + integrity. Encrypts IP payload. More commonly used than AH. MODES: Transport Mode: Protects only IP payload (data), IP header unchanged. Used for host-to-host communication. Lower overhead. Tunnel Mode: Entire original IP packet encrypted and encapsulated in new IP packet. Used for VPNs (gateway-to-gateway). Original IP header hidden. Higher security. SECURITY ASSOCIATION (SA): One-way relationship defining cryptographic parameters (algorithm, key). AH + ESP together provide complete security. IKE (Internet Key Exchange) negotiates SA parameters and manages keys automatically.